FortiPAM Workshop

Hands-On LAB Guide v1.9 Fundamentals

Table of Contents

1 FORTIPAM 1.9 HANDS-ON LAB 5

1.1 TIMING 5

2 LAB SETUP OVERVIEW 6

2.1 IMPORTANT NOTES ABOUT THE LABS 6
2.2 TOPOLOGY 6

3 ACCESS AND CREDENTIALS 7

3.1 RDP ACCESS 7
3.2 EMS SERVER ACCESS 7

4 INITIAL PROVISIONING 8

4.1 FORTIPAM 8
4.1.1 LOAD CONFIGURATION FILE: FPAM CONFIG 03 8
4.1.2 SETUP WIZARD 9
4.1.3 CONFIGURE OTHER INTERFACES 11
4.1.4 CONFIGURE EMAIL ALERT SETTINGS 15
4.1.5 CONFIGURE LOGIN DISCLAIMER 18
4.2 SETUP WINDOWS WORKSTATION 18
4.2.1 INSTALL FORTIPAM EXTENSION FOR GOOGLE CHROME 19
4.2.2 MANUAL INSTALLATION OF BROWSER EXTENSIONS (FYI) 20

5 SETUP FORTIPAM FOR CONTRACTOR (EXTERNAL) ACCESS 21

5.1 CREATE USERS AND GROUPS FOR CONTRACTORS 21
5.2 CREATE FOLDERS AND SECRETS FOR CONTRACTOR USERS 27
5.2.1 EXPLAINING FOLDERS 27
5.2.2 CREATE FOLDER 28
5.2.3 CREATE TARGET 29
5.2.4 WHAT IS A SECRET? 30
5.2.5 CREATE SECRET 33
5.3 TEST CONTRACTOR ACCESS 39
5.3.1 CUSTOMER SECRET TEMPLATE 42
5.3.2 USING THE GUEST USER FOR CONTRACTORS 45
5.3.3 ENABLE SESSION RECORDING 46
5.3.4 FAVORITE SECRETS 48
5.4 MODIFY VIDEO RECORDING SETTINGS 49
5.4.1 TEST MODIFIED RECORDING SETTINGS 50

6 ENABLE FORTIPAM FOR EMPLOYEE ACCESS 52

6.1 CREATE EMPLOYEE USERS AND GROUPS 52
6.1.1 CONFIGURE LDAP SERVER 53

6.1.2 Create Groups ... 55
6.1.3 Create Auto Provisioning Rule ... 56
6.1.4 Test Employee User Login ... 57
6.1.5 Admin User Usage ... 60
6.2 Setup FortiClient for PAM ... 60
6.2.1 Explaining ZTNA ... 61
6.2.2 How ZTNA Relates to FortiPAM ... 64
6.2.3 Install FortiClient on Windows Workstation ... 66
6.2.4 Register Windows Workstation with EMS ... 67
6.2.5 Review EMS Server Configuration ... 69
6.3 Setup Employee Folder and Secrets ... 71
6.3.1 Create Employee Folder ... 71
6.3.2 Create Employee Secrets ... 71
6.3.3 Test Employee Secrets ... 74
6.3.4 View the Logs ... 76

7 ENABLE ZTNA SECURITY FEATURES ... 78

7.1 Fortinet Zero Trust Network Access: An Architectural Overview ... 78
7.1.1 Core Architectural Components ... 78
7.1.2 The Role of FortiPAM in ZTNA Architecture ... 78
7.1.3 Deployment Models ... 79
7.2 Connect FortiPAM to EMS ... 79
7.3 Configure Client Certificate Authentication and ZTNA Tags ... 83
7.3.1 Review EMS ZTNA Tags ... 83
7.3.2 Configure Second Interface for ZTNA Access ... 85
7.3.3 Test Employee Access ... 90
7.3.4 Enabling ZTNA Tags on Secret Permissions ... 93
7.3.5 Create a TAG in EMS Server ... 93
7.3.6 Create Target/Secret for FortiGate ... 94
7.3.7 Test FortiGate Secret ... 96

8 PASSWORD HANDLING IN FORTIPAM ... 100

8.1 Overview of FortiPAM Password Handling ... 100
8.2 Setting up Password changing ... 101
8.3 Password changing and reconciliation ... 103

9 ADVANCED FORTIPAM SETTINGS ... 110

9.1 CheckOut & CheckIn ... 110
9.2 Approvals ... 111
9.3 FortiPAM Web Proxy for Web Launcher ... 116
9.3.1 Enable Explicit Proxy on the Interface ... 117
9.3.2 Enable Web Proxy on the Target ... 118
9.3.3 Test Web Launcher with Explicit Web Proxy Enabled ... 120
9.3.4 Custom HTTPS Ports on Targets ... 120
9.3.5 Test Custom HTTPS Ports on Targets with Explicit Web Proxy Enabled ... 124
9.4 Invite External User – One-time Invitation ... 125

1 FortiPAM 1.9 Hands-On LAB

This hands-on lab (HOL 1.9) covers two main use cases of a contractor (external) user and an employee user. The Contractor user will utilise the FortiPAM Privileged Access Agent browser extension while the Employee user will utilise the FortiClient PAM Agent.

1.1 Timing

Section	Duration
1. This page	5min
2. LAB Setup Overview	5min
3. FortiPAM Upgrade	
4. Initial Provisioning	15min
5. Setup FortiPAM for Contractor Access	30min
6. Enable FortiPAM for Employee Access	30min
7. Enable ZTNA Security Features	45min
8. Advanced FortiPAM Settings	

2 LAB Setup Overview

2.1 IMPORTANT NOTES ABOUT THE LABS

Please note that these labs have been created to facilitate learning specific product features and with specific outcomes in mind. You may have used these features before but not necessarily the way they are being used in this lab. It is important that you read and follow the lab guide, and not just copy the screenshots. If you don't, you will likely have issues with the labs. Most issues that CSE's have helped with during these labs have been from people not reading and following the guide.

2.2 Topology

1x Fabric Studio instance

- 1x FGT VM (7.6.2)
- 1x Debian Linux server
- 1x Lubuntu Linux workstation (not used for this lab)
- 1x Windows 2022 server (Domain Controller)
- 1x Windows 11 workstation
- 1x FortiPAM v1.9.0
- 1 EMS Server

3 Access and Credentials

You can access the various components from the Fabric Studio dashboard (prefer Chrome)

All credentials use ***F0rtiPAM*** as the password:

- FPOC access: *guest/F0rtiPAM*
- FortiGate: *admin/F0rtiPAM*
- FortiPAM: *admin/F0rtiPAM*
- Windows 2022 server: *administrator/F0rtiPAM*
- EMS: *emsadmin/F0rtiPAM*
- Windows 11 workstation: *admin/F0rtiPAM*
- Debian Linux server: *fortinet/F0rtiPAM*
- Lubuntu Linux workstation: *lubuntu/F0rtiPAM*

3.1 RDP Access

RDP access is available to the Windows 2022 server and Windows 11 workstation by manually configuring your RDP client as follows:

- Windows 11 workstation: [*fabric studio ip address*]:1389
- Windows 2022 server: [*fabric studio ip address*]:2389

You may find that response is not ideal at high resolutions and/or full screen. If so, try configuring your RDP client to connect at lower resolution and colour quality such as:

- 1440 x 900 Medium (16 bit) colour

3.2 EMS Server Access

EMS is installed on the EMS server. You can access it using HTTPS access from Fabric studio or using https://ems.fortipam.lab from the Windows 11 machine. You will make some configuration changes in EMS for this workshop, but those are minor to support what has been configured to support FortiPAM.

4 Initial Provisioning

4.1 FortiPAM

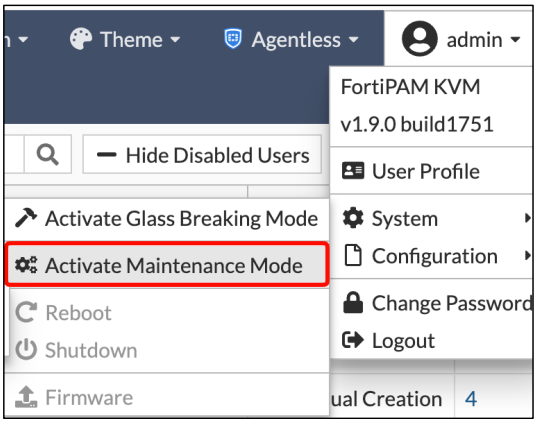
Think of FortiPAM features as a secure application running on top of the FortiPAM appliance. To access the PAM features and applications on the appliance, you must first log in through an Access Proxy—think of this as a Proxy Virtual IP (VIP), similar to the explicit proxy capability in FortiProxy. The Access Proxy is how FortiPAM brokers access to privileged systems.

By default, the physical FortiPAM port1 IP address (10.1.0.100) is synchronized with the default proxy VIP, allowing administrators to begin provisioning FortiPAM easily from the GUI. In Fabric Studio (FSS), port1 is assigned to a management subnet, enabling device access from the FSS dashboard. You will need to enable access on the remaining interfaces. To verify the default settings, connect to the FPA-Central GUI as an administrator (admin/F0rtiPAM).

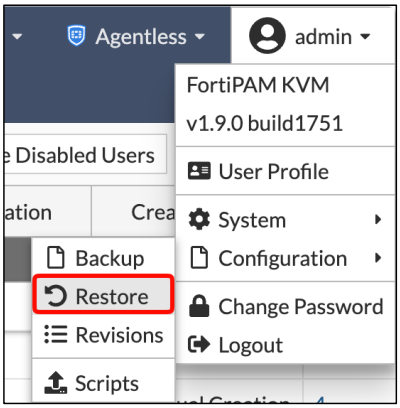
Restoring and backing up a configuration file in FortiPAM need for FortiPAM to be put in Maintenance Mode. In FortiPAM, maintenance mode is a state in which a managed resource (such as a server, network device, or database) is temporarily taken out of active privileged access management. This is typically used when administrators need to perform maintenance tasks—like patching, rebooting, or reconfiguring a system—without interference from automated password rotation, session monitoring, or access policies.

4.1.1 LOAD Configuration FILE: FPAM Config 03

On this task you will need to load configuration file into FPAM.



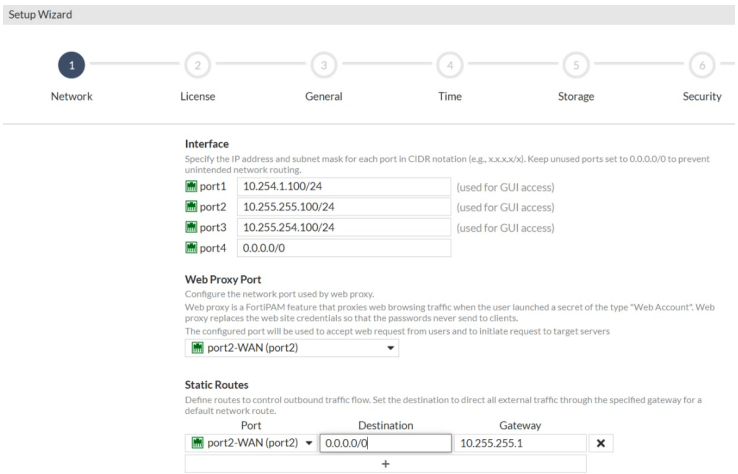
Login to FPA-Central as Admin/ *F0rtiPAM*, either by using the default admin profile or your own created administrator account.
Go to admin> System > Activate Maintenance Mode.
Press OK.

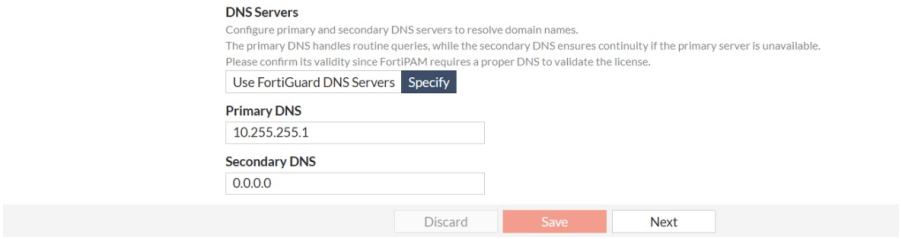


Go to Admin > Configuration >Restore.
Upload file “FPAM Config Chapter 03.conf”
Press OK > Press OK
A backup of the current configuration is downloaded to your download folder so that you can always restore previous configuration.
System will now reboot. Login with Admin / F0rtiPAM

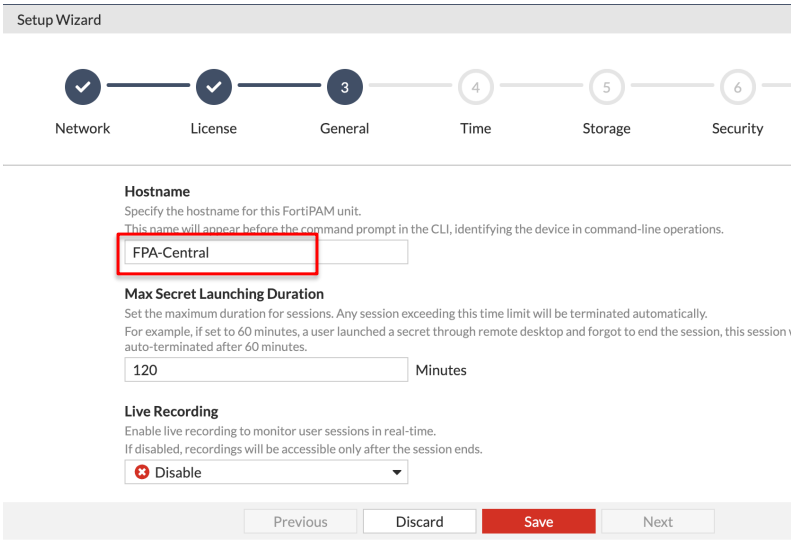
4.1.2 Setup Wizard

You will notice there is a *Setup Wizard* (under System tab) that starts and allows you to do some basic setup on first login. Review the *Setup Wizard* settings:





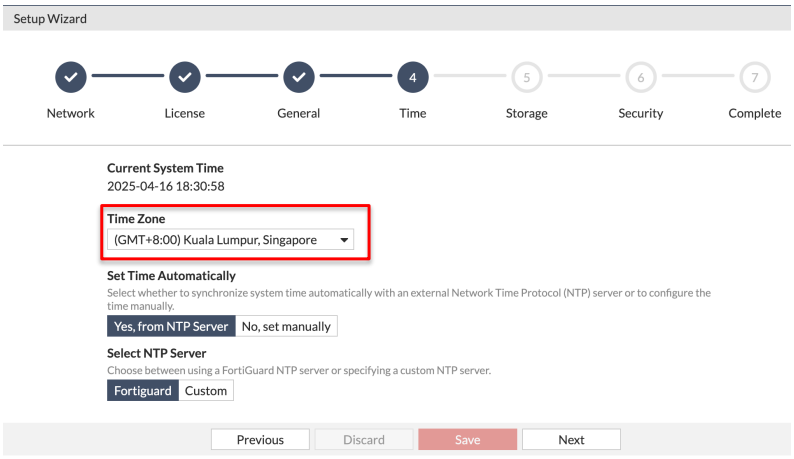
Click *Next* until you get to the General page and configure the hostname – ***FPA-Central***



For this Workshop we will not need Live recording, also known as over the shoulder Monitoring,. **Over-the-Shoulder Monitoring** is a security feature in FortiPAM (Privileged Access Management) that allows authorized administrators to **passively observe active privileged sessions in real-time**. This capability is critical for compliance, training, and security oversight without disrupting ongoing operations.

This does not impact our ability to videorecord secrets, this only impacts the over the shoulder monitoring activity.

Click *Save* then *Next.*
Set your time zone, you can leave it on the time zone that is set already or set it to your own.



Save and review the storage page. No changes are to be made here. Click *Next* to go to the Security page.

Do not enable vTPM, Private Data Encryption and Disk Encryption, enabling will mean we will need to reinstall the FortiPAM. This will be covered later. Click *Next* and *Complete* to finish the Setup Wizard. Again no changes here.

4.1.3 Configure other Interfaces

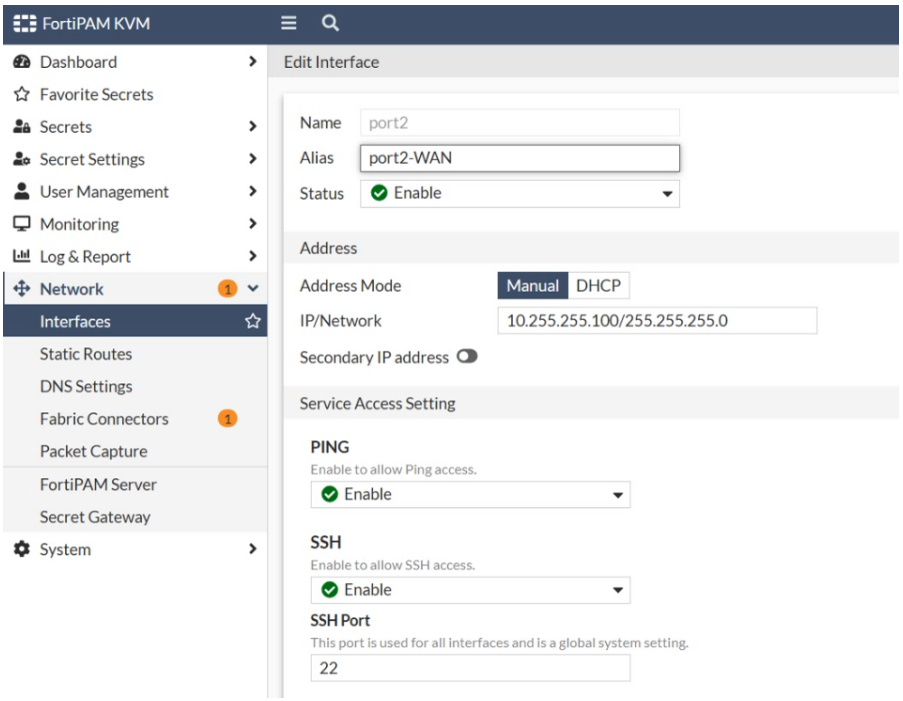
On ***FPA-Central*** go to *Network* > *Interfaces* and review the following configurations

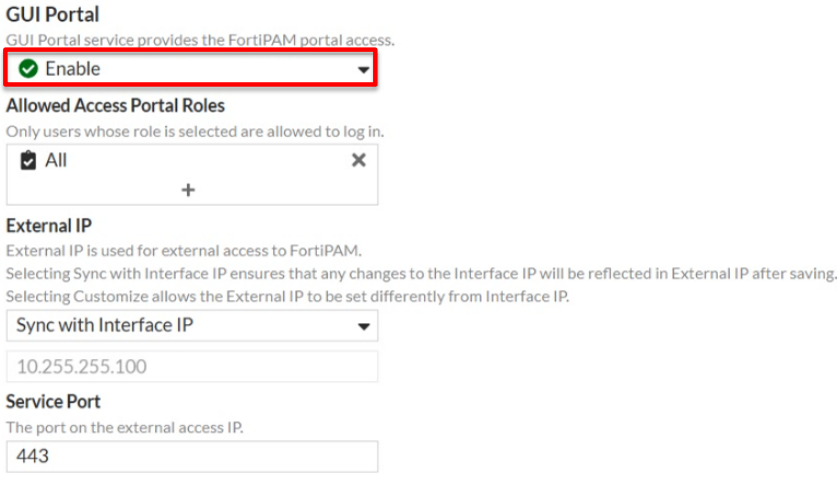
Interface	Purpose	Settings
Port2 (port2-WAN)	External user access	GUI Portal, Web Proxy
Port3 (port3-ZTNA)	ZTNA for internal user access	GUI Portal, ZTNA

Configure these ports.

Commented [VR1]: It is already provisioned

port2:


FortiPAM KVM
Dashboard
Favorite Secrets
Secrets
Secret Settings
User Management
Monitoring
Log & Report
Network
Interfaces
Static Routes
DNS Settings
Fabric Connectors
Packet Capture
FortiPAM Server
Secret Gateway
System
Edit Interface
Name
port2
Alias
port2-WAN
Status
Enable
Address
Address Mode
Manual
DHCP
IP/Network
10.255.255.100/255.255.255.0
Secondary IP address
Service Access Setting
PING
Enable to allow Ping access.
Enable
SSH
Enable to allow SSH access.
Enable
SSH Port
This port is used for all interfaces and is a global system setting.
22


GUI Portal
GUI Portal service provides the FortiPAM portal access.
Enable
Allowed Access Portal Roles
Only users whose role is selected are allowed to log in.
All
External IP
External IP is used for external access to FortiPAM.
Selecting Sync with Interface IP ensures that any changes to the Interface IP will be reflected in External IP after saving.
Selecting Customize allows the External IP to be set differently from Interface IP.
Sync with Interface IP
10.255.255.100
Service Port
The port on the external access IP.
443

SSL Certificate

SSL certificates create encrypted connections and establish trust when accessing FortiPAM. They are issued for a specific server or enterprise network.

Fortinet_SSL

Minimum SSL Version

Lowest SSL/TLS version acceptable from a client.

TLSv1-1

ZTNA Control

Enable to allow access only from endpoints with matching ZTNA tags.

Disable

Explicit Web Proxy

Explicit Web Proxy can be enabled on only one interface in the system.
Enabling this toggle will activate the web proxy service on the current interface.

Enable

Port

This port is used for all interfaces and is a global setting.

8080

CA Certificate

Fortinet_CA_SSL

The browser may warn of an untrusted site even if its certificate is valid. This happens because the traffic is proxied by FortiPAM in
certificate to resolve the false positive "untrusted site" warning.
During installation, you may be asked to specify the certificate store (trusted root CA/intermediate CA). Most platforms automatic
also specify the location manually. In that case, check the "Issued to" and "Issued by" fields in the "General" tab of the certificate dial
Authorities". If different, choose "Intermediate Certification Authorities".

SNMP

Enable to allow SNMP Access.

Disable

FortiToken Mobile Push

Enable to allow FortiToken Mobile Push notification from FortiToken Mobile application used for two-factor authentication.
To successfully use this feature, the user must also enable the **Push Server Status** below.

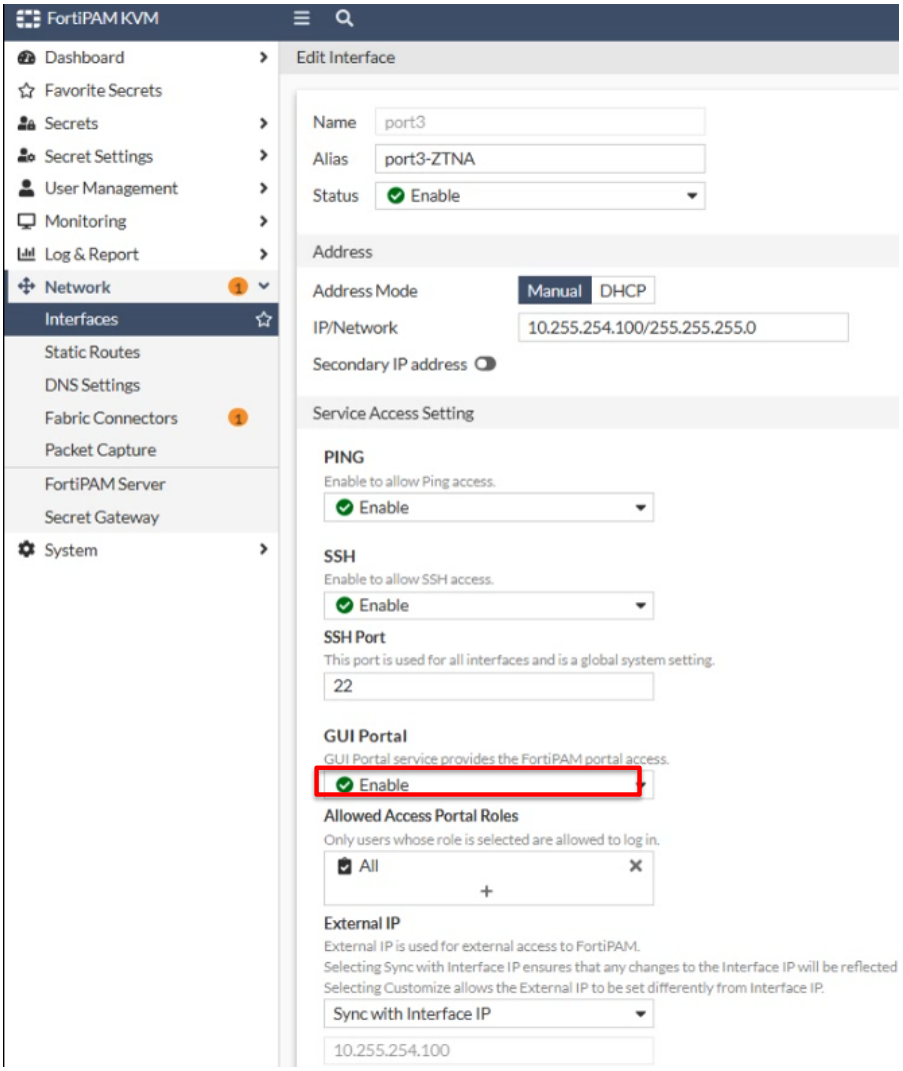
Disable

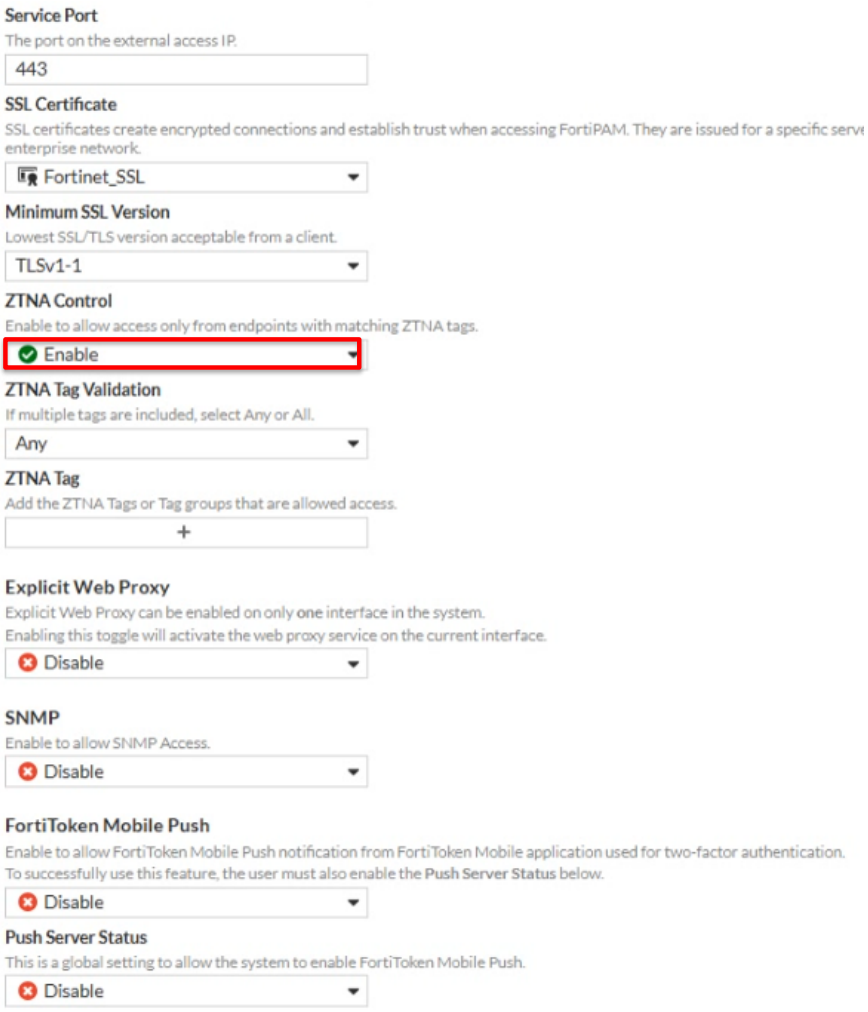
Push Server Status

This is a global setting to allow the system to enable FortiToken Mobile Push.

Disable

port3:

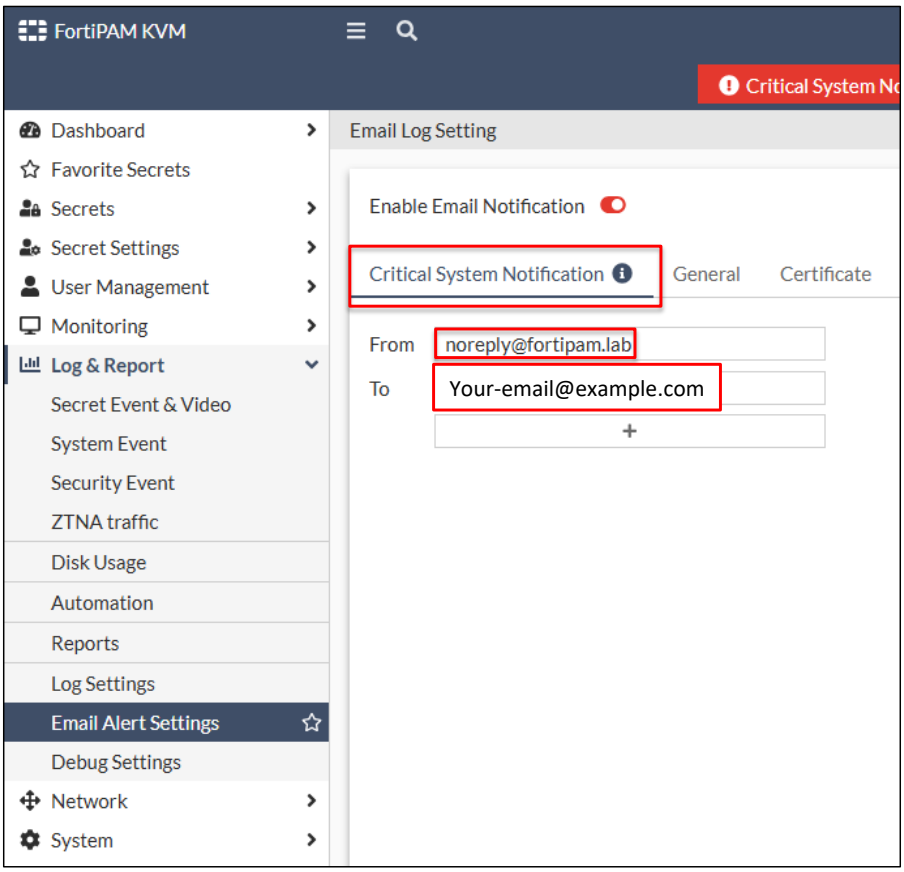

FortiPAM KVM
Dashboard
Favorite Secrets
Secrets
Secret Settings
User Management
Monitoring
Log & Report
Network
Interfaces
Static Routes
DNS Settings
Fabric Connectors
Packet Capture
FortiPAM Server
Secret Gateway
System
Edit Interface
Name
port3
Alias
port3-ZTNA
Status
Enable
Address
Address Mode
Manual
DHCP
IP/Network
10.255.254.100/255.255.255.0
Secondary IP address
Service Access Setting
PING
Enable to allow Ping access.
Enable
SSH
Enable to allow SSH access.
Enable
SSH Port
This port is used for all interfaces and is a global system setting.
22
GUI Portal
GUI Portal service provides the FortiPAM portal access.
Enable
Allowed Access Portal Roles
Only users whose role is selected are allowed to log in.
All
External IP
External IP is used for external access to FortiPAM.
Selecting Sync with Interface IP ensures that any changes to the Interface IP will be reflected
Selecting Customize allows the External IP to be set differently from Interface IP.
Sync with Interface IP
10.255.254.100



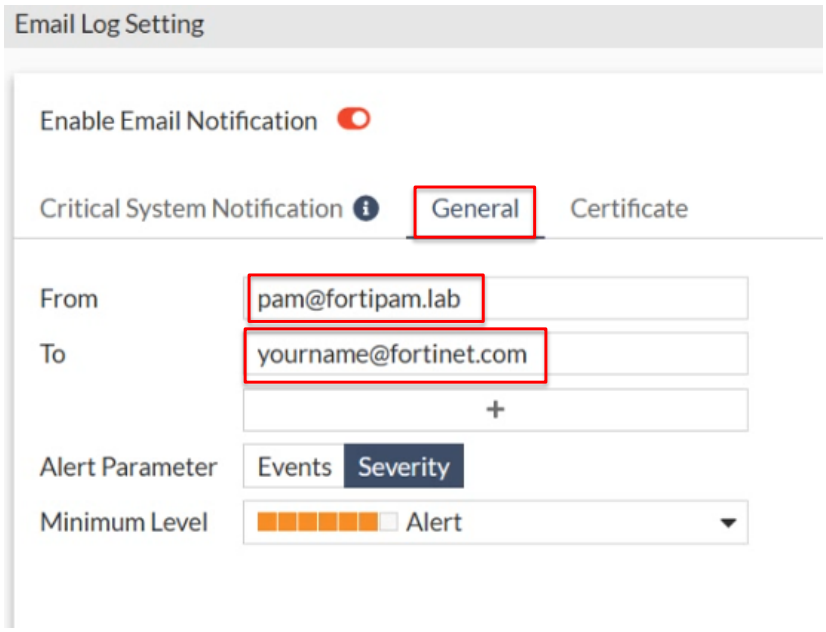
4.1.4 Configure Email Alert Settings

Login to FortiPAM GUI as ***admin***. Go to *Log & Report* > *Email Alert Settings* and configure your email address for alerts.

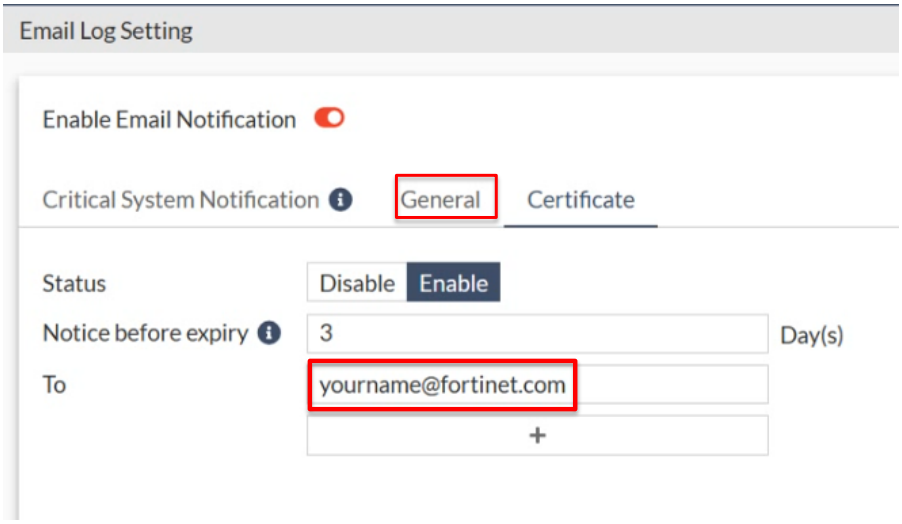
From: ***noreply@fortipam.lab***
To: ***[your email address]***



Configure email alerting on the *General* tab also:



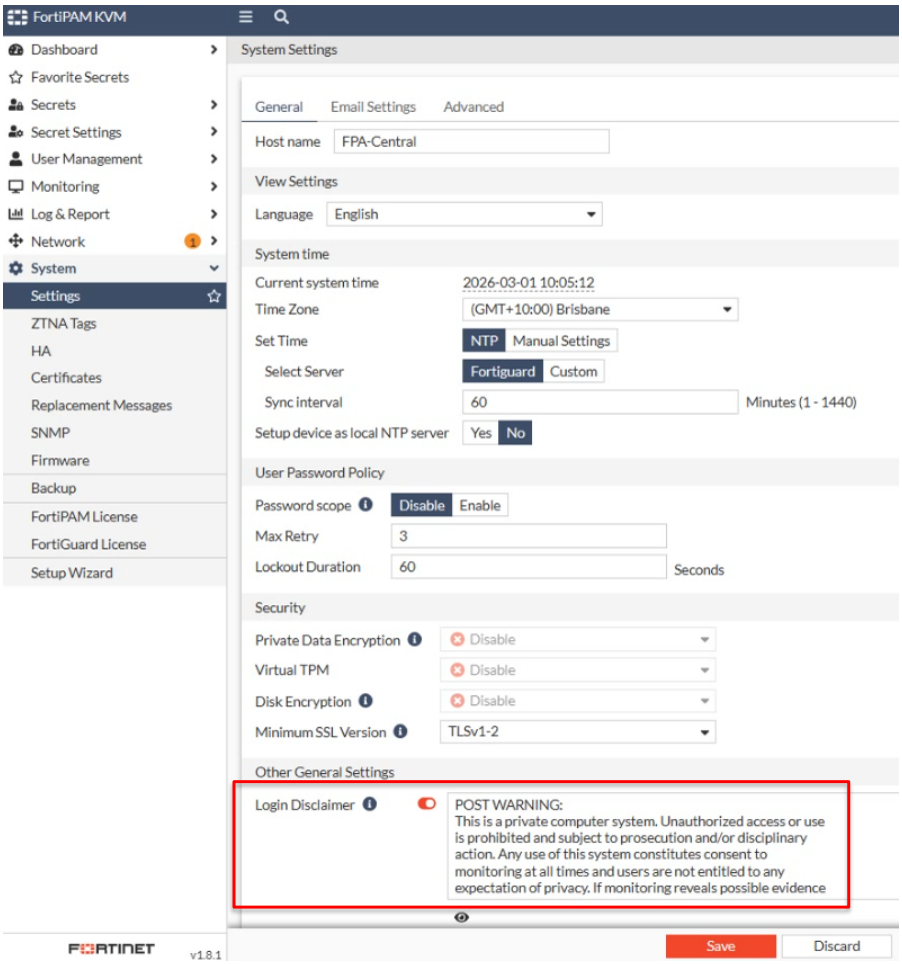
Go to certificate settings



Press *apply*.

4.1.5 Configure Login Disclaimer

Go to *System* > *Settings* page, scroll down and enable the Login Disclaimer. Review the text for the disclaimer and notice at the end there is the option to include the last successful login time for the user. Apply the changes.



4.2 Setup Windows Workstation

The Windows workstation is being used first to demonstrate PAM functionality for users that can't/won't have FortiClient installed. In this workshop the use case is a contractor user who needs to access privileged systems.

Agentless in FortiPAM refers to the ability to manage, monitor, and secure privileged access to target systems **without installing any software (agents) on those systems or on end-user devices**. This is a core architectural principle that distinguishes FortiPAM from traditional PAM solutions that require agents on every managed endpoint. However, there are important nuances and limitations to understand regarding what can and cannot be achieved without at least a browser extension for web-based sessions.

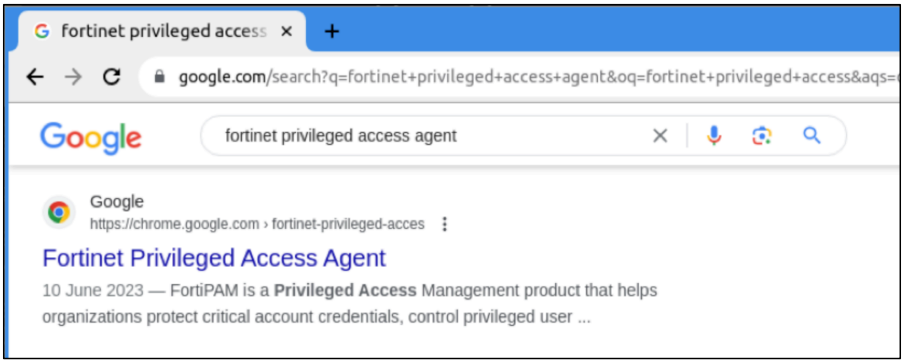
What "Agentless" Actually Means in FortiPAM

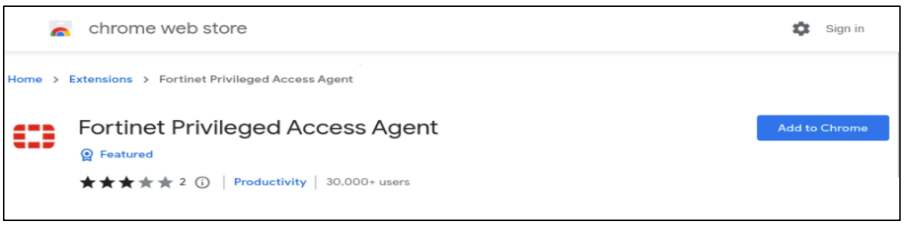
Component	Agentless Status	Explanation
Target Systems (Servers, DBs, Network Devices)	✅ **Fully Agentless**	No software installation required on any target system
Protocol-Based Sessions (RDP, SSH, VNC)	✅ **Fully Agentless**	Work entirely through browser-based HTML5 clients without local software
File Transfer Protocols (SCP, SFTP, FTP, SMB)	✅ **Fully Agentless**	Handled via web-based interfaces in the browser
Web Application Sessions (Salesforce, AWS, O365, Custom Apps)	⚠️ **Requires Browser Extension**	Need browser extension for full recording and credential injection

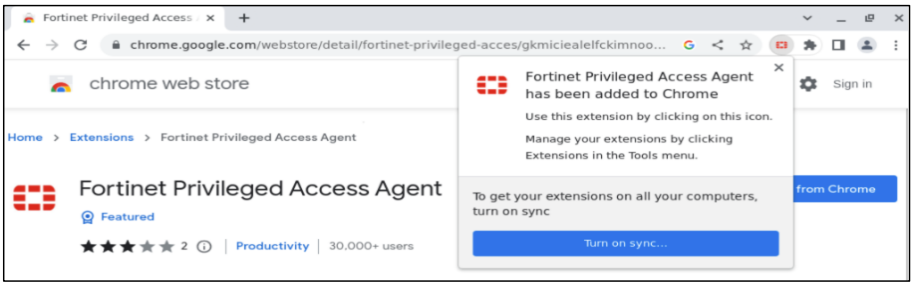
For this workshop we will be using the browser extension – Chrome and Edge are the preferred browsers, but Firefox is fully supported using the browser extension.

4.2.1 Install FortiPAM Extension for Google Chrome

RDP to the windows workstation ***(access [fabric studio ip address]:1389 and use admin)***. Open Chrome browser and then search for “Fortinet Privileged Access Agent” and install it.







Enable the browser extension to run in Chrome Incognito windows by going to chrome://extensions in the URL bar and editing the details for the browser extension.

4.2.2 Manual Installation of Browser Extensions (FYI)

If the environment is air-gapped or has restricted access preventing installation of the browser extensions online, you may download the browser extensions from https://www.fortinet.com/support/product-downloads

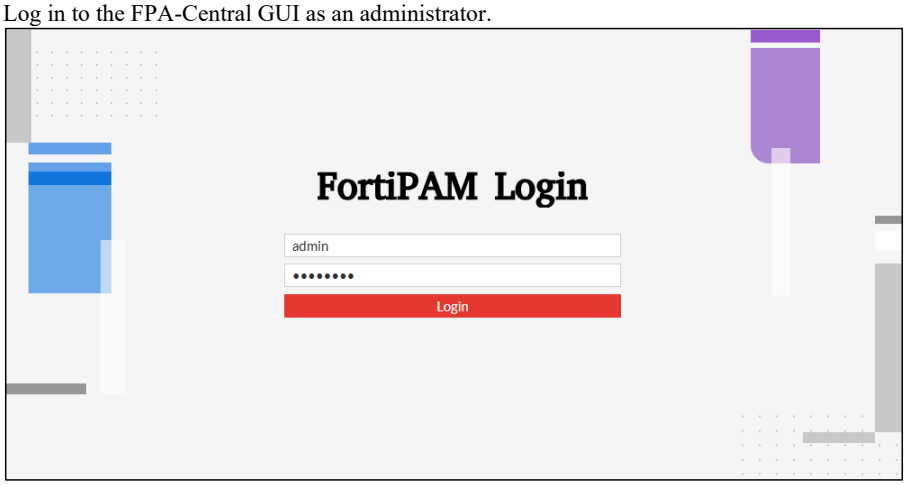
See also : https://docs.fortinet.com/document/fortipam/1.8.0/administration-guide/968276/fortipam-browser-extension-and-standalone-forticlient-air-gapped-installation

5 Setup FortiPAM for Contractor (External) Access

Many organizations are seeking a secure solution for providing contractors with access to privileged systems. For example, an organization might need to grant Fortinet TAC or Professional Services access to manage FortiGates for troubleshooting (TAC) or project related services (PS). Similarly, a building manager might need to give an air conditioning technician remote access to manage the building's HVAC system.

In such scenarios, contractors may be unable or unwilling to install FortiClient with the PAM-specific components. Therefore, all access will be provided via a browser extension. This lab use case focuses on a contractor who requires SSH access to a server for firmware updates and/or troubleshooting.

Log in to the FPA-Central GUI as an administrator.



5.1 Create Users and Groups for Contractors

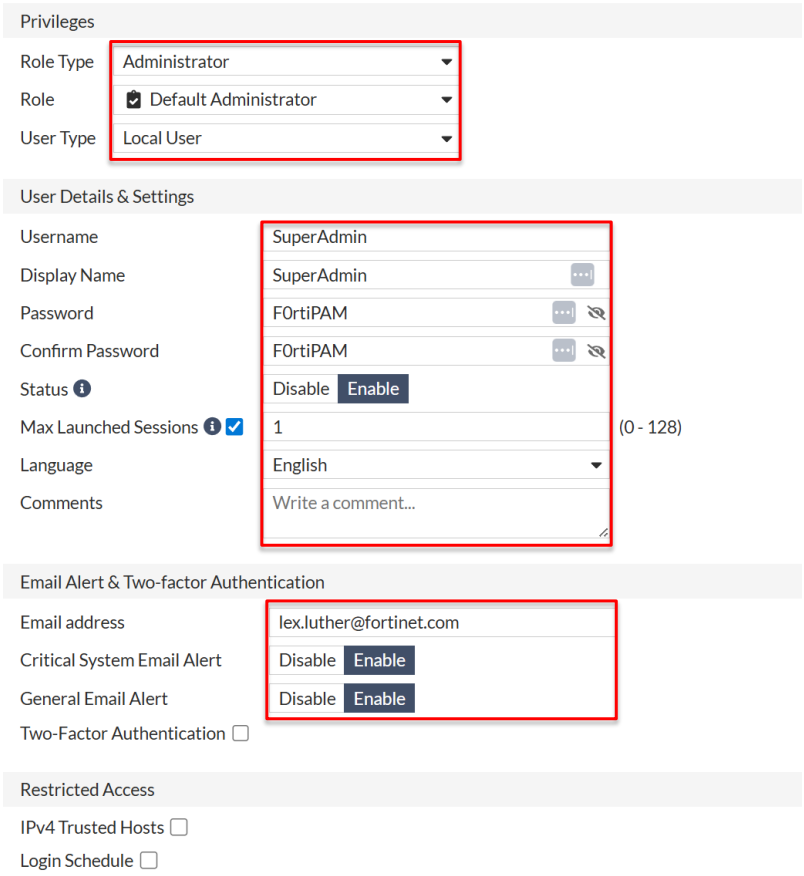
The first thing we need to do is create a new administrators account and disable the default one.

User Management > User List
We are going to create a new administrative user. In this guide, we use **SuperAdmin** as an example; feel free to replace **SuperAdmin** with your own named administrative account.

It is possible that an administrator named **SuperAdmin** already exists. If it does, please verify that it has the role **Default Administrator**. If the account does not exist, please create it. Alternatively, if it exists but does not have the appropriate role, change the role to **Default Administrator** and make sure the password is set to **F0rtiPAM**.

Click on **Max launched sessions** and set it to **1**, then fill in your own email address.
Make sure that Critical Email alert and General Email alert are enabled

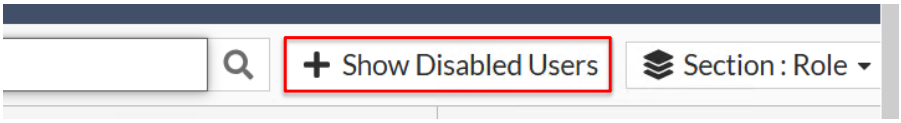
Add your email address in “Email Alert & Two-factor Authentication” ?



Press on Submit.

We are first going to test if we can login as Super Admin
Log out as Admin and Login as SuperAdmin.
Got to *User Management* > *User List*

Make sure that show disabled users is set:



Select Admin and try to disable the account.

You should have gotten an error message, the default admin cannot be disabled, best practice is to give it a very strong password and give the password to the security team for safe keeping and let them change the password and maintain it.

Important Administrative Account Notice
For the duration of this workshop and all future FortiPAM operations, it is critical that we maintain consistency in administrative account usage. While we will be referencing both **SuperAdmin** and **Admin** account types interchangeably throughout this training, please note:

⚠ **Each administrator should use ONLY ONE designated administrative account consistently.** Do not switch between different admin accounts for routine tasks.

This consistency ensures:

- **Clear audit trails** - All actions traced to a single identity
- **Simplified troubleshooting** - No confusion about which account performed what
- **Proper RBAC enforcement** - Permissions remain predictable and manageable

Role-Based Access Control (RBAC) in FortiPAM is a security framework that restricts system access to authorized users based on their defined organizational roles. For administrator accounts specifically, RBAC ensures that privileged administrative functions are appropriately segregated and controlled. Especially important for secrets, secrets created by one administrator are not accessible by another administrator unless access is explicitly given.

Throughout this workshop, please remember:

1. **Consistency is Key**
    - Choose **EITHER** SuperAdmin **OR** Admin account
    - Use the **SAME** account for all exercises
    - Do not switch between accounts mid-workshop
2. **Why This Matters**
    - Audit logs will show clear activity trail
    - Troubleshooting becomes straightforward
    - Permissions remain predictable
    - Examples work consistently
3. **Account References in Materials**
    - When you see "SuperAdmin" - use your chosen admin account
    - When you see "Admin" - still use your chosen admin account
    - Both terms refer to "your designated administrative account"

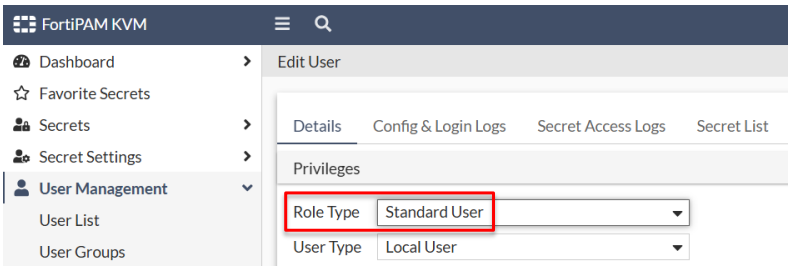
Best Practice Takeaway

- In production, always maintain separate admin identities
- Never share admin accounts
- Use RBAC to assign appropriate permissions
- Document which admin account performs which functions
- Whenever possible split administrative access from user access.

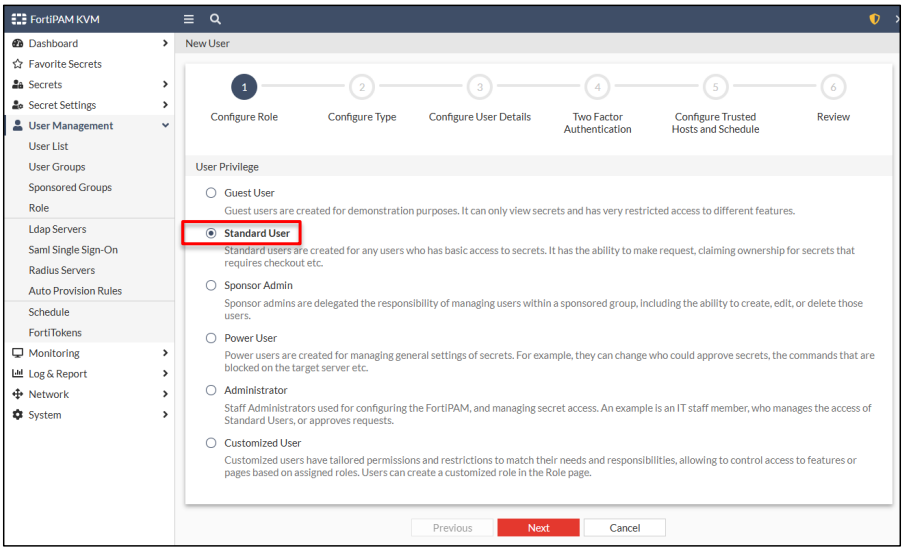
- Use MFA in production
- Use ZTNA for Administrative access whenever possible.

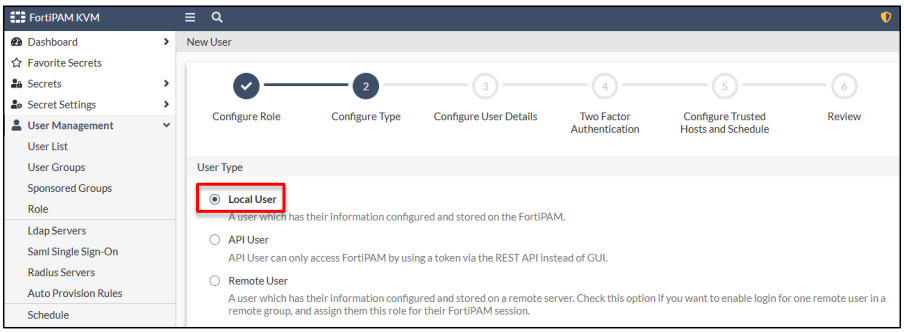
Go to *User Management* > *User List* and check if the contractor user has already been created

- If already created edit it and change the role type to “standard user” – check the other settings and save.

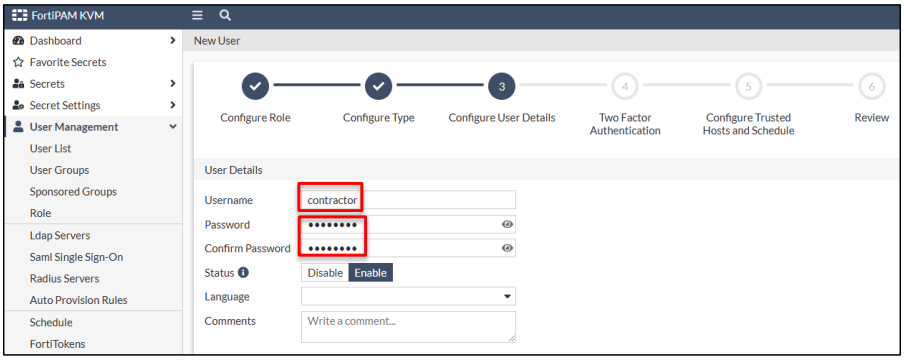


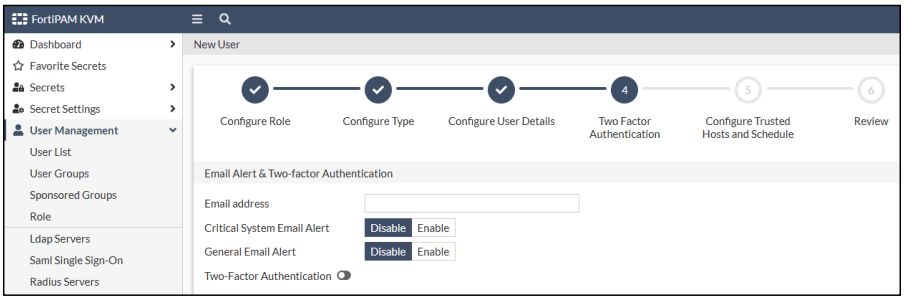
- if not already created create it as below

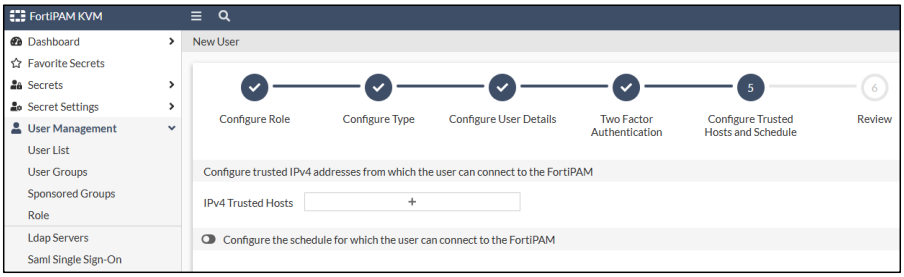


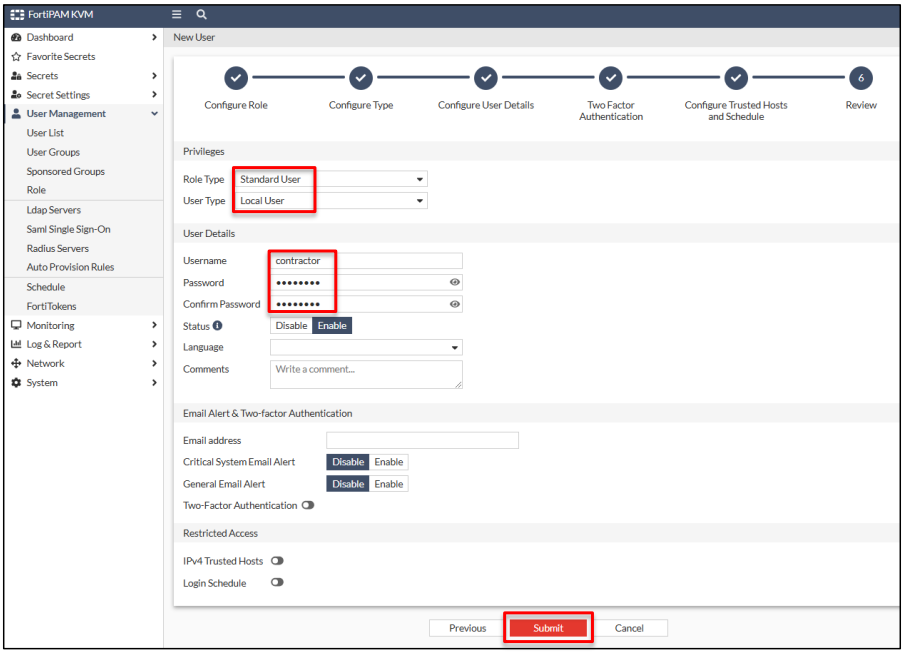


Username: ***contractor***
Password: ***FortiPAM***

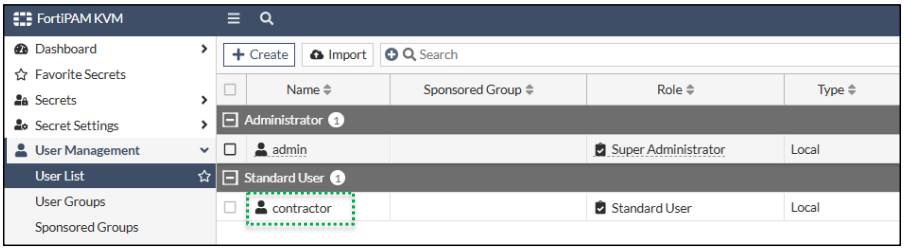




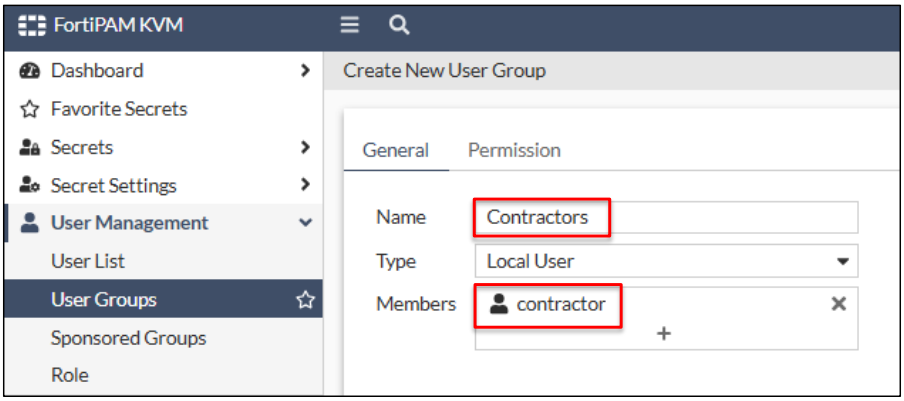




Click *Submit*.



Go to *User Management* > *User Groups* and check if the Contractors groups has already been created and if the contractor is part of it, if not create it and make the contractor part of it.



5.2 Create Folders and Secrets for Contractor Users

5.2.1 Explaining Folders

In FortiPAM, we have two different types of Folders, personal folder and public folders. the difference between Personal Folders and Public Folders lies in access control, sharing, and use cases. Both are used to organize **secrets** (credentials, passwords, SSH keys, etc.) hierarchically, but they serve very different purposes.

Personal Folders

- Private to the individual user (and FortiPAM administrators with elevated rights).
- Only the owner can view, edit, or manage the secrets inside.
- Ideal for personal or individual credentials that should not be shared (e.g., a sysadmin's personal SSH key or a user's own database password).
- Permissions cannot be granted to other users/groups — they remain strictly private.
- Best for: Personal accountability, sensitive individual accounts, or testing.

Public Folders

- Shared across users or user groups.
- Administrators or folder owners can grant read/write/launch permissions to specific users, roles, or groups.
- Secrets inside inherit the same permissions as the folder (makes bulk permission management easy).
- Ideal for team-shared credentials (e.g., a service account used by the whole DevOps team, or a common database password for a department).
- Supports hierarchical organization and role-based access control (RBAC).
- Best for: Collaborative environments, shared service accounts, or centralized credential management.

You can create nested sub-folders within Public Folders to mirror your organizational structure—for example:

- Production/ → Databases/ → MySQL/ → Primary-DB

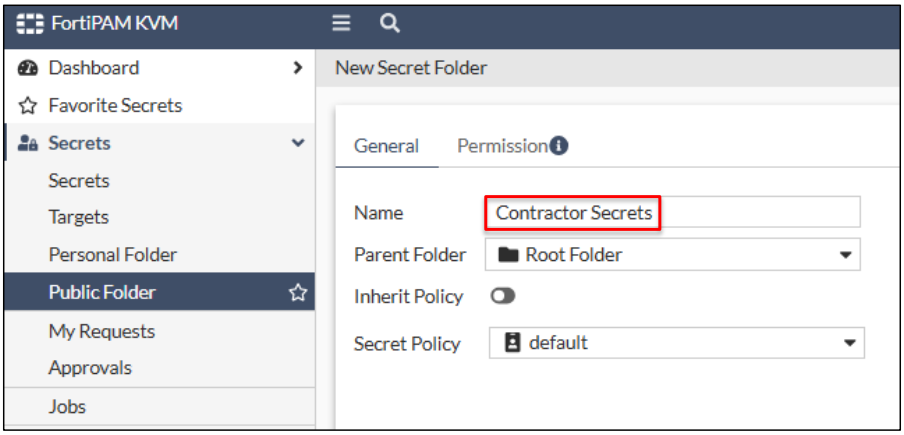
Recommendation Practice:

- Use Personal Folders for anything truly private or user specific.
- Use Public Folders for anything that needs to be accessed by a team, department, or role (with proper approval workflows via FortiPAM requests).

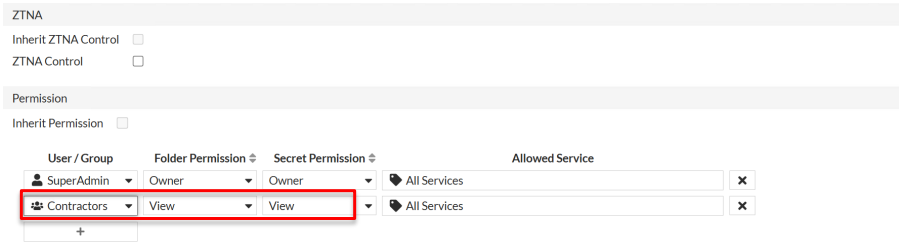
This design makes FortiPAM very flexible for both individual and enterprise-scale privileged access management.

5.2.2 Create Folder

Go to *Secrets* > *Public Folder* and create a folder named “Contractor Secrets” if not already created:



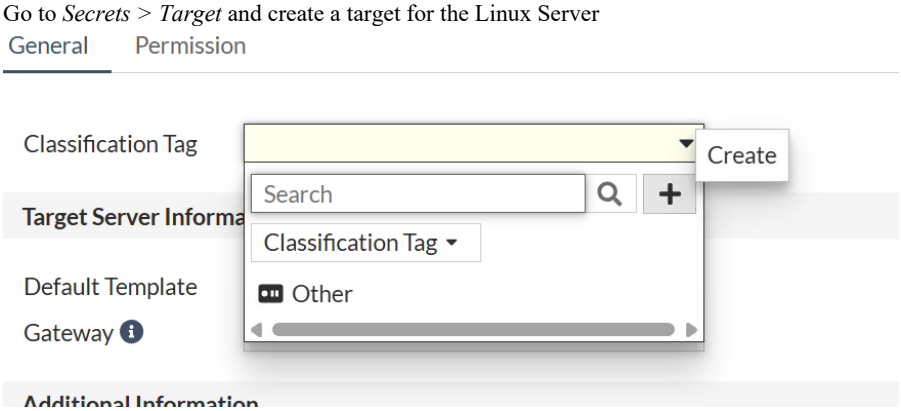
Check the permissions tab and add the Contractors Group with Folder and Secret View permissions



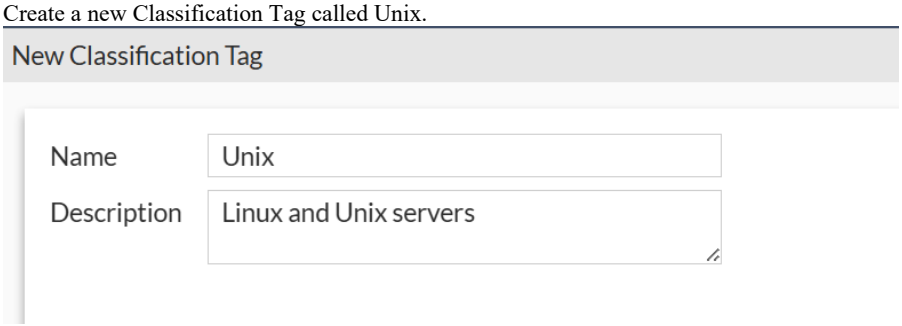
5.2.3 Create Target

In FortiPAM, a **Target** is the critical IT asset you want to protect and control access to. In simple terms, it's the "what" you are connecting to. **It is a Server or Device:** A target is any hardware or virtual asset that hosts a privileged account. This includes Windows workstations, Windows domain controllers, web servers, Unix/Linux servers, SQL servers, routers, firewalls, and other network devices.

Go to *Secrets* > *Target* and create a target for the Linux Server

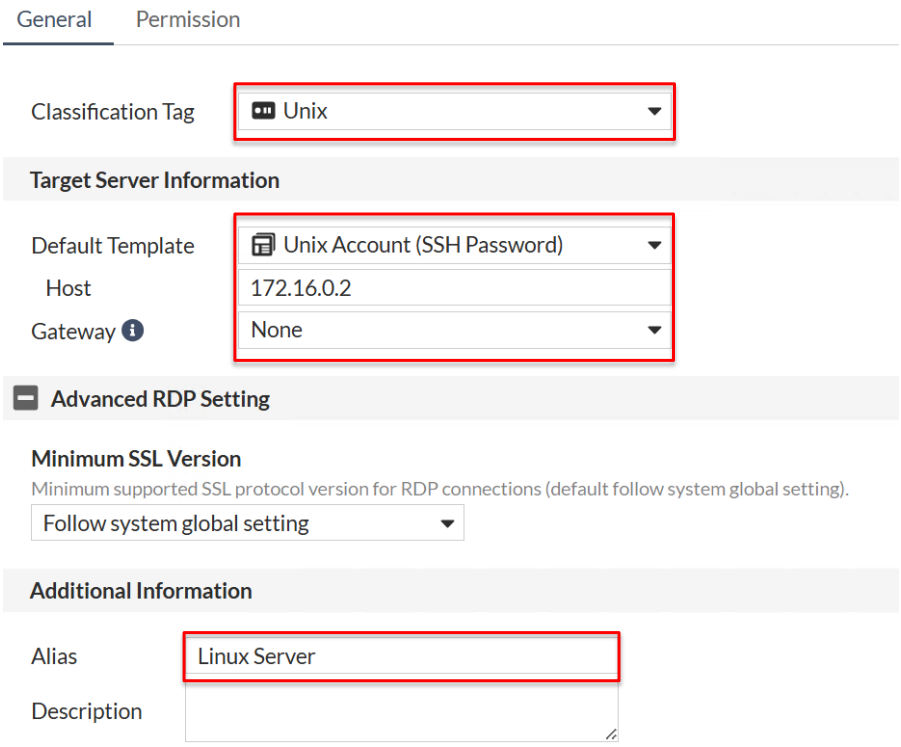


Create a new Classification Tag called Unix.



Select the new classification tag.

Name: ***Linux Server***
Classification Tag: ***Unix***
Default Template: ***Unix Account (SSH Password)***
Host: ***172.16.0.2***



5.2.4 What is a Secret?

At the heart of FortiPAM are **secrets**—the core objects that store and protect your organization's most sensitive credentials and data. Think of them as the digital equivalents of passwords, keys, and certificates, but with enterprise-grade security controls built around them.

5.2.4.1 What Exactly Is a Secret in FortiPAM?

A secret is any piece of sensitive information stored inside FortiPAM's encrypted vault. Unlike a simple password manager, FortiPAM treats each secret as a **privileged asset** with its own lifecycle, access controls, and audit trail.

Common examples include:

Secret Type	Examples
Credentials	Username + password combinations, application logins
Cryptographic Keys	SSH private keys, API keys, encryption keys
Infrastructure Access	Database credentials, RDP credentials, service accounts
Certificates	SSL/TLS certificates with private keys
Custom Secrets	License keys, configuration tokens, shared secrets

All secrets are encrypted both **at rest** (within the vault) and **in transit** (during access).

5.2.4.2 How Secrets Are Organized

Secrets don't live in a flat list—they're stored inside **folders** that control access and visibility. This hierarchical structure mirrors how real organizations work.

5.2.4.3 Key Features That Make Secrets Secure

What transforms a simple stored password into a privileged access management solution? These features:

Just-in-Time (JIT) Access
Users never see the actual secret by default. Instead, they **request access**. When approved, they receive a temporary **checkout** (typically 8–24 hours). After the checkout expires, the password is automatically rotated. This means:

- No permanent credentials floating around
- No shared passwords written on sticky notes
- Every access is temporary and audited

Automatic Password Rotation
Secrets can be configured to auto rotate:

- After every checkout
- On a scheduled basis (e.g., every 30 days)
- Immediately after a security incident

This eliminates the risk of stale credentials and ensures compliance with rotation policies.

Session Recording
When someone uses a secret to launch a connection (RDP, SSH, HTTPS), FortiPAM can record the entire session. Every keystroke and click is captured for:

- Forensic analysis
- Compliance audits
- Insider threat detection

Approval Workflows
Critical secrets can require multi-step approval before checkout. You can configure:

- Manager approval

- Security team validation
- Emergency bypass with justification

Granular Permissions
Inside Public Folders, you can assign precise permissions:

Permission Level	What the User Can Do
Read-only	View secret metadata, but not the actual value
Checkout	Request temporary access to the secret
Launch	Connect directly via RDP/SSH without seeing the credential
Manage	Create, edit, or delete secrets within the folder

Real-World Example in Action
Imagine a DevOps team needing access to a production database password:

1. **The Setup:** The DBA creates a secret called "Production-MySQL-Password" in a Public Folder named Production-Databases. Rotation is set to 24 hours after checkout.
2. **The Request:** A developer needs to troubleshoot an issue at 2 AM. They request checkout through FortiPAM.
3. **The Approval:** If configured, the on-call manager receives an approval request. For emergency access, they can approve immediately.
4. **The Access:** The developer receives the password for a 24-hour window. They connect to the database.
5. **The Audit:** FortiPAM logs:
    - Who requested access
    - When they accessed it
    - How long they used it
    - What commands they ran (if session recording was enabled)
6. **The Rotation:** 24 hours later, the password automatically rotates to a new, cryptographically random value. The old password is useless to anyone who might have captured it.

Why This Matters for Your Organization
Unlike traditional password managers (like KeePass, Excel sheets, or shared browser storage), FortiPAM treats secrets as **privileged assets** with:

Capability	FortiPAM	Traditional Password Manager
Just-in-Time Access	✅ Yes	❌ No
Auto-rotation	✅ Yes	❌ No
Session Recording	✅ Yes	❌ No

Capability	FortiPAM	Traditional Password Manager
Approval Workflows	✅ Yes	❌ No
Granular Permissions	✅ Yes	⚠️ Limited
Compliance Auditing	✅ Yes	❌ No

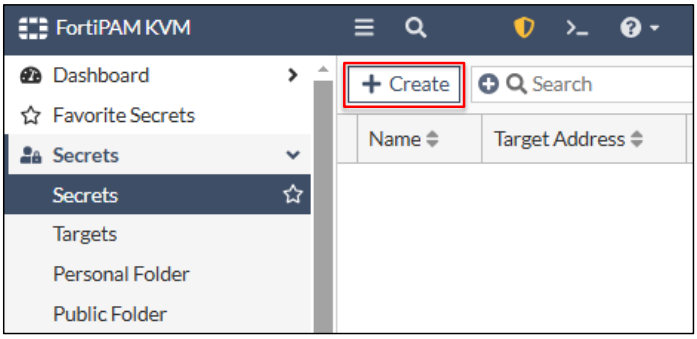
This makes FortiPAM compliant with major security frameworks including:

- **IEC 62443** (industrial cybersecurity)
- **NIS2 Directive** (EU network security)
- **NIST 800-53** (US federal standards)
- **ISO 27001** (information security management)

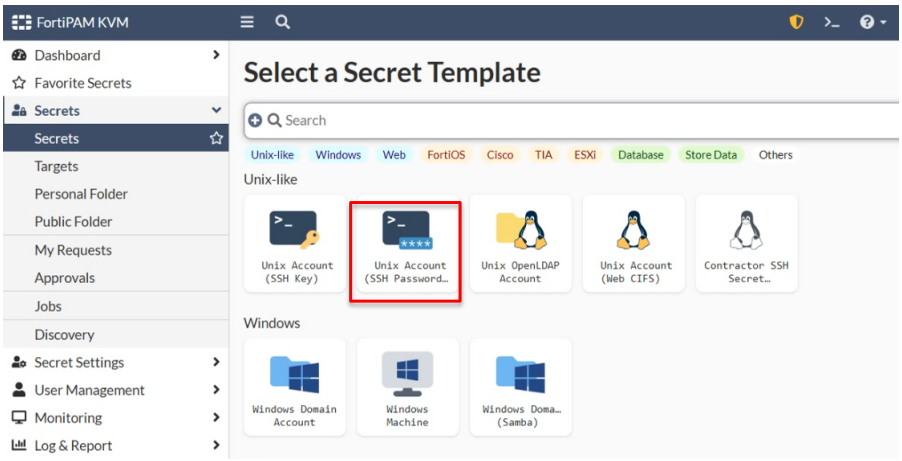
5.2.5 Create Secret

In FortiPAM a ***Secret*** contains all the parameters required to connect to a target system. Parameters such as the IP address, protocol used, credentials used to connect to the system and other advanced PAM features/settings. Some of these settings are inherited from the folder via a **Secret Policy** but inheritance can be disabled to configure these directly on a Secret.

Go to *Secrets* > *Secrets* and click *Create.*



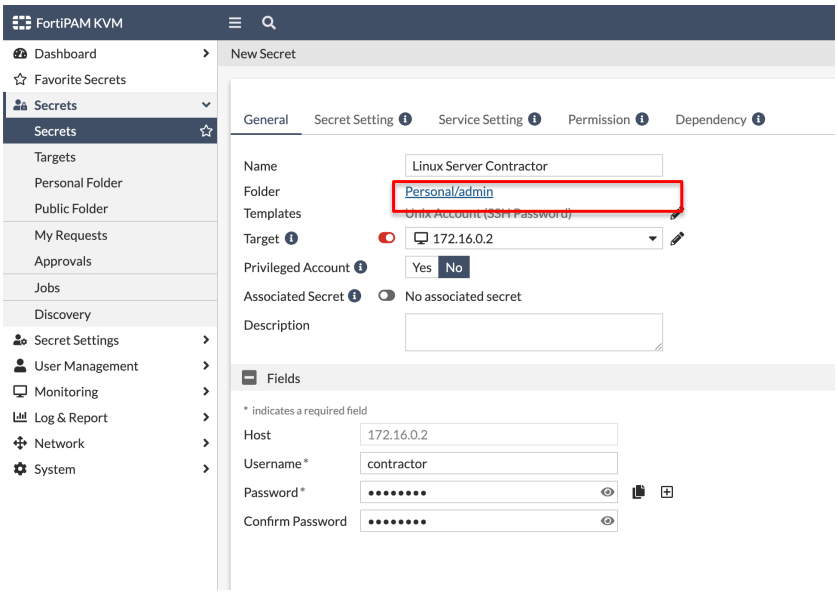
Select the *Unix Account (SSH Password)* template:

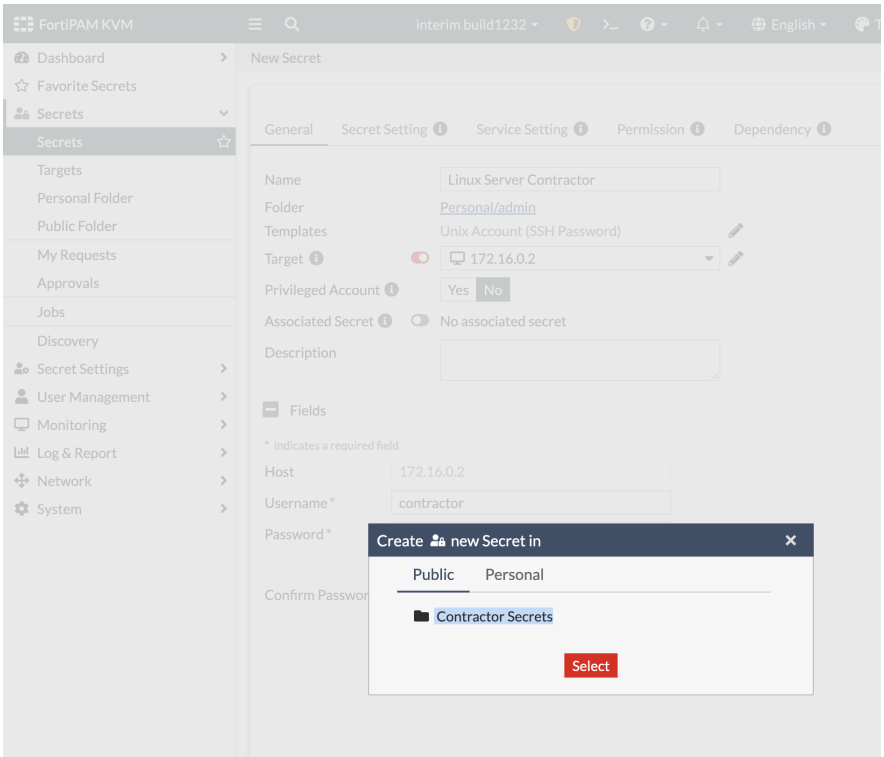


Configure the following values for the secret:

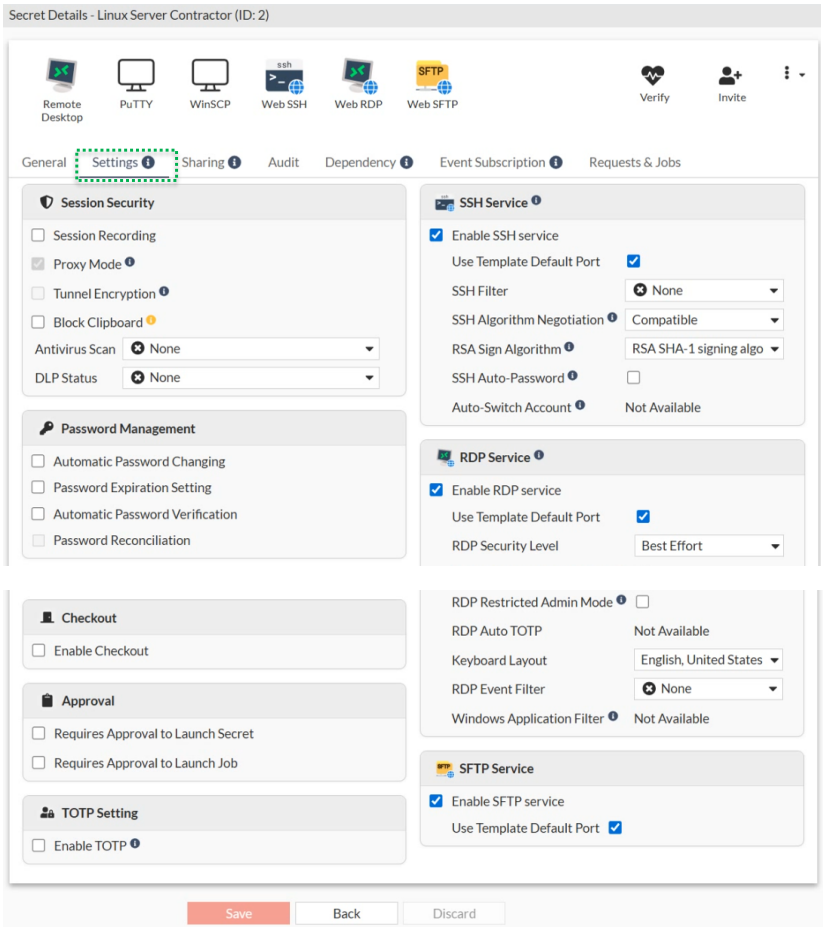
- Name: ***Linux Server Contractor***
- Target: ***Linux Server***
- Username: ***contractor***
- Password: ***F0rtiPAM***

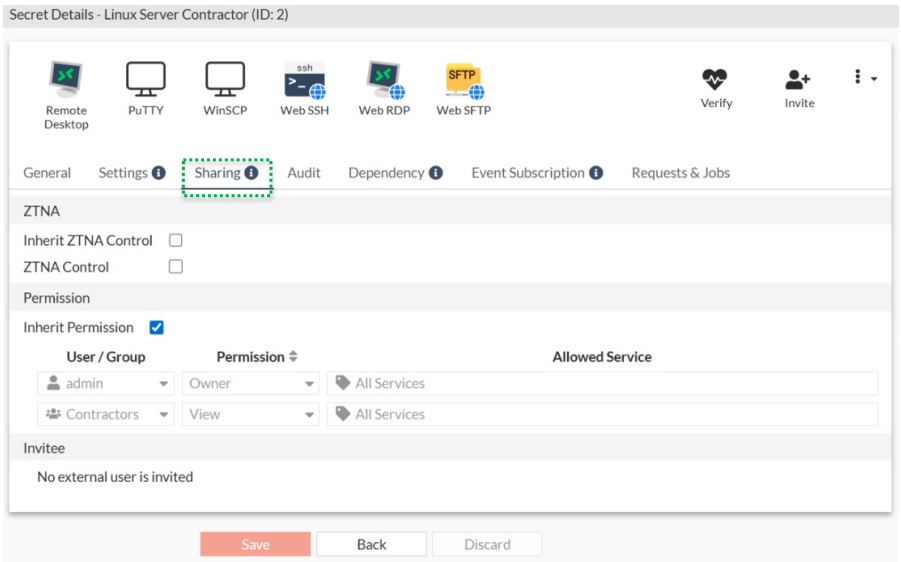
Click the folder link to change the folder to *Contractor Secrets*

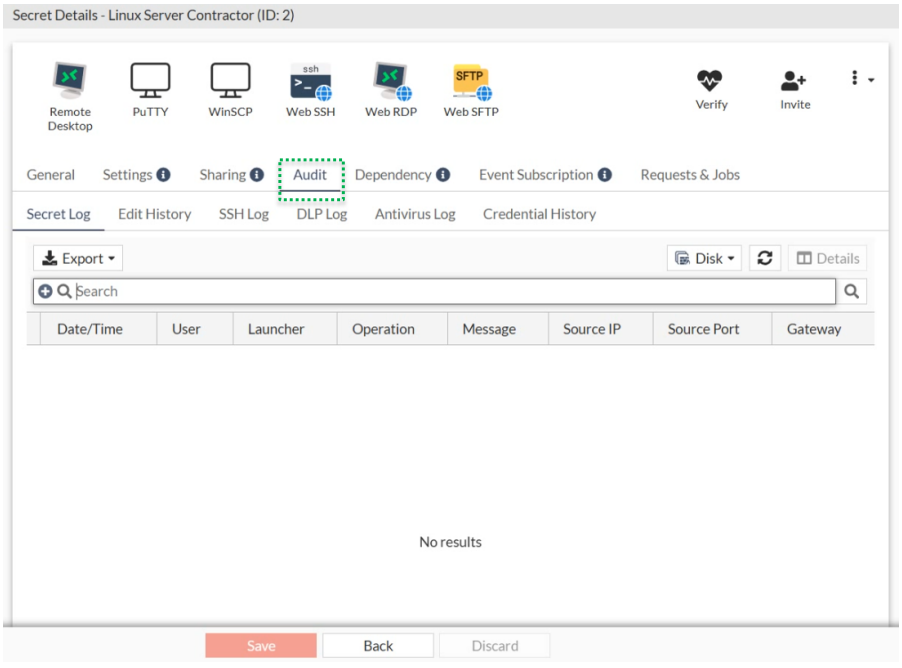

FortiPAM KVM
Dashboard
Favorite Secrets
Secrets
Secrets
Targets
Personal Folder
Public Folder
My Requests
Approvals
Jobs
Discovery
Secret Settings
User Management
Monitoring
Log & Report
Network
System
New Secret
General
Secret Setting
Service Setting
Permission
Dependency
Name
Linux Server Contractor
Folder
Personal/admin
Templates
Target
172.16.0.2
Privileged Account
Yes
No
Associated Secret
No associated secret
Description
Fields
* indicates a required field
Host
172.16.0.2
Username *
contractor
Password *
Confirm Password

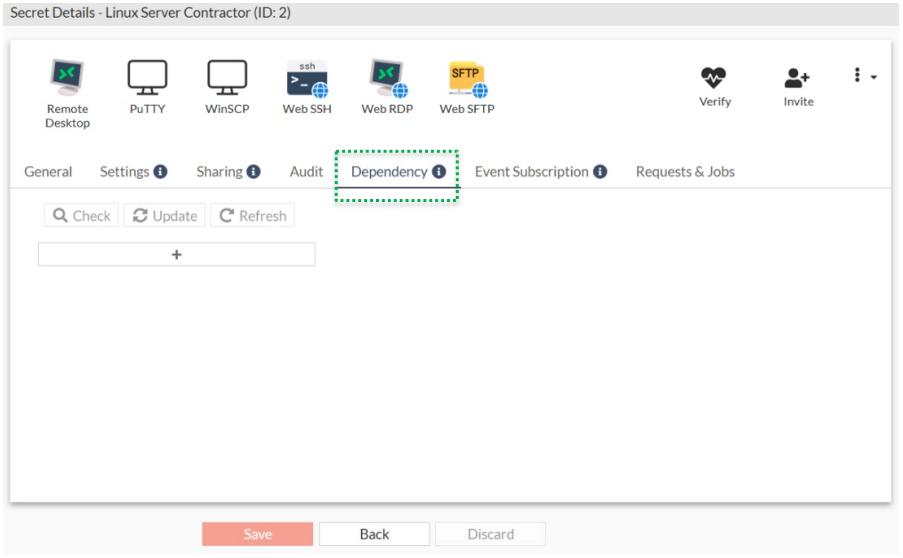

FortiPAM KVM
interim build1232
English
Create new Secret in
Public
Personal
Contractor Secrets
Select

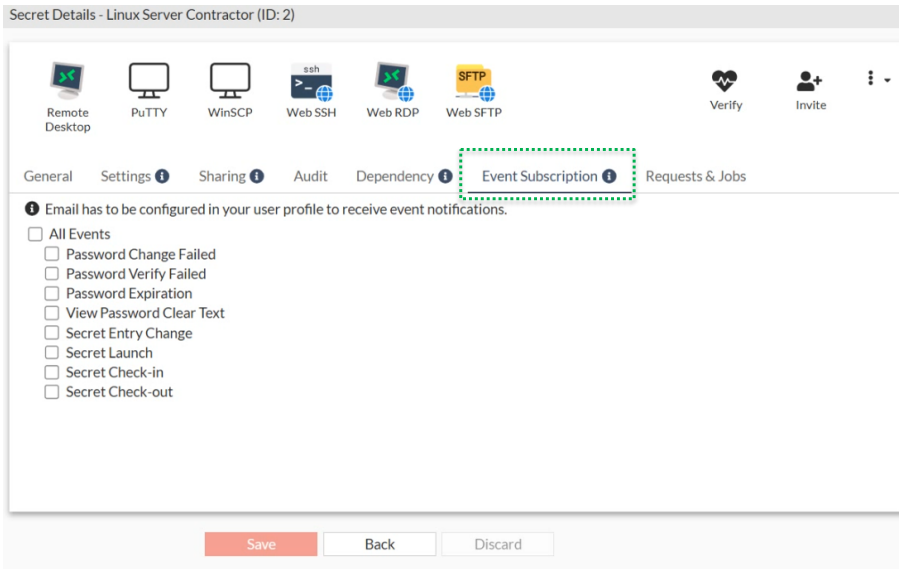
Check available options in the secret settings tab before saving this secret.

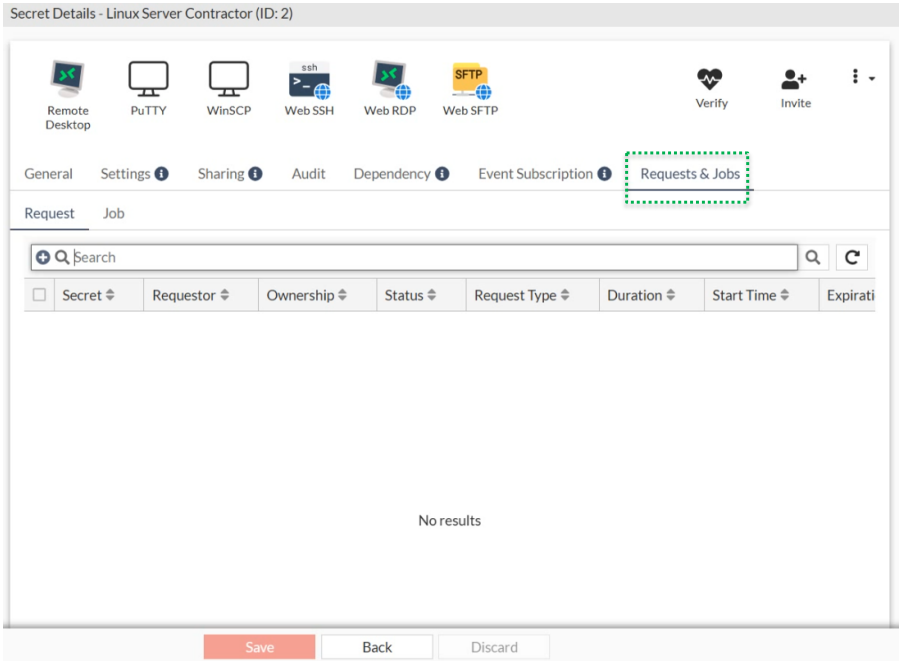



Secret Details - Linux Server Contractor (ID: 2)
Remote Desktop
PuTTY
WinSCP
Web SSH
Web RDP
Web SFTP
Verify
Invite
General
Settings
Sharing
Audit
Dependency
Event Subscription
Requests & Jobs
ZTNA
Inherit ZTNA Control
ZTNA Control
Permission
Inherit Permission
User / Group
Permission
Allowed Service
admin
Owner
All Services
Contractors
View
All Services
Invitee
No external user is invited
Save
Back
Discard

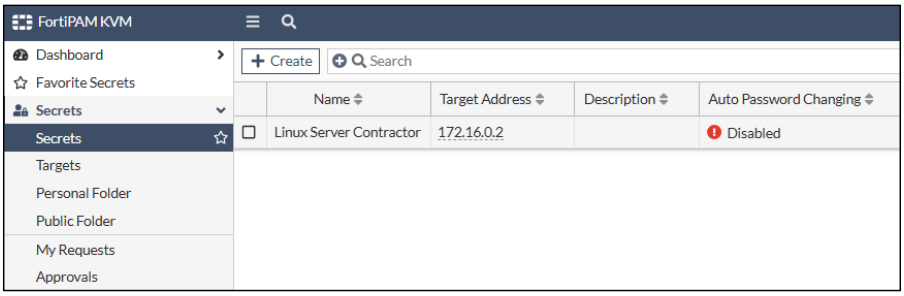

Secret Details - Linux Server Contractor (ID: 2)
Remote Desktop
PuTTY
WinSCP
Web SSH
Web RDP
Web SFTP
Verify
Invite
General
Settings
Sharing
Audit
Dependency
Event Subscription
Requests & Jobs
Secret Log
Edit History
SSH Log
DLP Log
Antivirus Log
Credential History
Export
Disk
Details
Search
Date/Time
User
Launcher
Operation
Message
Source IP
Source Port
Gateway
No results
Save
Back
Discard


Secret Details - Linux Server Contractor (ID: 2)
Remote Desktop
PuTTY
WinSCP
Web SSH
Web RDP
Web SFTP
Verify
Invite
General
Settings
Sharing
Audit
Dependency
Event Subscription
Requests & Jobs
Check
Update
Refresh
+
Save
Back
Discard


Secret Details - Linux Server Contractor (ID: 2)
Remote Desktop
PuTTY
WinSCP
Web SSH
Web RDP
Web SFTP
Verify
Invite
General
Settings
Sharing
Audit
Dependency
Event Subscription
Requests & Jobs
Email has to be configured in your user profile to receive event notifications.
All Events
Password Change Failed
Password Verify Failed
Password Expiration
View Password Clear Text
Secret Entry Change
Secret Launch
Secret Check-in
Secret Check-out
Save
Back
Discard



These options can be configured in a Secret Policy which can be applied to a folder. You will look at these options again in a later step. ***Save*** the Secret.

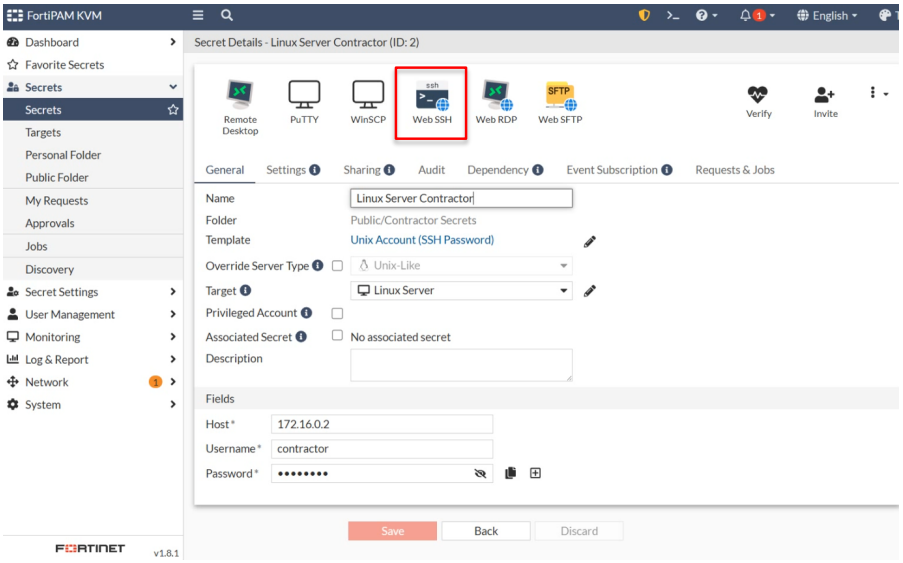


5.3 Test Contractor Access

On the Windows workstation use Chrome (use Incognito mode) to login to https://pam.fortipam.lab as ***contractor***.
Navigate the menu structure to the limited options available since the contractor user account is a standard user with only access to the folders and secrets it has been given permissions to.

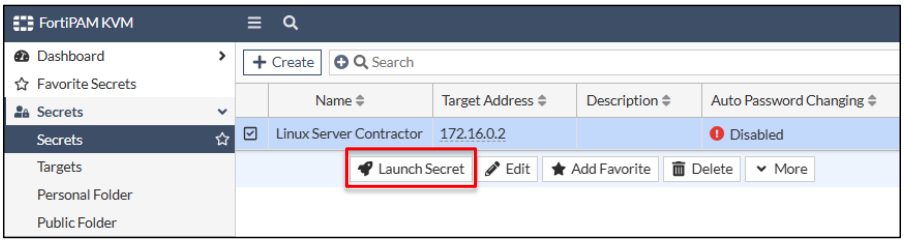
Go to *Secrets* > *Secrets* and double click the *Linux Server Contractor* secret:

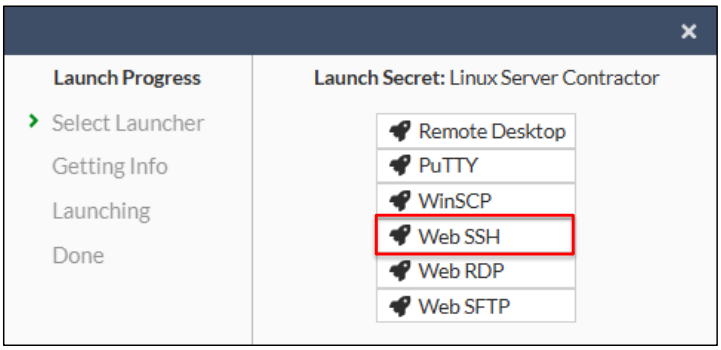
The displayed launchers are the default launchers configured for the *Unix Account (SSH Password)* Secret Template. Select the WebSSH launcher. Note the new icons in PAM v1.9 for the launchers.



Or

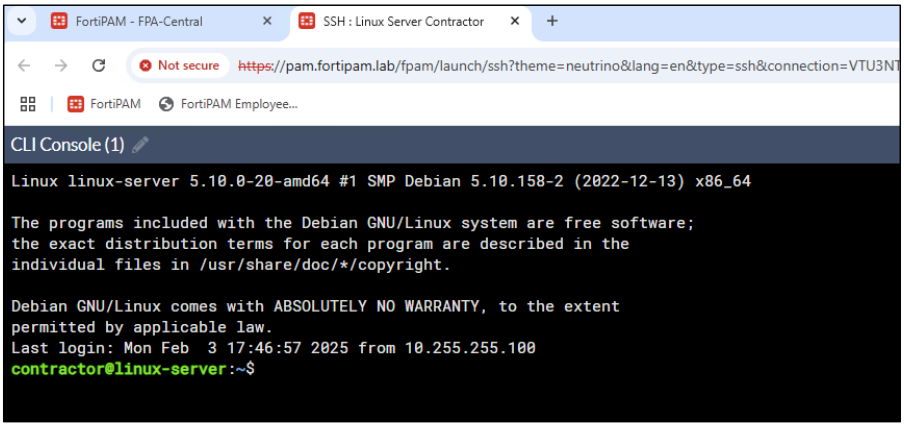
Go to *Secrets* > *Secrets* and select *Linux Server Contractor* secret and click *Launch Secret*. Select *WebSSH*:



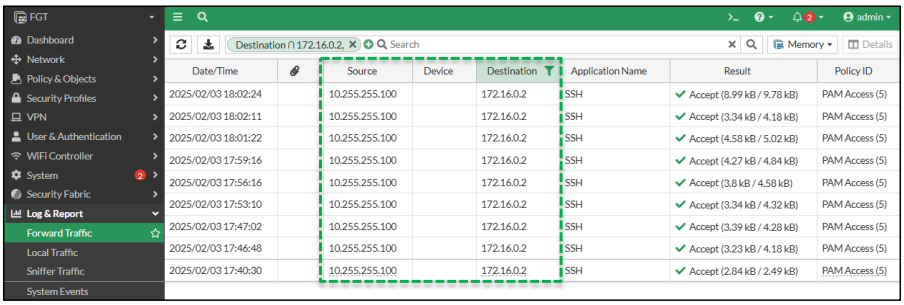


Some of these are Windows applications which are not relevant to a Linux server (e.g. RDP related launchers) and can also not be launched using the browser extension. It would be more appropriate to create a custom Secret Template that included only the Web launchers. Select Web SSH.

You will be logged in without being prompted for credentials. The *contractor* user never needs to know the credentials to login to the Linux server.



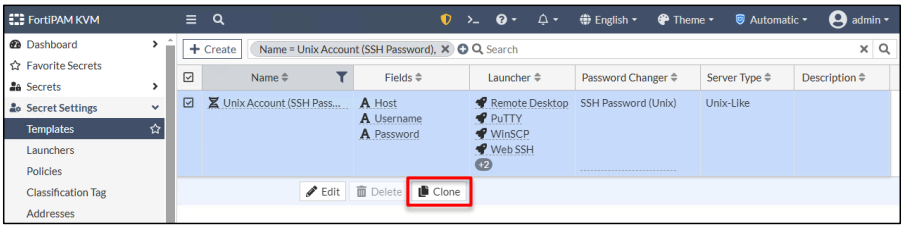
Open a management session to the FortiGate, open a HTTPS session to 10.1.0.1 from the windows workstation. Check the Forward Traffic logs (got to FortiGate GUI via Fabric Studio https://yourlabip:13000/ login with admin / F0rtiPAM) and look for traffic in Log & Report > Forward Traffic, filter Destination to the Linux Server, 172.16.0.2. Notice that traffic never comes from the Windows workstation, it is sourced from the FortiPAM interface address (10.255.255.100) as it is proxying all traffic to the hosts defined in the secrets.



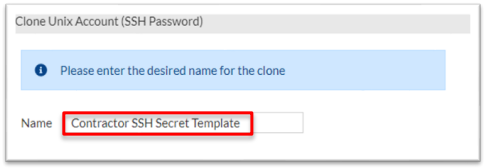
5.3.1 Customer Secret Template

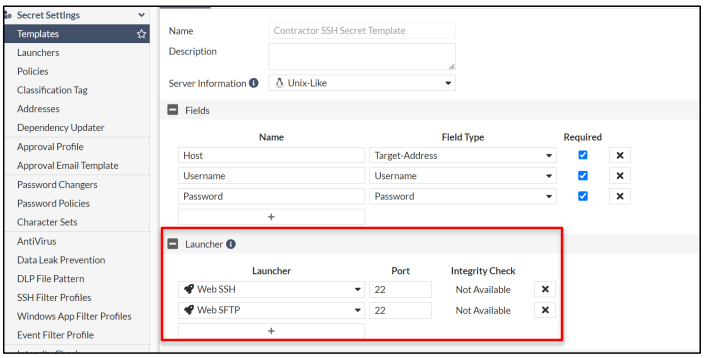
Now you will create a custom Secret Template to only make available the WebSSH and WebSFTP launchers for the contractor user.

Login to FortiPAM GUI as ***SuperAdmin***, go to *Secret Settings* > *Templates* and select the *Unix Account (SSH Password)* template. Click *Clone*:

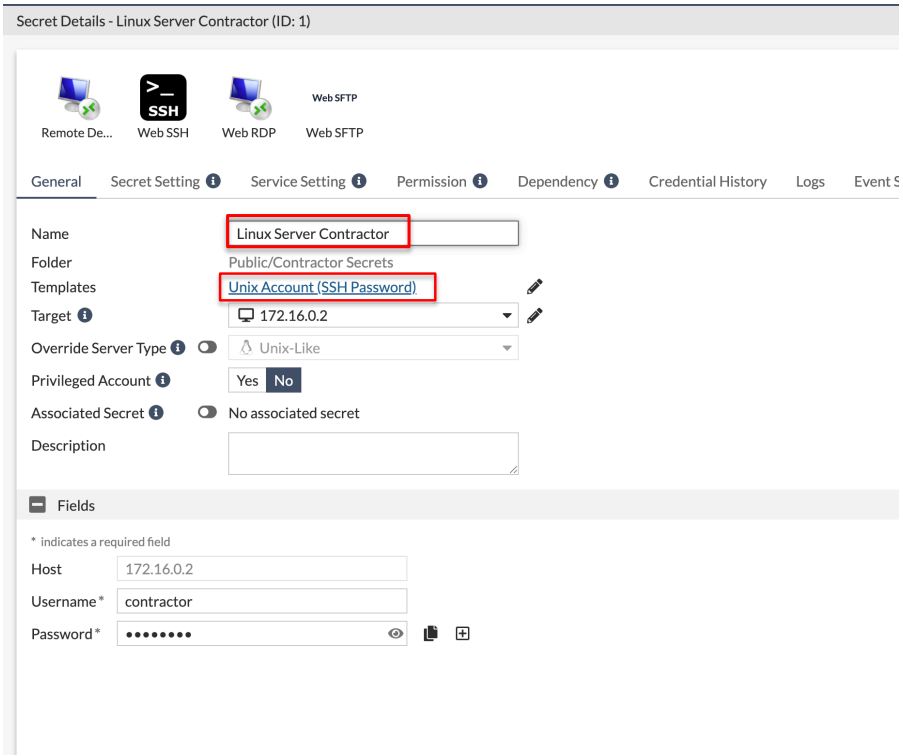


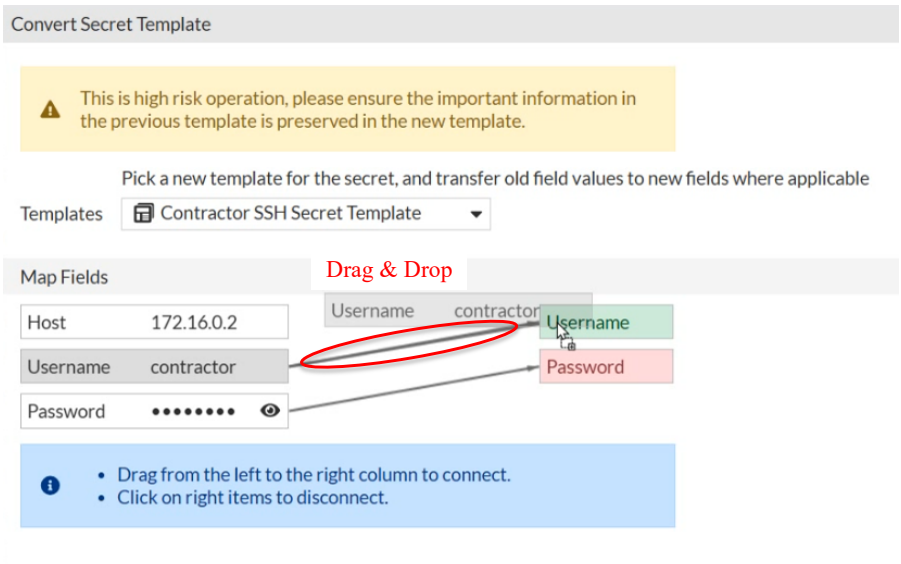
Name the new template "*Contractor SSH Secret Template*" (change the name slightly if it already exists). Edit the new template, keep only the Web SSH and Web SFTP launchers and save the changes. If it gives you an error that the template already exists give it another name and use in the lab your created template.





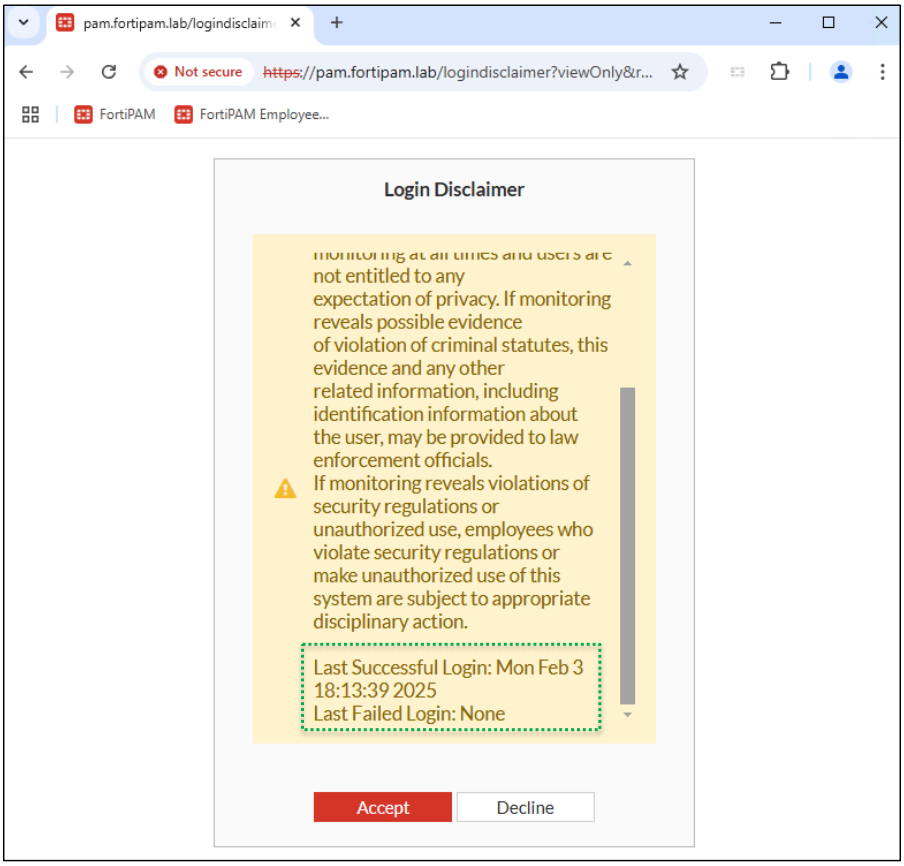
Go to *Secrets* > *Secrets* and edit the "Linux Server Contractor" Secret. Assign the new Secret Template by clicking the link to the existing Secret Template:

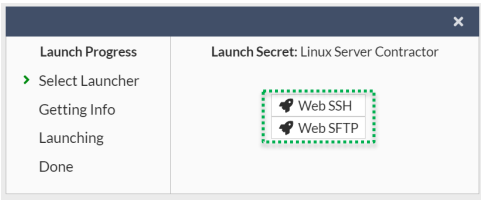




Save the changes.

On the Windows workstation use Chrome (use Incognito mode) to login to https://pam.fortipam.lab as ***contractor*** and test the modified secret. Notice on the login banner that there is now a *last login* time displayed.





5.3.2 Using the guest user for contractors

The Guest User role is one of several predefined user types in FortiPAM, each with increasing levels of access:

- **Guest User:** For demonstration or limited external access. Can only view and use specifically assigned secrets.
- **Standard User:** A basic user who can log in and request access to resources.
- **Power User:** Can manage general secret settings.
- **Administrator:** Full configuration and management rights over the FortiPAM system.

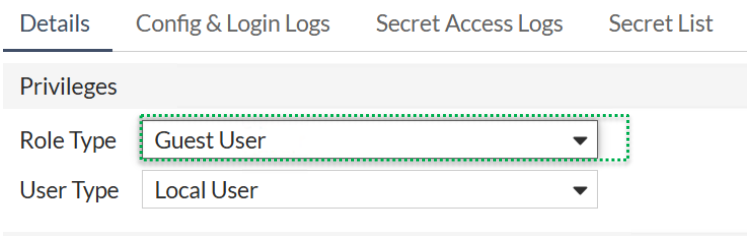
The Guest User Experience
The entire interface for a guest is streamlined to focus only on the task at hand—accessing secrets. Here's what that experience looks like:

- **Focused Login and View:** The login process is the same, but upon successful login, the guest is taken to a simplified interface. The standard tree menu is gone, and they only see a **card-based layout** displaying the secrets that have been explicitly shared with them.
- **Interaction Based on Secret Policy:** How a guest interacts with a secret card depends entirely on the security policy configured by the administrator for that specific secret

We are now going to use the guest user profile for our contractor user.

Login to FortiPAM GUI as ***SuperAdmin***, go to User Management > User List > double click contractor.

Change his role type to Guest User and **SAVE**.

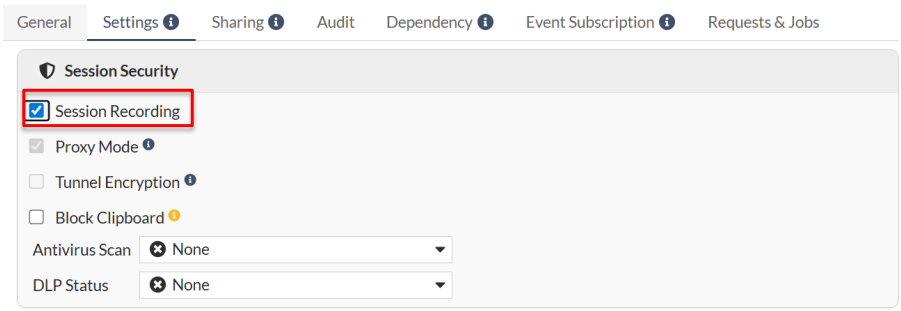


Log out as SuperAdmin, login as contractor. See the differences in the Gui. It is now a very minimized Gui with only options for launching secrets.

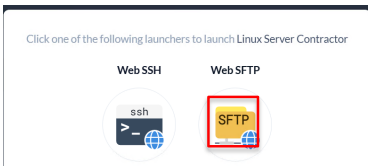
5.3.3 Enable Session Recording

Now you will enable session recording so that a video record is made of all sessions using this secret.

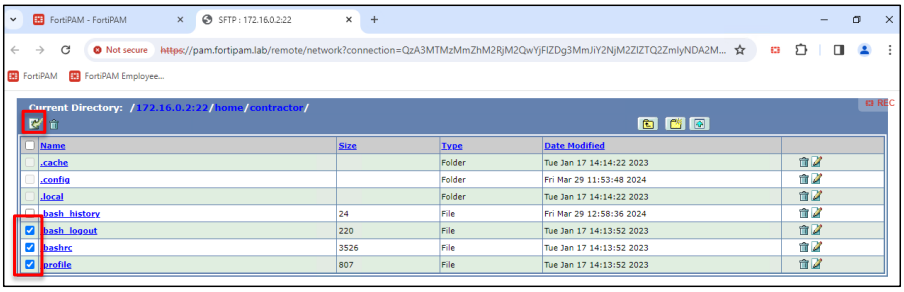
Login to FortiPAM GUI as ***SuperAdmin***, edit the secret, go to Settings tab, enable Session Recording and save the changes.



On the Windows workstation, login to https://pam.fortipam.lab as ***contractor***, launch WebSFTP to test.

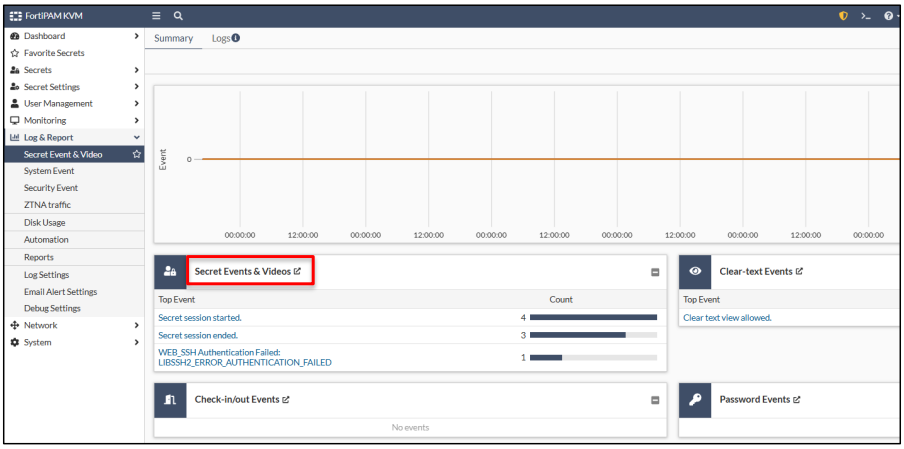


Select some files and download them

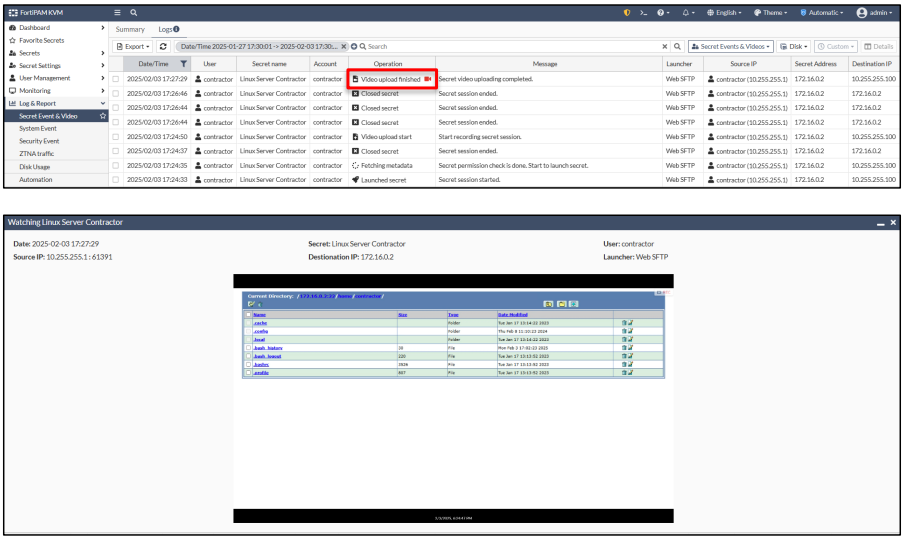


Logout using the button on the far right or close the window.

Login to FortiPAM GUI as ***admin***. Go to *Log & Report* > *Secret Event and Video* and Click *Secret Events and Videos*.



Double-click the first log entry and playback the video

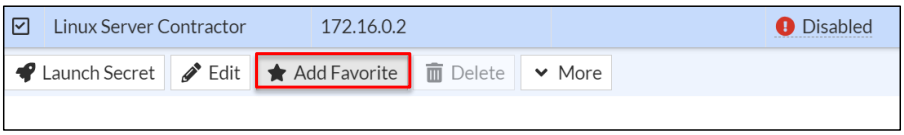


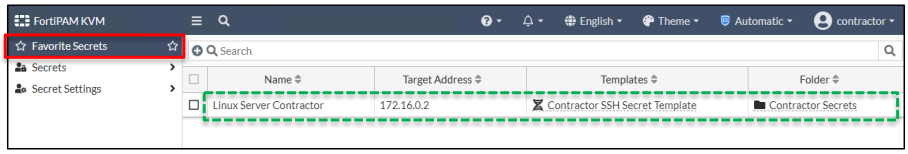
5.3.4 Favorite Secrets

Change the user role of the user contractor back to standard User. Login to FortiPAM GUI as ***SuperAdmin***, go to User Management > User List, double click contractor.

Change his role type to Standard User and **SAVE**

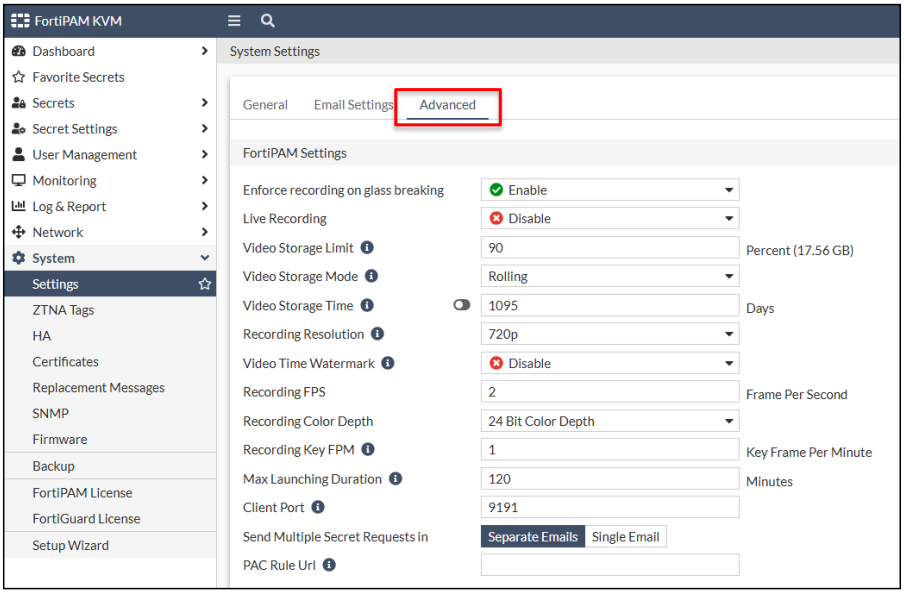
You can add a Secret to your Favorites, do this after logging in as *contractor*. It will then be displayed under *Favorite Secrets*





5.4 Modify Video Recording Settings

The video recording in the previous exercise was not the default settings. The default settings are in: *System > Settings > Advanced > See picture.*

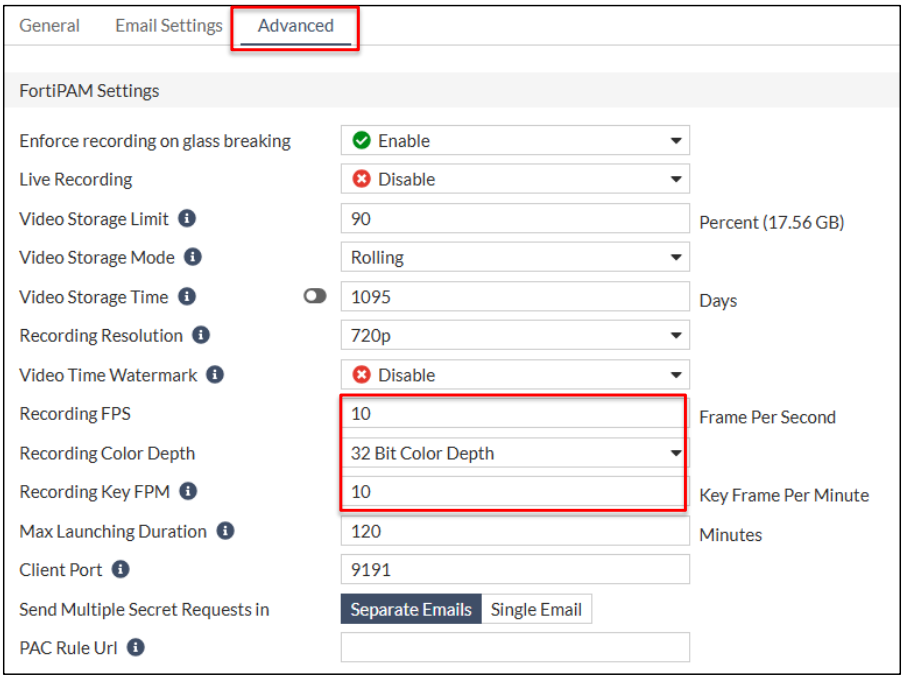


These settings are good for conserving disk space (approximately 250MB per hour with default settings), but many customers may want higher quality recordings. Note that higher quality recordings with more FPS and Key FPM will use more disk space and more network bandwidth - this should be considered when planning a FortiPAM deployment.

If these setting have not already been modified, you will now go and modify the recording settings.

Login to *FPA-Central* GUI as ***admin*** and go to *System > Settings > Advanced*. Modify the PAM settings as follows and click Apply to save changes:

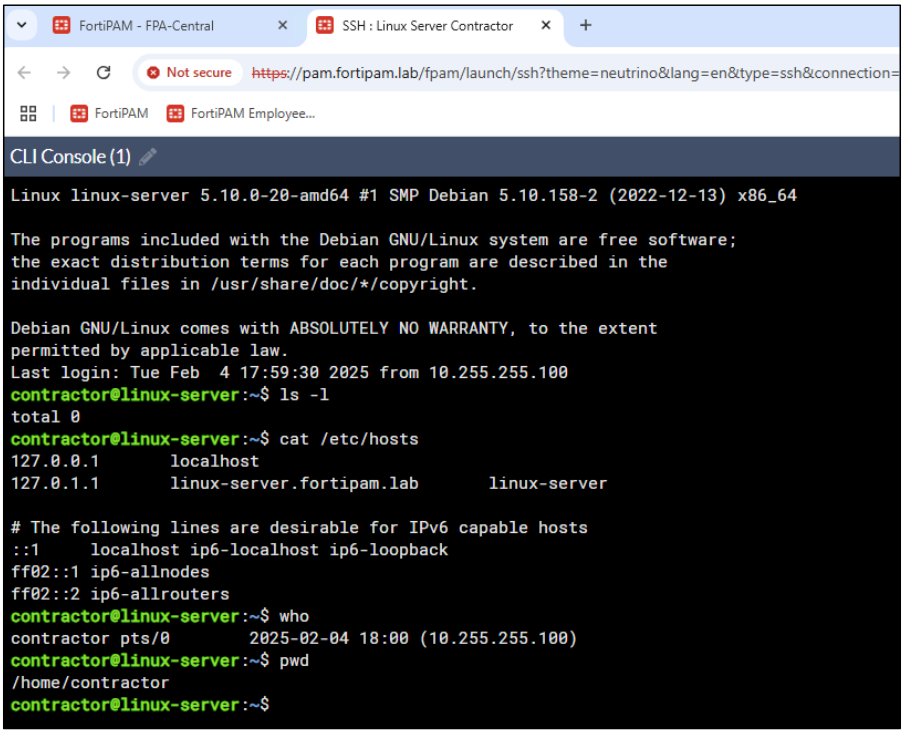
- Recording FPS: ***10***
- Recording Color Depth: ***32 Bit Color Depth***
- Recording Key FPM: ***10***



Click *Save.*

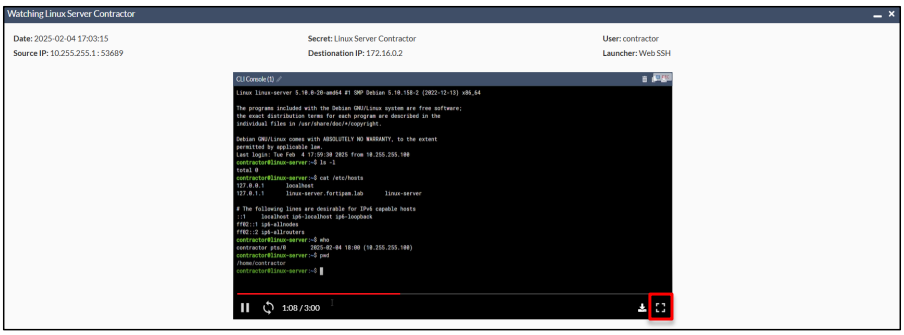
5.4.1 Test Modified Recording Settings

Login to https://pam.fortipam.lab on the Windows Workstation as ***contractor*** and launch a Web SSH session to the Linux Server. Enter some commands, such as "*ls -l /*" and "*cat /etc/hosts*".



Login to FortiPAM GUI as ***admin*** and view the recording at *Log & Report* > *Secret Event and Video* and Click *Secret Events and Videos*

Note that you can view the video full screen by clicking the full screen button:



Note the improved video quality.

6 Enable FortiPAM for Employee Access

We will upload a new config file to the FortiGate for these exercises.
Access the Fortigate and login with admin.
Go to Admin > Configuration > Restore
Use upload and restore the configuration: Fortigate Config.conf

6.1 Create Employee Users and Groups

The Windows 2022 server has the following users/groups already configured:

- *pamaduser* – member of "*PAM Users*"
- *pamadadmin* – member of "*PAM Admins*"

There are several advantages of using provisioned users in FortiPAM. The most immediate advantage is that administrators no longer need to create each user manually. With automated provisioning, remote users are automatically created in FortiPAM upon their first successful login based on predefined rules. This "set it and forget it" approach saves significant time and effort, especially in larger organizations.

FortiPAM supports auto-provisioning regardless of the authentication protocol, including LDAP, RADIUS, or SAML. This means you can connect FortiPAM directly to your existing corporate identity infrastructure—whether it's Microsoft Entra ID (via SAML), Active Directory (via LDAP), or another LDAP/RADIUS source—and users are provisioned automatically based on their group membership.

Role-Based Access Control from the Start

When you create an auto-provisioning rule, you define the user's role (access profile) based on the remote group they belong to in your identity source. This ensures that:

- Users are granted the appropriate permissions immediately upon first login
- Permissions are consistent across all users in the same group
- The principle of least privilege is enforced automatically
- Scalability Without Administrative Overhead

As your organization grows, the number of users who need access to FortiPAM will grow too. Automated provisioning ensures that onboarding scales effortlessly. You don't need to add headcount in your security team just to manage user accounts—the system handles it for you.

Supports Zero Trust and Compliance
Automated provisioning aligns with Zero Trust principles by tightly integrating with your identity provider. Combined with FortiPAM's Just-in-Time (JIT) access, approval workflows, and session monitoring, auto-provisioning contributes to a comprehensive audit trail. Every user action is tied back to their provisioned identity, which is essential for meeting compliance standards like NIS2, ISO 27001, and PCI-DSS.

Efficient License Management
If a rule is disabled or deleted, or if a user no longer matches any provisioning rule, they

become "out-of-sync." Importantly, **out-of-sync users do not occupy license seats**. This ensures you're only paying for active, authorized users and helps maintain license hygiene.

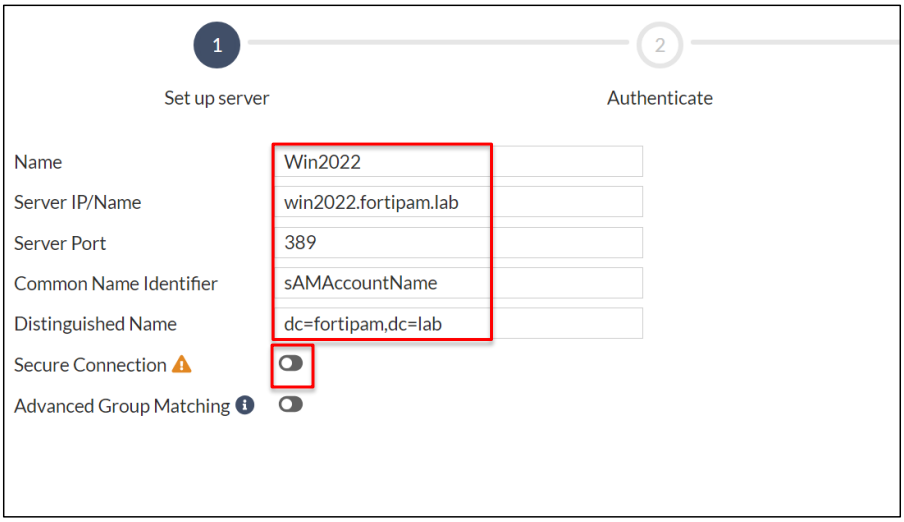
Visibility into User Origin
FortiPAM includes a **"Created By" column** in the User List, allowing administrators to easily distinguish between manually created users and those who were auto-provisioned. This provides clear visibility into how users were onboarded.

For this exercise we are going to focus on the JIT functionality, JIT works with AD/LDAP, SAML and Radius servers. In this exercise we are going to use AD.

6.1.1 Configure LDAP Server

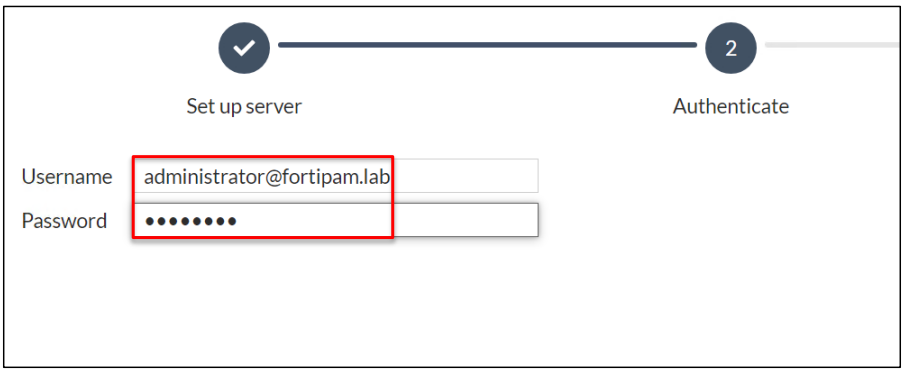
Login to FortiPAM GUI as ***admin***. Go to *User Management* > *Ldap Servers* and click Create if server does not exist. Configure or check the following:

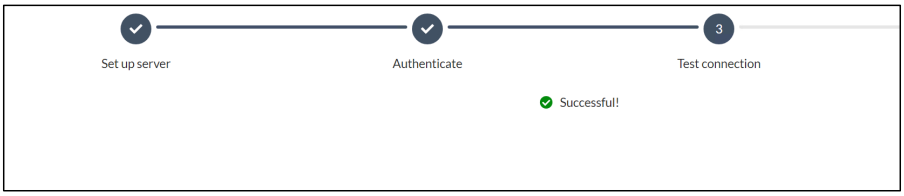
- Name: ***Win2022***
- Server IP/Name: ***win2022.fortipam.lab***
- Server Port: ***389*** (When you disable the secure connection setting, it will automatically change to 389.)
- Common Name Identifier: ***sAMAccountName***
- Distinguished Name: ***dc=fortipam,dc=lab***
- Secure Connection: ***Uncheck***
- Server Identity Check: ***Disabled (must be disabled before disabling secure connection)***
- Secure Connection: ***Disabled***



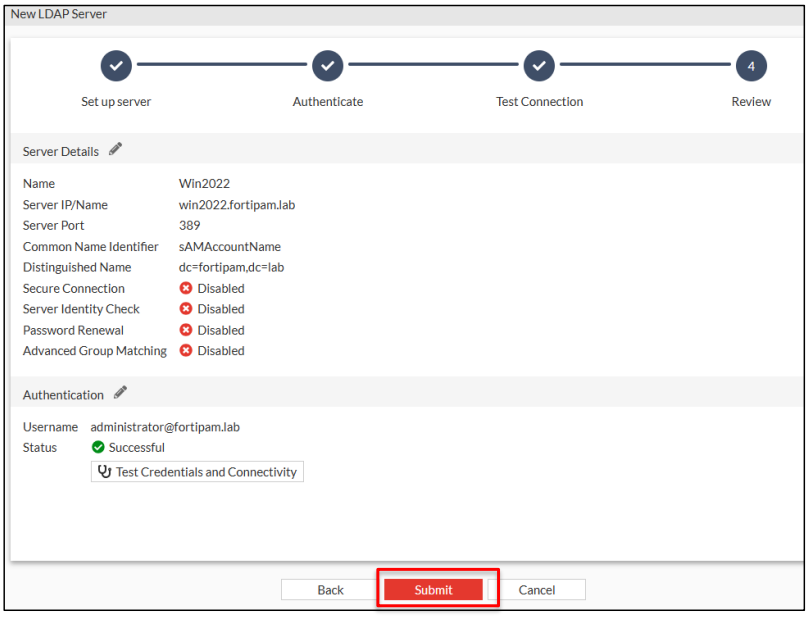
Click *Next*

Enter the *administrator@fortipam.lab* / *F0rtiPAM* credentials and click *Test connection*:





Click *Next*

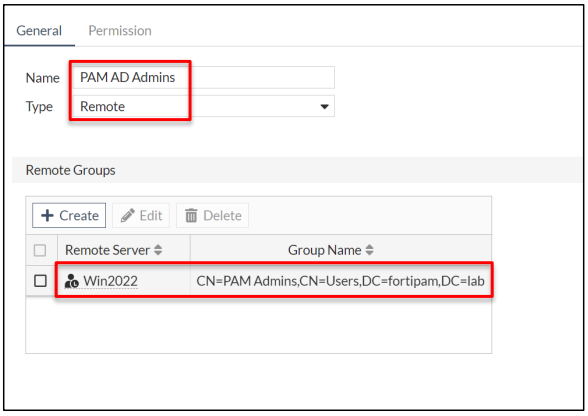


Click *Submit* to save the LDAP server configuration.

6.1.2 Create Groups

Go to *User Management* > *User Groups* and click *Create* if not created yet:

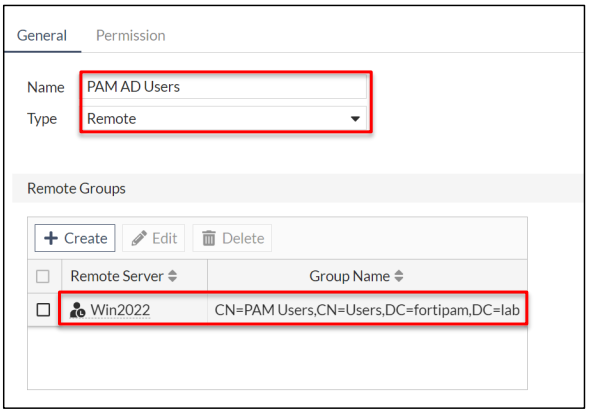
- Name: ***PAM AD Admins***
- Type: ***Remote User Group***
- Remote Groups: *[click create, select the previously created LDAP server and then select the **PAM Admins** group from the list in Active Directory]*

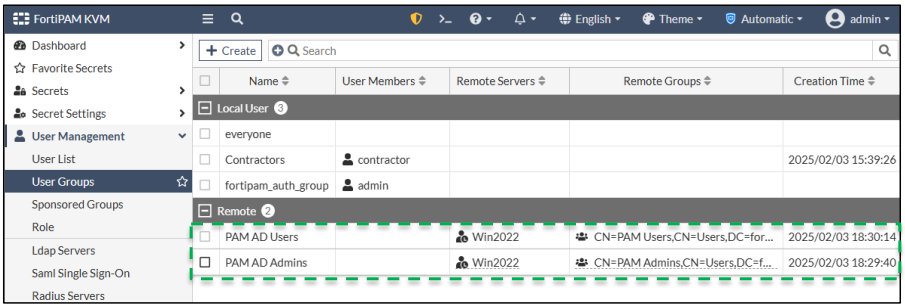


Click OK to save.

Repeat the process for the ***PAM AD Users*** group:

- Name: ***PAM AD Users***
- Type: ***Remote User Group***
- Remote Groups: *[click create, select the previously created LDAP server and then select the **PAM Users** group from the list in Active Directory]*



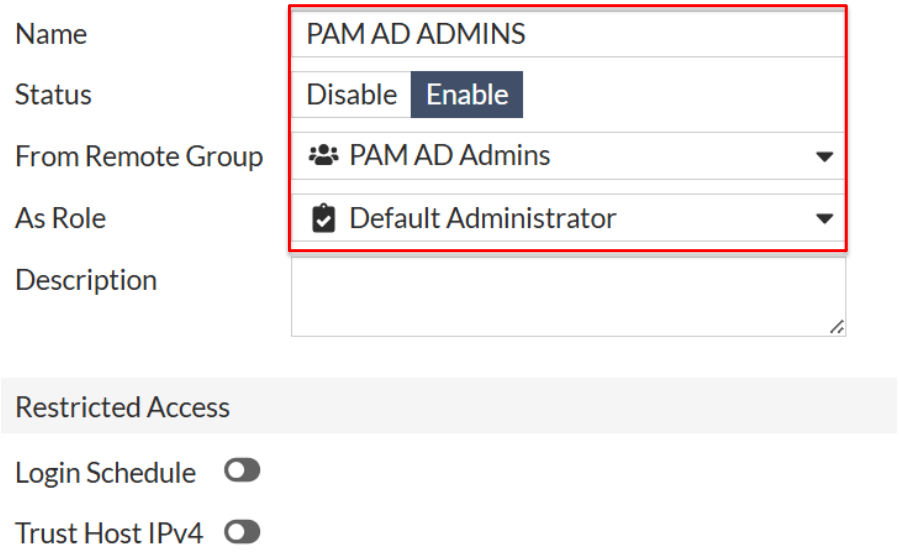


6.1.3 Create Auto Provisioning Rule

Go to *User Management* > *Auto Provisioning Rule* and click *Create* if not created yet.

Create the following rule

- Name：***PAM AD ADMIN***
- Status: ***ENABLE***
- From Remote Group: ***PAM AD Admins***
- As Role: ***Default Administrator***

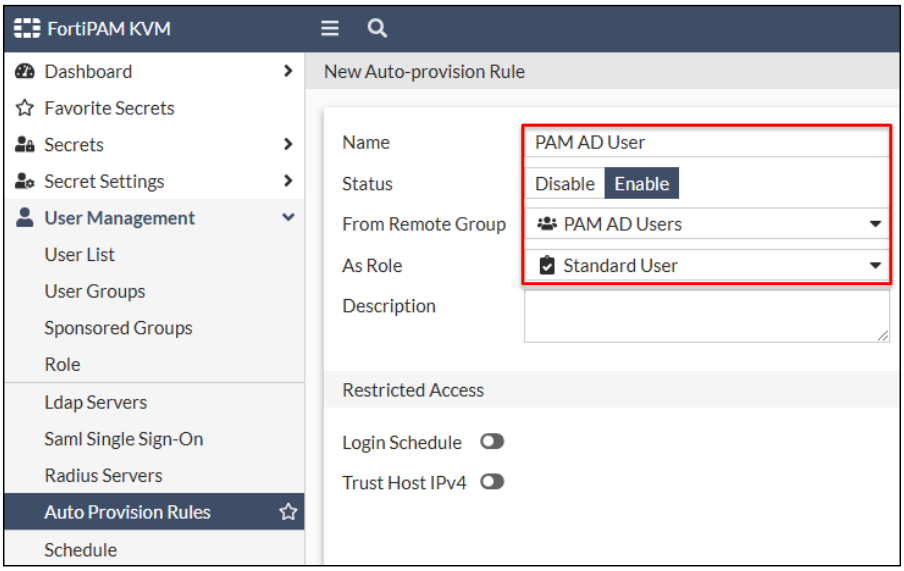


Click *Submit*

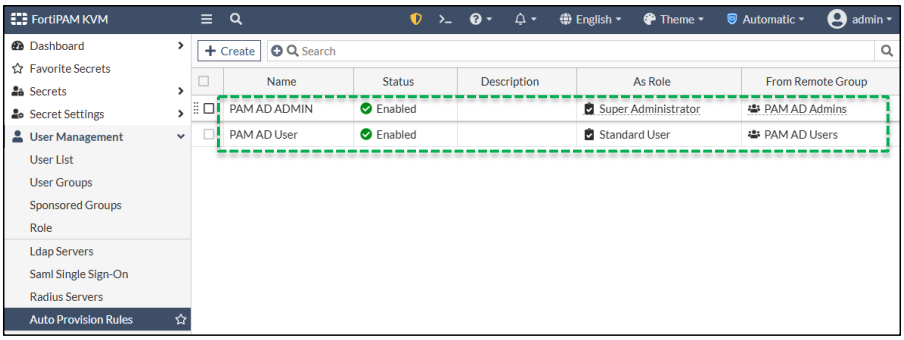
Create the following rule if not created yet

- Name ***PAM AD User***

- Status ***ENABLE***
- From Remote Group ***PAM AD Users***
- As Role ***Standard User***



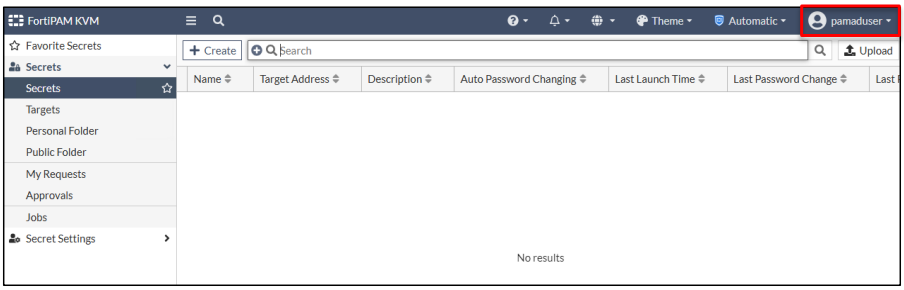
Click *Submit*

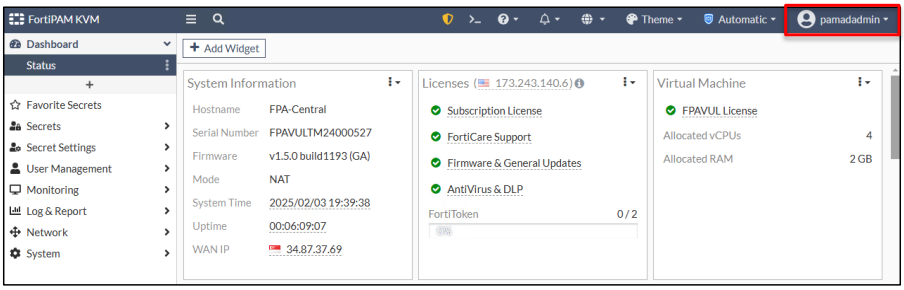


6.1.4 Test Employee User Login

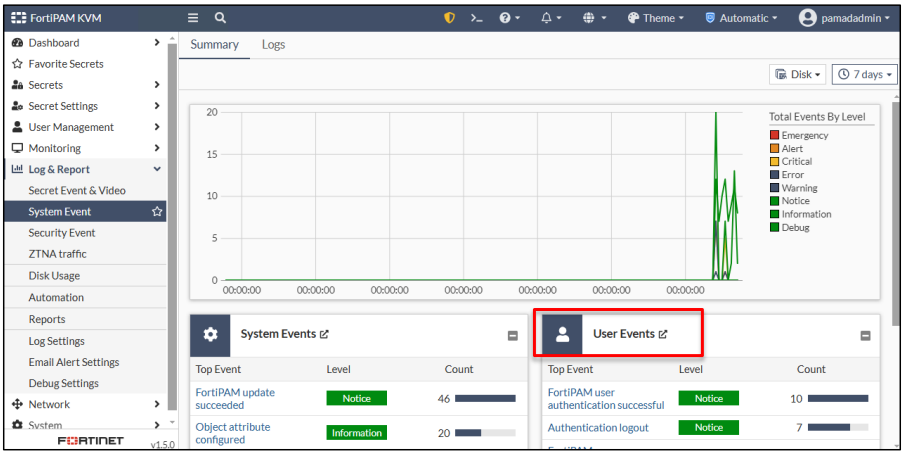
Check if pamaduser and pamadadmin users already exist on the FortiPAM. If so delete them.

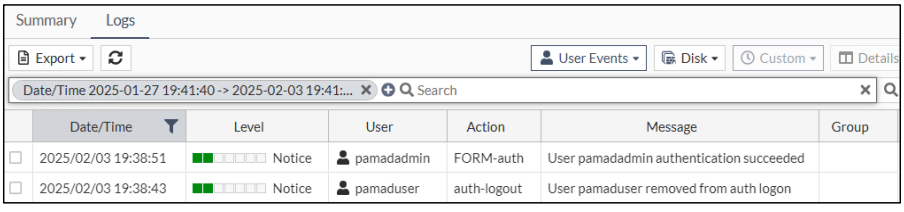
Test the login with ***pamaduser*** and ***pamadadmin*** by logging in to https://pam.fortipam.lab on the Windows workstation. The AD user will not have any secrets or folders available yet (apart from the personal folder) but should still be able to login.

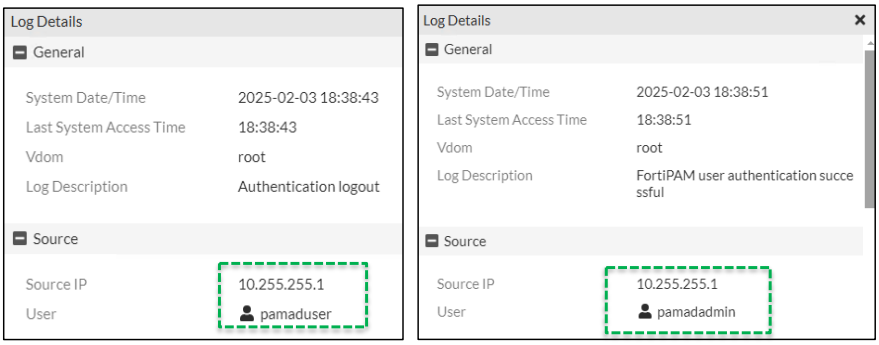




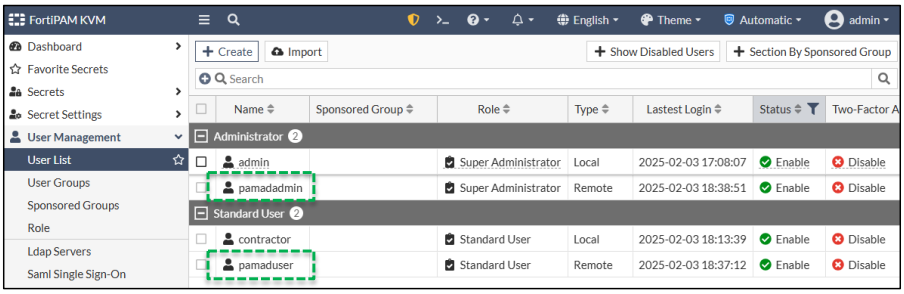
Check the logs when logged as *pamadadmin* at *Log & Report* > *System Events* > *User Events*



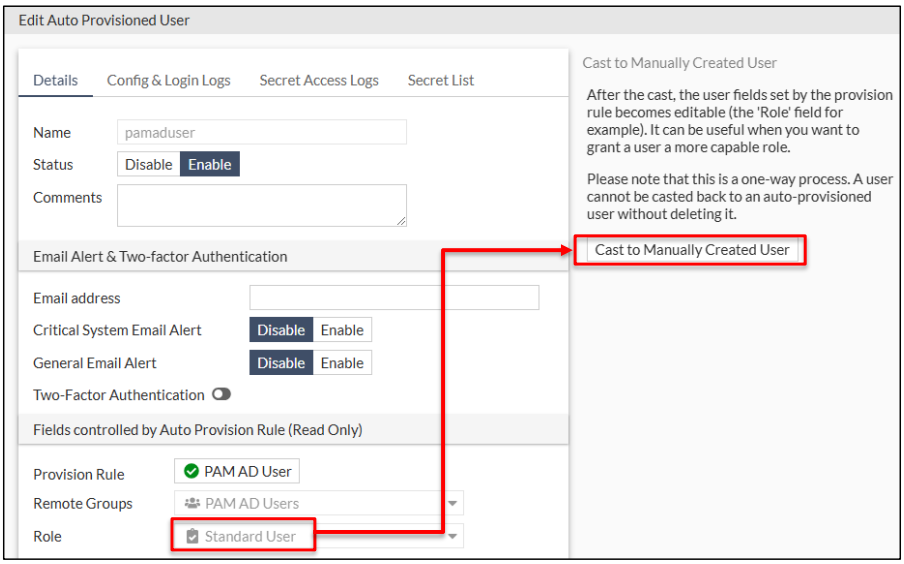




Go to *User Management* > *user list* : the pamadadmin and pamadusers have been created dynamically



Can you spot the difference between a manually created user and a provisioned user? Double click any of the provisioned users.



See the option to change a provisioned user to a manually created user. You can change the role of a manually created user but not of a dynamically provisioned user, so if you need to change the role of a provisioned user, you first need to change it to a manually created user.

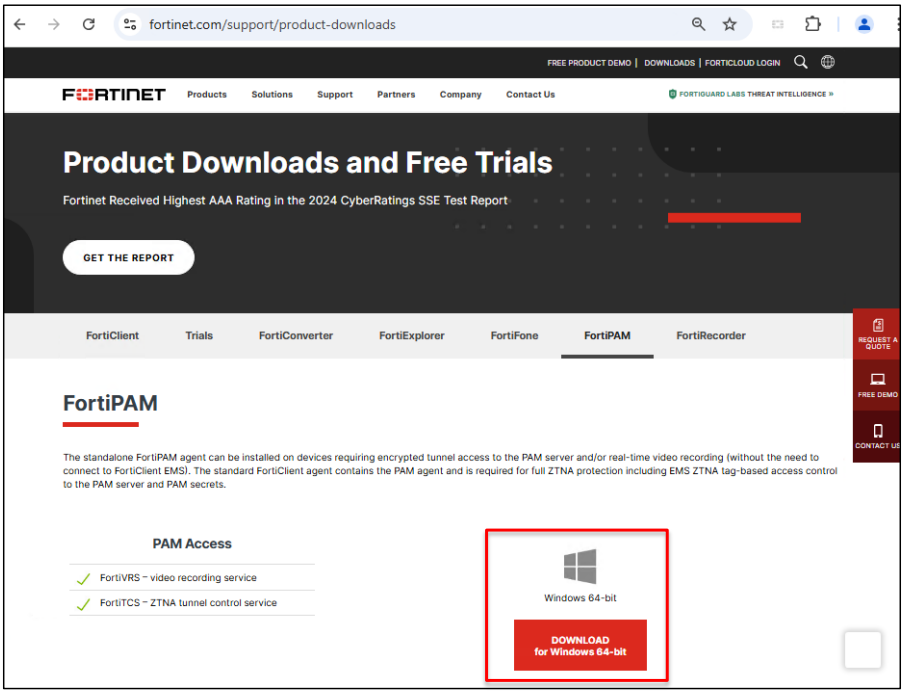
6.1.5 Admin User Usage

Now that you have the *pamadadmin* user working, it is good practice to stop using the default *admin* user to configure FortiPAM and reserve the *admin* user for creating other FortiPAM administrators or enter Glass Breaking mode

6.2 Setup FortiClient for PAM

(DO NOT do this as FortiClient has already been downloaded on your Windows workstation*)**

This is just FYI. There is a free standalone PAM client with just the PAM components. The PAM FortiClient components allow launching of native applications (eg. Putty, RDP Client). This is available on the support site and info site under the FortiClient folder and is named *FortiClientPAMSetup….* You can also download it from the Product Downloads page. Note that the free PAM Agent is not supported by TAC.



In this workshop you are going to install the full FortiClient so that you can configure the ZTNA features.

6.2.1 Explaining ZTNA

This is a lengthy explanation on what ZTNA is, and how it relates to FortiPAM, this is background information that will help you understand the importance of ZTNA but if you are in a hurry or short of time you can skip this section and move to the configuration of ZTNA. However, it is strongly advised to read this in that case on a later date to understand what you have been doing, why, and what the advantages are of it.

ZTNA stands for **Zero Trust Network Access**. At its simplest level, it's a modern way to securely connect users to the applications they need—without trusting them just because they're on the network.
Let me break this down in simple terms.

The Old Way: VPN (The Castle-and-Moat Model)
To understand ZTNA, it helps to understand what came before:
Traditional VPN Thinking:

- ✓ Once you're inside the castle, you're trusted.
- ✓ Welcome! Everything is accessible.

With traditional VPN:

- You log in once
- You get placed "inside" the corporate network

- From there, you can often access many systems
- The network *trusts* you because you're inside

The problem: If an attacker steals your VPN credentials, they're now *inside* your network too—and often can move laterally to find sensitive data.

The ZTNA Way: Zero Trust
ZTNA flips this model completely:
ZTNA Thinking:
Never trust, always verify—every single time – and keep on checking.
Some of the things you can check with ZTNA:

- ✓ Who are you?
- ✓ Is this your device
- ✓ Where are you?
- ✓ Av up to date?
- ✓ What is your keyboard?
- ✓ What time is it?

With ZTNA:

- You're never placed "inside" a network
- You connect *directly* to specific applications, not the network
- Every access request is verified—even if you just accessed something else
- The network remains invisible to you

The Core Principles of ZTNA

Principle	**What It Means**
Never Trust, Always Verify	No user or device is trusted by default—even if they're connecting from the office
Least Privilege Access	Users get access *only* to what they need, nothing more
Micro-segmentation	Applications are isolated from each other; compromising one doesn't expose others
Continuous Verification	Trust is re-evaluated throughout a session, not just at login

How ZTNA Works (Simplified)

1. **User requests access** to a specific application (like Salesforce or an internal tool)
2. **ZTNA checks multiple factors:**
    - Identity: Are you who you say you are? (MFA required)
    - Device: Is your device compliant? (up-to-date, not compromised)
    - Context: Are you connecting from a trusted location? At a reasonable hour?
3. **If all checks pass:** A secure, encrypted connection is created *directly* to that application
4. **If any check fails:** Access is denied

The user never sees the network—they just get access to the app.

Key Benefits of ZTNA

Benefit	What It Means for You
Reduced Attack Surface	The network is invisible; attackers can't scan for vulnerabilities
No Lateral Movement	Even if compromised, an attacker can't jump from one app to another
Consistent Security	Same verification whether you're in the office, at home, or at a coffee shop
Granular Control	Access can be restricted to specific apps, not entire subnets

Real-World Example
Scenario: Sarah, a finance manager, needs to access the corporate accounting system from home.

With VPN:
- Sarah connects to VPN
- She's now "inside" the corporate network
- She opens the accounting app
- While connected, she could theoretically access file servers, HR systems, or development environments—whether she needs to or not

With ZTNA:
- Sarah opens her browser and goes to the accounting app URL
- She authenticates with MFA
- ZTNA checks her identity, device health, and location
- A secure connection is established *only* to the accounting app
- Sarah never sees—and cannot reach—anything else

Why ZTNA Matters Now
Traditional VPNs were designed for a world where:
- Employees worked from offices
- Corporate data lived in data centres
- "Trust but verify" was acceptable

Today:
- People work everywhere
- Data lives in multiple clouds
- Threats are more sophisticated

ZTNA was built for *this* world. It's a core component of **Zero Trust Architecture**, which major security frameworks (NIST, CISA) now recommend—and regulations increasingly require.

In short: **ZTNA means you stop trusting networks and start trusting identity, device, and context—every single time.**

6.2.2 How ZTNA Relates to FortiPAM

Now that you understand ZTNA at a basic level, let's connect it specifically to **FortiPAM**—because this is where the magic happens. FortiPAM doesn't just store secrets; it actively enforces **Zero Trust principles** when granting access to those privileged credentials.

The Core Relationship: ZTNA + PAM = Enhanced Security
FortiPAM integrates ZTNA controls to ensure that before a user can access any privileged secret, their device and context are verified. This moves beyond simple "username and password" security to full endpoint posture assessment.

Here's how it works:

6.2.2.1 Continuous Endpoint Validation

When FortiPAM is integrated with **FortiClient EMS**, it performs continuous ZTNA endpoint validation.

This means:

- **Device compliance is checked** before granting access to sensitive systems
- FortiPAM verifies device profiles for vulnerabilities, installed antivirus protection, and location
- This is described as **"Zero Trust fully realised"** —devices are never trusted by default

6.2.2.2 Tags-Based Access Control

FortiPAM enables ZTNA controls for IT and OT environments **via tags** to check:

- Device vulnerabilities
- Installed virus protection
- Geographic location
- Other security posture indicators

These tags determine whether a device meets the security baseline required to access privileged credentials.

6.2.2.3 Two Layers of ZTNA Protection

When ZTNA endpoint control is enabled, it applies to:

- **FortiPAM user login**—can the user even access the FortiPAM interface?
- **Target server launching**—can the user launch a specific privileged session?

This creates defence in depth: even if someone can log in, their device might still be blocked from launching sensitive sessions if it's non-compliant.

6.2.2.4 Deployment Architecture Requirements

The ZTNA features in FortiPAM require a specific architecture:

Component	Requirement
FortiPAM	Licensed and configured

Component	Requirement
FortiClient EMS	Required for ZTNA functionality
FortiClient	Standard version (not standalone) with ZTNA & PAM features enabled
Result	"Both FortiPAM and the target server are protected by the highest security level"

Important Note: ZTNA is only supported when using standard FortiClient with EMS. Standalone FortiClient or browser-only extensions do not support ZTNA.

6.2.2.5 Real-World Example: ZTNA + FortiPAM in Action

Let's walk through a practical scenario:
The Situation: A senior DevOps engineer needs to access a production database password stored in FortiPAM.

The ZTNA-Enhanced Flow:

1. **Device Check:** The engineer's laptop has FortiClient installed, which reports to EMS
2. **Posture Assessment:** EMS verifies:
    - Windows updates are current
    - Antivirus is enabled and updated
    - Disk encryption is active
    - Device is running corporate image
3. **Context Validation:** The connection is coming from the corporate office during business hours (low risk)
4. **Access Granted:** All checks pass → FortiPAM allows login
5. **Secret Launch:** Engineer requests the database password
6. **Second ZTNA Check:** Even though logged in, FortiPAM re-validates device posture before launching the privileged session, additional checks can be applied before granting access, for example we can check if user is on corporate LAM and not on corporate Wifi and grant him only access if he is on the corporate LAN.
7. **Session Recording:** All activity is recorded for audit

If at any moment during the session of the engineer's his laptop fails the ZTNA checks, ZTNA would block access entirely—regardless of correct credentials. For example, let say the AV detects a virus, until the virus is removed the engineer will not be allowed access and if he has an active session he will be disconnected and logged-off.

6.2.2.6 Why This Combination Matters

Without ZTNA	With ZTNA + FortiPAM
"You have the password? You're in."	"Your credentials are correct, but your device is non-compliant → Access denied."

Without ZTNA	With ZTNA + FortiPAM
Stolen credentials = full access	Stolen credentials + non-compliant device = still blocked
No visibility into endpoint risk	Continuous endpoint posture monitoring
Trust based on who you are	Trust based on who you are + device health + context

Technical Implementation
To set up ZTNA-based access control in FortiPAM, you configure:

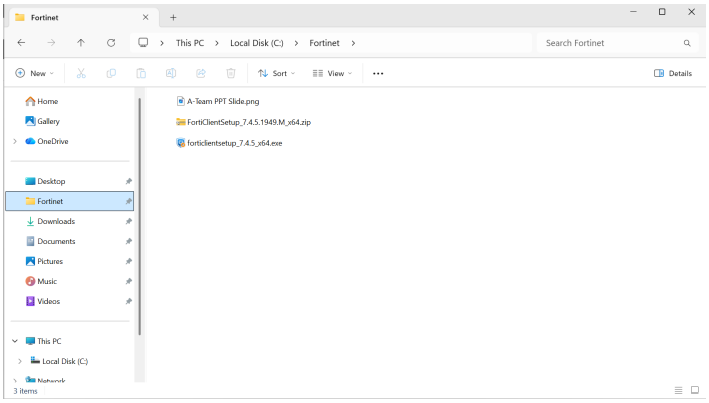
- **ZTNA servers**
- **ZTNA rules**
- **EMS tags** that define compliant device profiles7

When enforced, **devices without FortiClient installed (or without the required tags) cannot access FortiPAM**. This ensures that only managed, compliant devices can reach your privileged credentials.

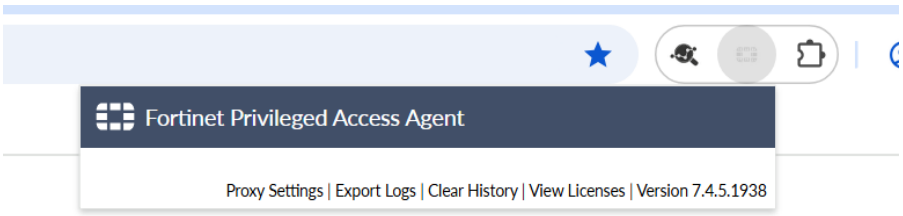
In essence, FortiPAM extends ZTNA principles to privileged access. It ensures that even authorized users with correct credentials cannot access sensitive systems from untrusted or non-compliant devices. This is what makes FortiPAM a complete Privileged Access Management solution rather than just a password manager.

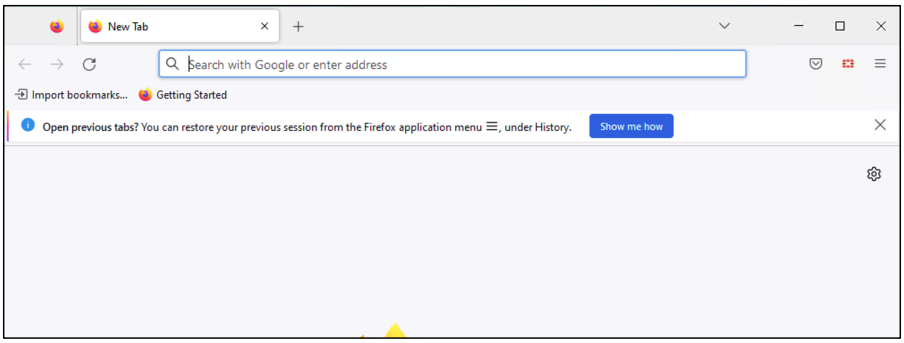
6.2.3 Install FortiClient on Windows Workstation

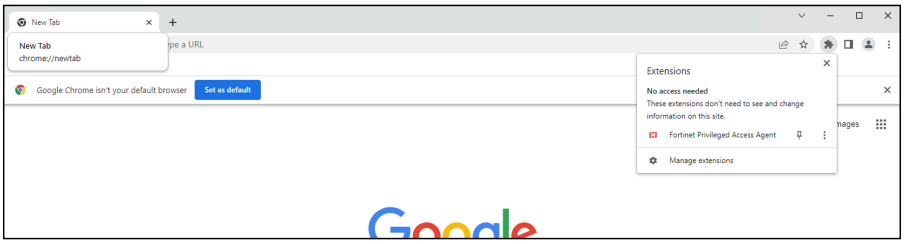
On the Windows workstation go to **C:\Fortinet** and launch the FortiClient installer:



Click through the prompts to complete the install. Check that the *FortiPAM Privileged Access Agent* extension has been installed by FortiClient on all Chrome, Firefox and Edge browsers (note: in first contractor lab we manually installed that extension on Chrome – FortiClient installation does this automatically for all **installed and supported browsers**).



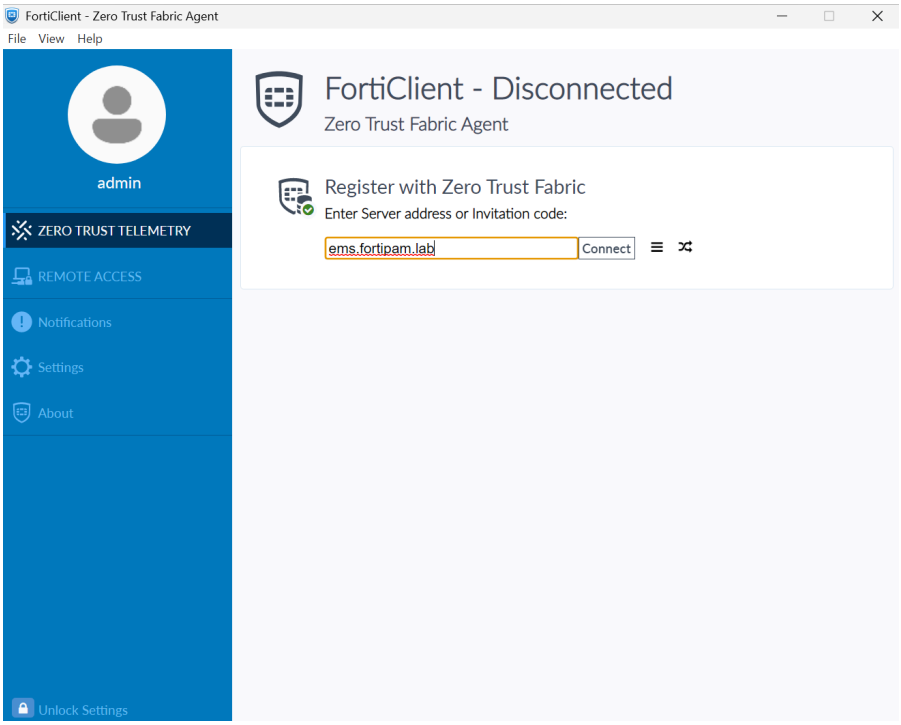


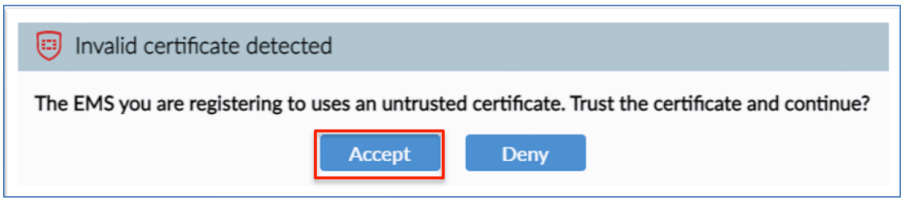


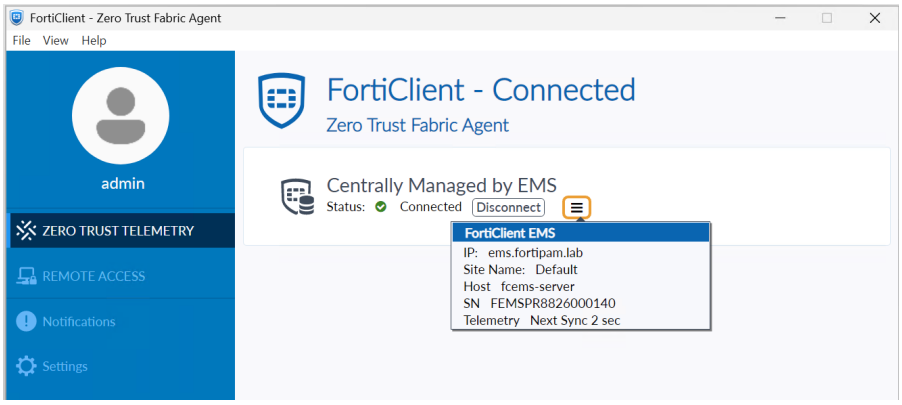
Enable the browser extension to run in Chrome Incognito windows by going to chrome://extensions in the URL bar and editing the details for the browser extension.

6.2.4 Register Windows Workstation with EMS

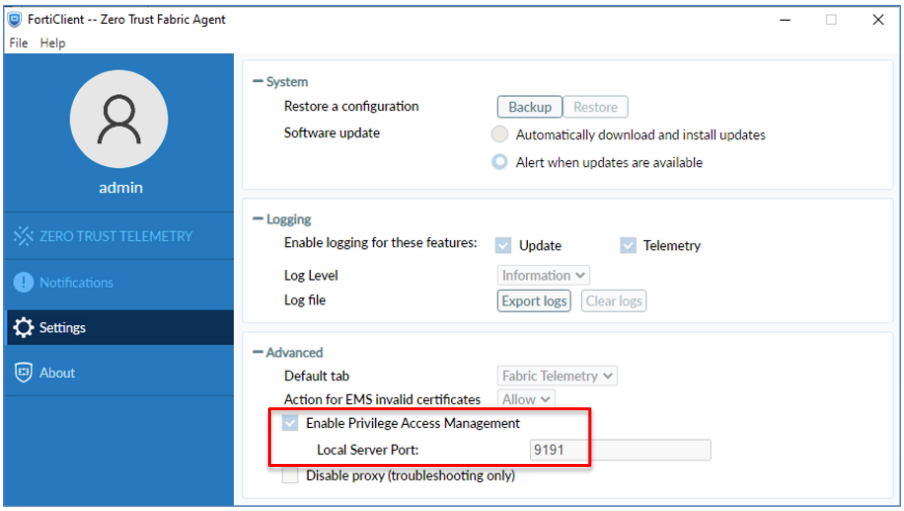
On the Zero Trust Telemetry tab of FortiClient, connect to ***ems.fortipam.lab*** and accept the EMS certificate if not already connected.


FortiClient - Zero Trust Fabric Agent
File View Help
admin
ZERO TRUST TELEMETRY
REMOTE ACCESS
Notifications
Settings
About
Unlock Settings
FortiClient - Disconnected
Zero Trust Fabric Agent
Register with Zero Trust Fabric
Enter Server address or Invitation code:
ems.fortipam.lab
Connect


Invalid certificate detected
The EMS you are registering to uses an untrusted certificate. Trust the certificate and continue?
Accept
Deny

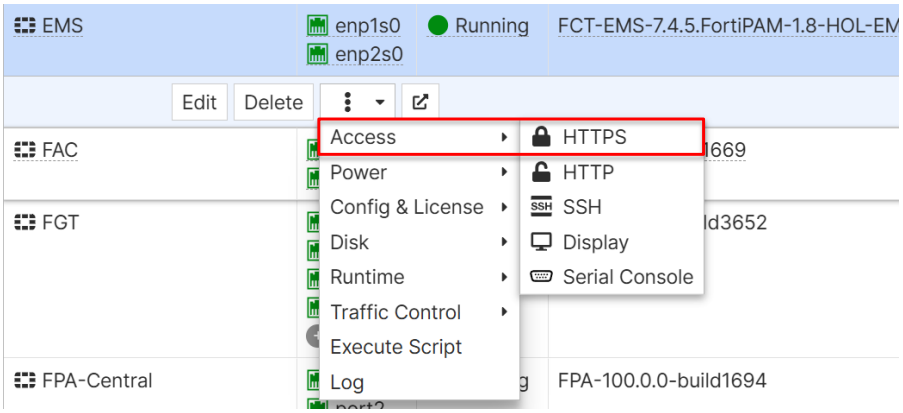

FortiClient - Zero Trust Fabric Agent
File View Help
admin
ZERO TRUST TELEMETRY
REMOTE ACCESS
Notifications
Settings
FortiClient - Connected
Zero Trust Fabric Agent
Centrally Managed by EMS
Status: Connected
Disconnect
FortiClient EMS
IP: ems.fortipam.lab
Site Name: Default
Host fcems-server
SN FEMSPR8826000140
Telemetry Next Sync 2 sec

Once connected, FortiClient will receive its configuration from EMS. Go to the *Settings* tab and check that Privileged Access Management is enabled, if it is not enabled do not worry we will enable it during this lab.



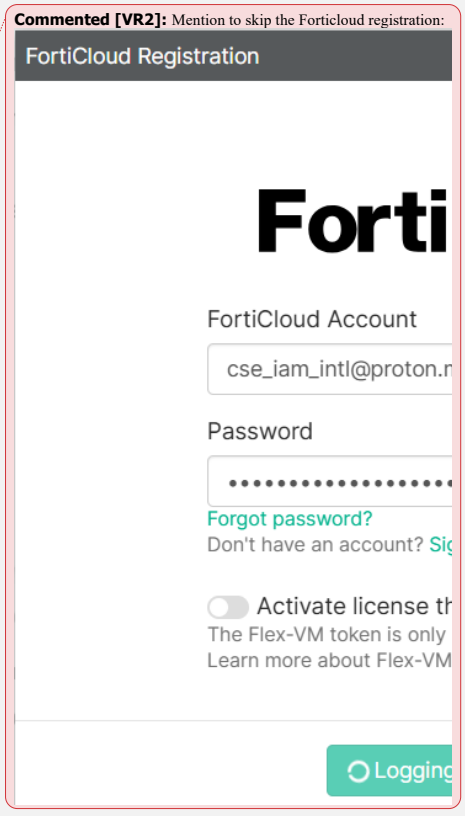
6.2.5 Review EMS Server Configuration

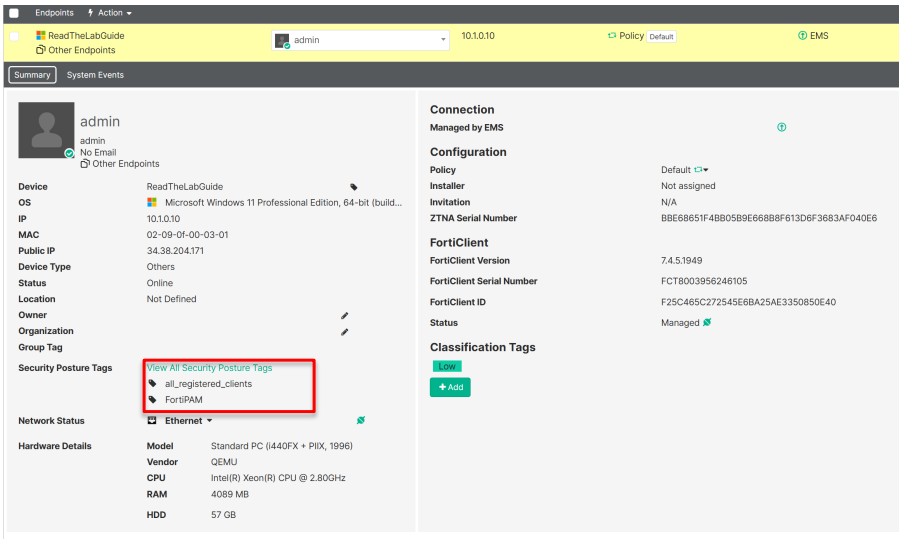
Connect to the EMS server using HTTPS by using *Access* > *HTTPS* from the FortiPOC dashboard.



Go to *Endpoints* > *All Endpoints*. You should see your Windows 11 workstation. Click on it and note the Zero Trust Tags which have been preconfigured.

Commented [VR2]: Mention to skip the Forticloud registration:

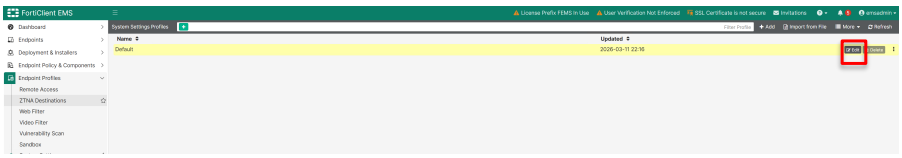




- **all_registered_clients** – this is a default tag
- **FortiPAM** – indicates that the FortiPAM FortiClient components have been installed. This is detected by checking for the presence of the video recording service executable at *C:\Program Files\Fortinet\FortiClient\fortivrs.exe*

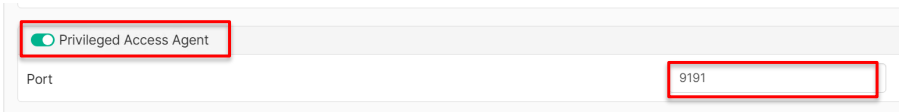
We will use these tags to restrict access within FortiPAM. We will now make sure that PAM is enabled on the EMS server.

- If not logged in as emsadmin please login as emsadmin into ems.
- Select Endpoint Profiles> system settings and highlight Default, select Edit



Select Advanced and scroll down to the bottom of the page

Make sure that the default port has been set 9191 and that Privileged Access Agent is enabled if not set it to the correct port and enable Privileged Access Agent.

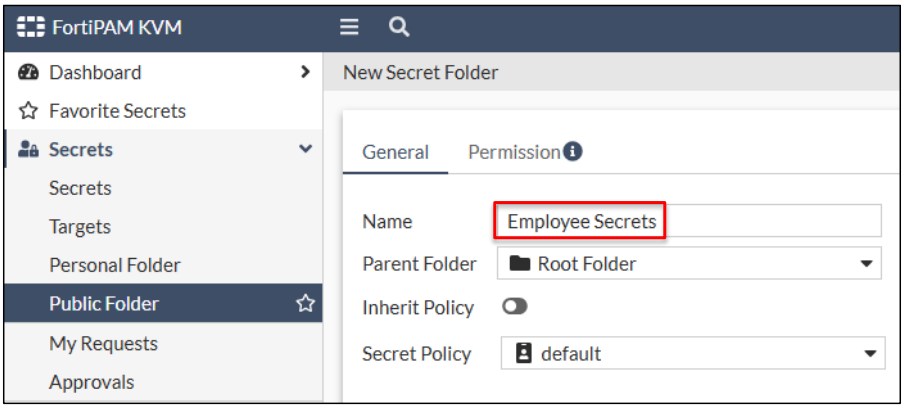


Save if any changes have been made.

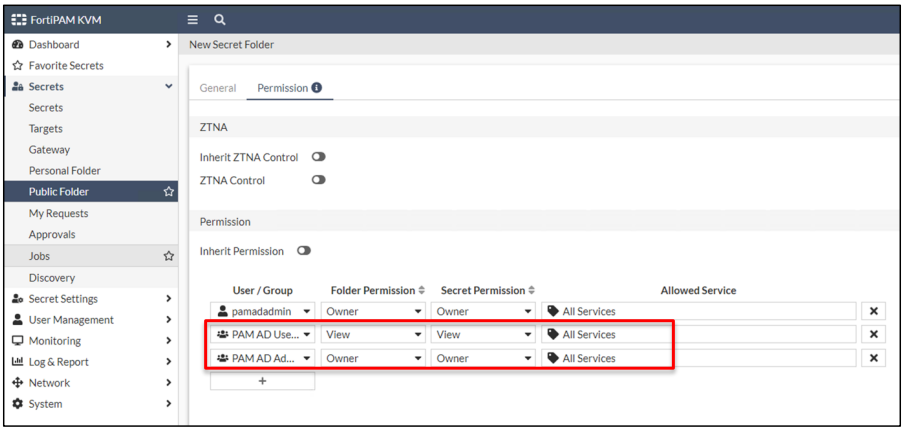
6.3 Setup Employee Folder and Secrets

6.3.1 Create Employee Folder

Login to FortiPAM GUI as ***pamadadmin*** and go to *Secrets* > *Public Folder*. Click *Create* > *Folder* and name the folder ***Employee Secrets***.

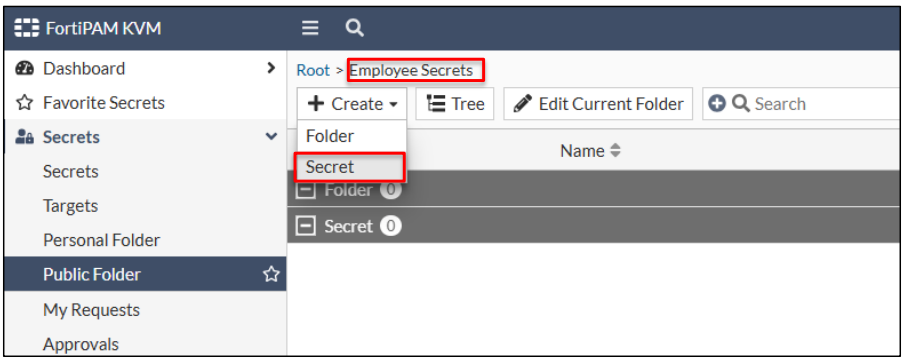


pamadadmin user is already Owner for both Folder and Secret. Give the ***PAM AD Users*** group View permissions for both Folder and Secret. Give the ***PAM AD Admins*** group Owner permissions for both Folder and Secret:



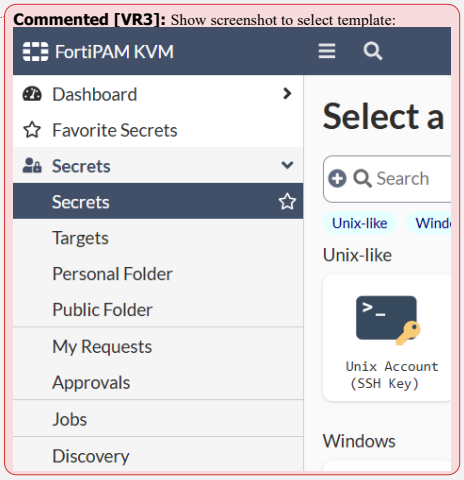
6.3.2 Create Employee Secrets

Go to *Secrets* > *Public Folder* > *Double click on Employee Secrets* and click *Create* > *Secret*.

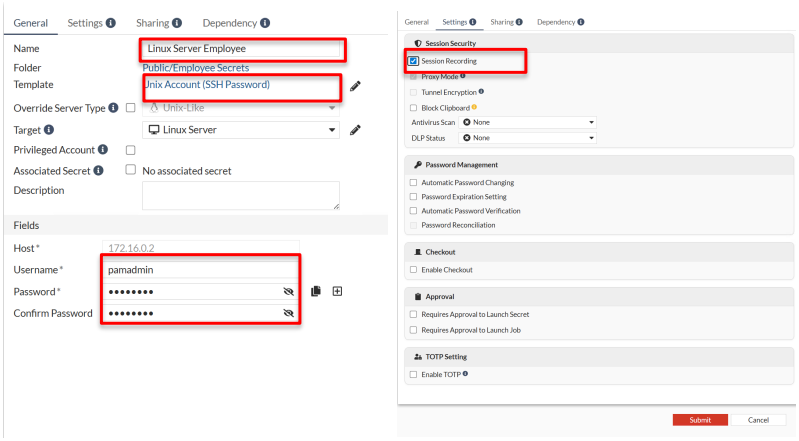


Use the following configuration:

Commented [VR3]: Show screenshot to select template:



- Name: ***Linux Server Employee***
- Target: **Linux Server**
- Template: **Unix Account (SSH Password)**
- Username: ***pamadmin***
- Password: ***F0rtiPAM***
- Enable Session Recording: ***Enable***

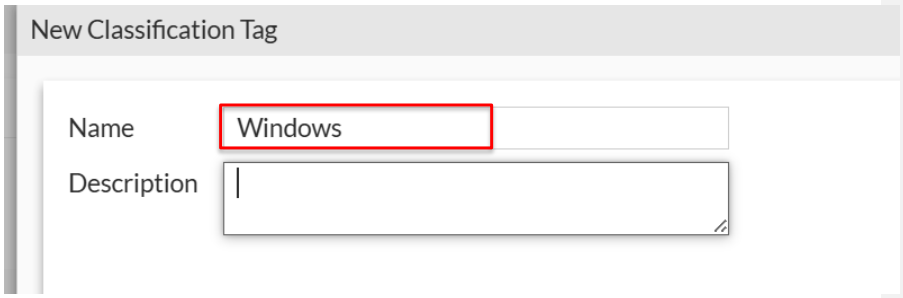


Submit the Secret.

Create a new target under Secrets > Targets for the Windows Server if not already present:

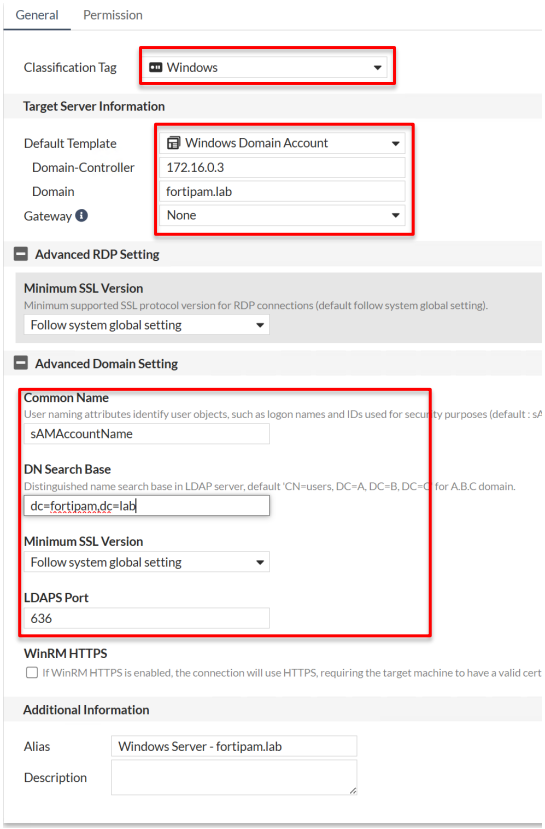
- Name: ***Windows Server***
- Classification Tag: ***Windows***
- Template: ***Windows Domain Account***
- Domain-Controller: ***172.16.0.3***
- Domain: ***fortipam.lab***

Create a new Classification Tag Windows



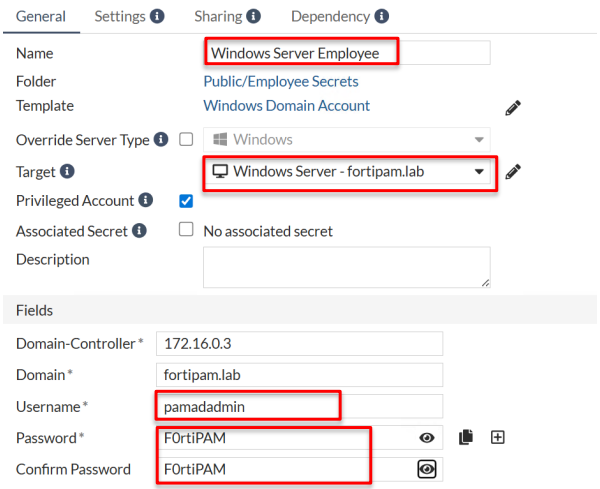
Advanced Setting

- Common Name: ***sAMAccountName*** *(default)*
- DN Search Base: ***dc=fortipam,dc=lab***



Create another secret in the Employee Secrets folder with the following configuration (should be already created):

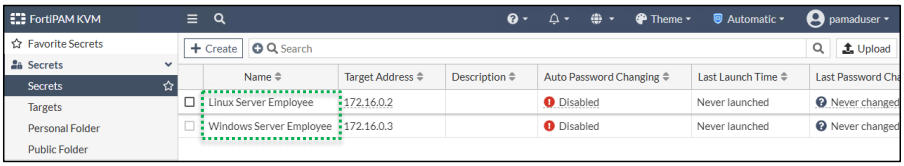
- Name: ***Windows Server Employee***
- Target: ***Windows Server – fortipam.lab***
- Privileged Account: ***Yes***
- Username: ***pamadadmin***
- Password: ***F0rtiPAM***
- Enable Session Recording: ***Enable***



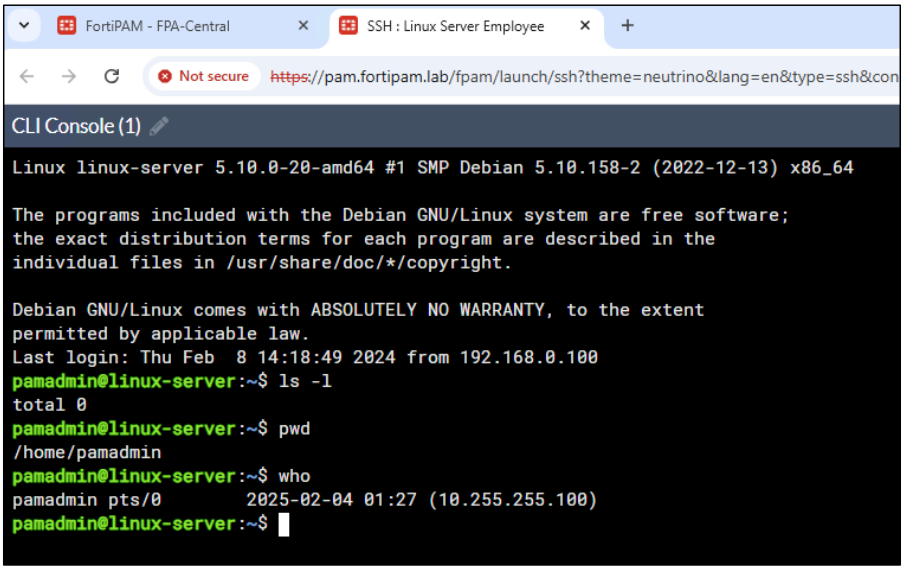
Submit the secret.

6.3.3 Test Employee Secrets

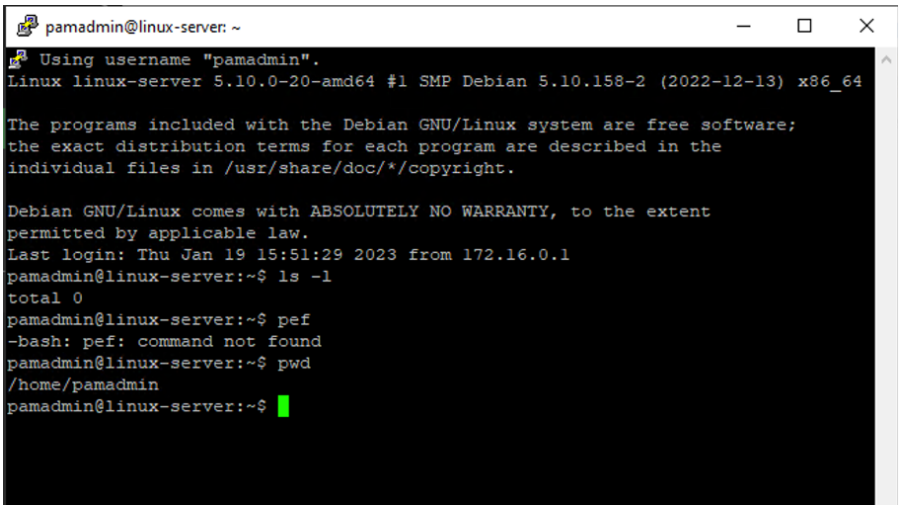
On the Windows workstation login to FortiPAM as ***pamaduser*** and go to *Secrets* > *Secret*. You will see the secrets you just created. Test each secret using both the Web launchers and the native applications.



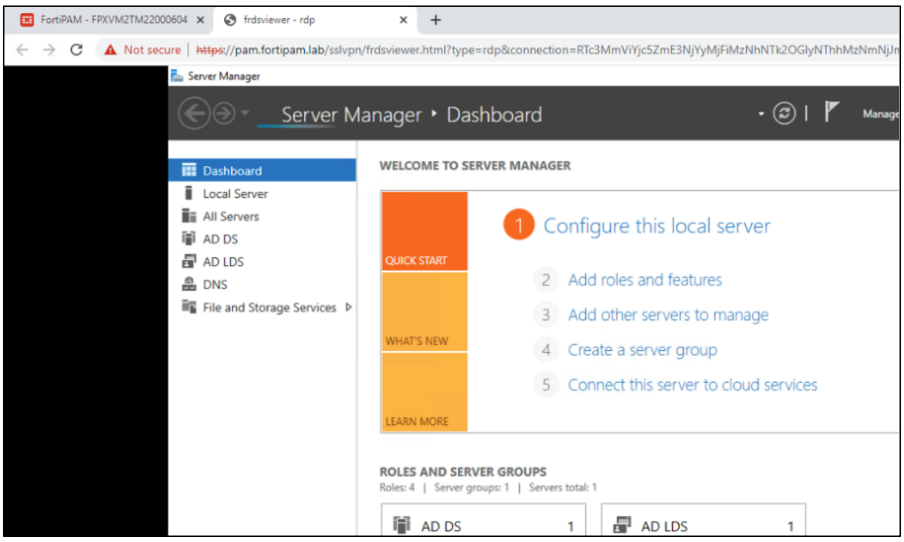
Linux Server – Web Launcher



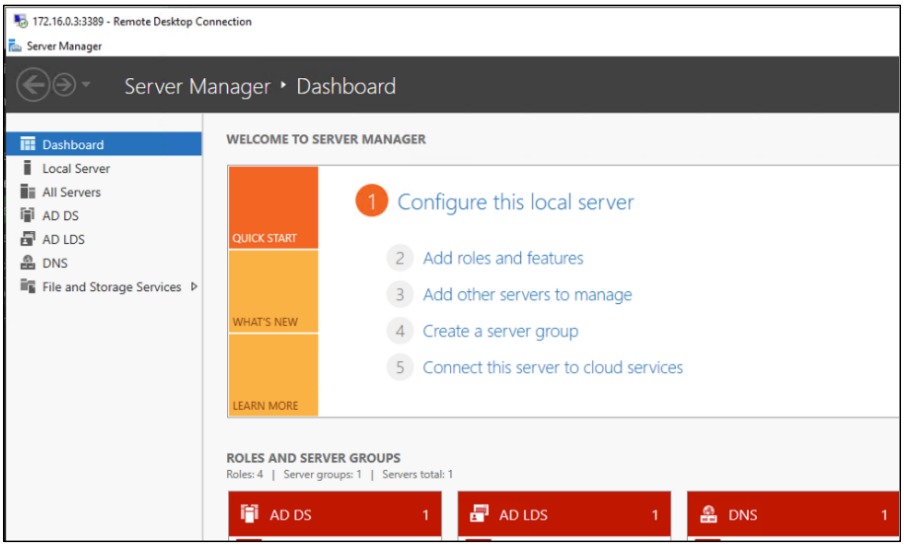
Linux Server – PuTTY



Windows Server WebRDP Launcher

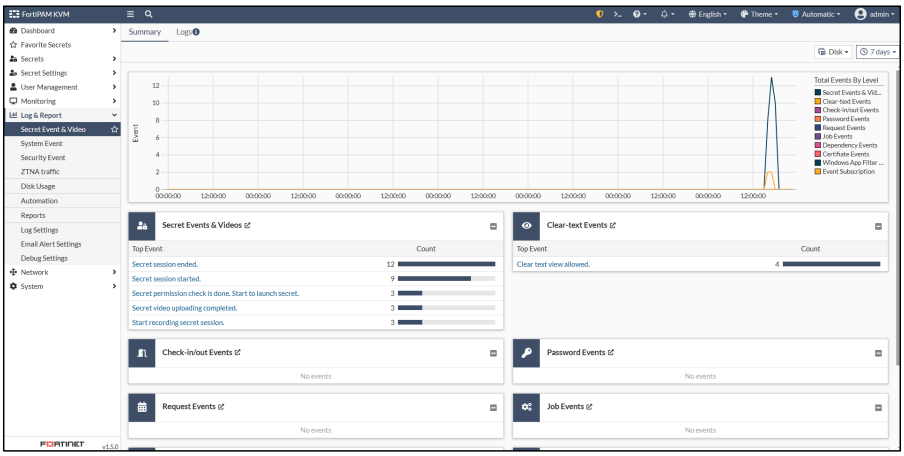


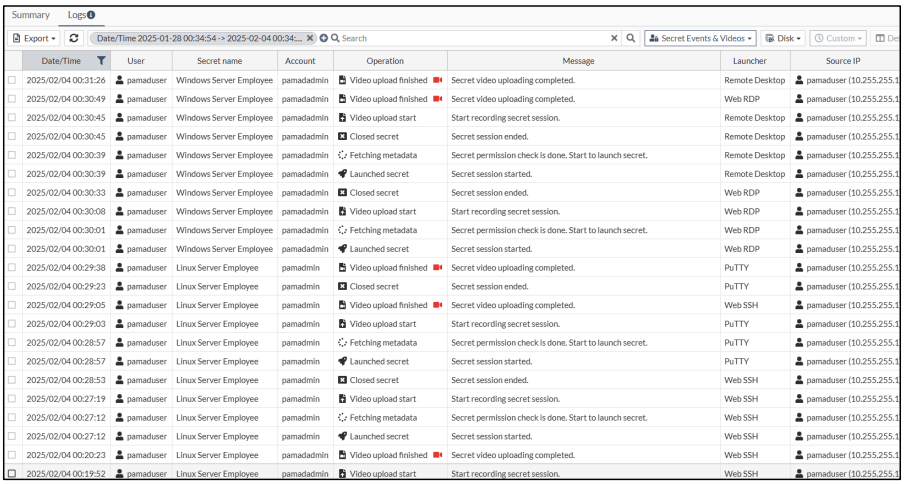
Windows Server Remote Desktop Client

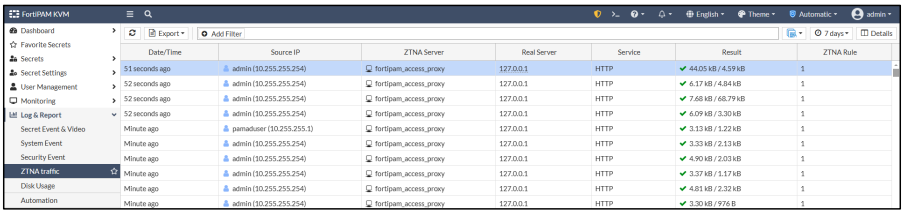


6.3.4 View the Logs

Login to FortiPAM GUI as ***admin***. Go to *Log & Report > Secret > Secret Event and Video* and view the logs. Also check the other available logs. View the video session recordings. Check the ZTNA logs.


FortiPAM KVM
Dashboard
Favorite Secrets
Secrets
Secret Settings
User Management
Monitoring
Log & Report
Secret Event & Video
System Event
Security Event
ZTNA traffic
Disk Usage
Automation
Reports
Log Settings
Email Alert Settings
Debug Settings
Network
System
Summary
Logs
Disk
7 days
Event
Total Events By Level
Secret Events & Vid...
Clear-text Events
Check-in/out Events
Password Events
Request Events
Job Events
Dependency Events
Certificate Events
Windows App Filtar ...
Event Subscription
Secret Events & Videos
Top Event
Count
Secret session ended. 12
Secret session started. 9
Secret permission check is done. Start to launch secret. 3
Secret video uploading completed. 3
Start recording secret session. 3
Clear-text Events
Top Event
Count
Clear text view allowed. 4
Check-in/out Events
No events
Password Events
No events
Request Events
No events
Job Events
No events


Summary
Logs
Export
Date/Time 2025-01-28 00:34:54 -> 2025-02-04 00:34:...
Search
Secret Events & Videos
Disk
Custom
Date/Time
User
Secret name
Account
Operation
Message
Launcher
Source IP
2025/02/04 00:31:26 pamaduser Windows Server Employee pamadadmin Video upload finished Secret video uploading completed. Remote Desktop pamaduser (10.255.255.1
2025/02/04 00:30:49 pamaduser Windows Server Employee pamadadmin Video upload finished Secret video uploading completed. Web RDP pamaduser (10.255.255.1
2025/02/04 00:30:45 pamaduser Windows Server Employee pamadadmin Video upload start Start recording secret session. Remote Desktop pamaduser (10.255.255.1
2025/02/04 00:30:45 pamaduser Windows Server Employee pamadadmin Closed secret Secret session ended. Remote Desktop pamaduser (10.255.255.1
2025/02/04 00:30:39 pamaduser Windows Server Employee pamadadmin Fetching metadata Secret permission check is done. Start to launch secret. Remote Desktop pamaduser (10.255.255.1
2025/02/04 00:30:39 pamaduser Windows Server Employee pamadadmin Launched secret Secret session started. Remote Desktop pamaduser (10.255.255.1
2025/02/04 00:30:33 pamaduser Windows Server Employee pamadadmin Closed secret Secret session ended. Web RDP pamaduser (10.255.255.1
2025/02/04 00:30:08 pamaduser Windows Server Employee pamadadmin Video upload start Start recording secret session. Web RDP pamaduser (10.255.255.1
2025/02/04 00:30:01 pamaduser Windows Server Employee pamadadmin Fetching metadata Secret permission check is done. Start to launch secret. Web RDP pamaduser (10.255.255.1
2025/02/04 00:30:01 pamaduser Windows Server Employee pamadadmin Launched secret Secret session started. Web RDP pamaduser (10.255.255.1
2025/02/04 00:29:38 pamaduser Linux Server Employee pamadmin Video upload finished Secret video uploading completed. PuTTY pamaduser (10.255.255.1
2025/02/04 00:29:23 pamaduser Linux Server Employee pamadmin Closed secret Secret session ended. PuTTY pamaduser (10.255.255.1
2025/02/04 00:29:05 pamaduser Linux Server Employee pamadmin Video upload finished Secret video uploading completed. Web SSH pamaduser (10.255.255.1
2025/02/04 00:29:03 pamaduser Linux Server Employee pamadmin Video upload start Start recording secret session. PuTTY pamaduser (10.255.255.1
2025/02/04 00:28:57 pamaduser Linux Server Employee pamadmin Fetching metadata Secret permission check is done. Start to launch secret. PuTTY pamaduser (10.255.255.1
2025/02/04 00:28:57 pamaduser Linux Server Employee pamadmin Launched secret Secret session started. PuTTY pamaduser (10.255.255.1
2025/02/04 00:28:53 pamaduser Linux Server Employee pamadmin Closed secret Secret session ended. Web SSH pamaduser (10.255.255.1
2025/02/04 00:27:19 pamaduser Linux Server Employee pamadmin Video upload start Start recording secret session. Web SSH pamaduser (10.255.255.1
2025/02/04 00:27:12 pamaduser Linux Server Employee pamadmin Fetching metadata Secret permission check is done. Start to launch secret. Web SSH pamaduser (10.255.255.1
2025/02/04 00:27:12 pamaduser Linux Server Employee pamadmin Launched secret Secret session started. Web SSH pamaduser (10.255.255.1
2025/02/04 00:20:23 pamaduser Linux Server Employee pamadadmin Video upload finished Secret video uploading completed. Web SSH pamaduser (10.255.255.1
2025/02/04 00:19:52 pamaduser Linux Server Employee pamadadmin Video upload start Start recording secret session. Web SSH pamaduser (10.255.255.1


FortiPAM KVM
Dashboard
Favorite Secrets
Secrets
Secret Settings
User Management
Monitoring
Log & Report
Secret Event & Video
System Event
Security Event
ZTNA traffic
Disk Usage
Automation
Export
Add Filter
7 days
Details
Date/Time
Source IP
ZTNA Server
Real Server
Service
Result
ZTNA Rule
51 seconds ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 44.05 kB / 4.59 kB 1
52 seconds ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 6.17 kB / 4.84 kB 1
52 seconds ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 7.68 kB / 68.79 kB 1
52 seconds ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 6.09 kB / 3.30 kB 1
Minute ago pamaduser (10.255.255.1) fortipam_access_proxy 127.0.0.1 HTTP 3.13 kB / 1.22 kB 1
Minute ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 3.33 kB / 2.13 kB 1
Minute ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 4.90 kB / 2.03 kB 1
Minute ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 3.37 kB / 1.17 kB 1
Minute ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 4.81 kB / 2.32 kB 1
Minute ago admin (10.255.255.254) fortipam_access_proxy 127.0.0.1 HTTP 3.30 kB / 976 B 1

7 Enable ZTNA Security Features

7.1 Fortinet Zero Trust Network Access: An Architectural Overview

Zero Trust Network Access (ZTNA) represents a shift in how connectivity is provisioned. Instead of placing users on the corporate network to grant them access to applications, ZTNA creates a direct, encrypted connection between the user and the specific application they are authorized to use. The core principle is consistent: "never trust, always verify." Every access attempt is treated as a potential threat until the user's identity and device posture are validated against policy.

Within the Fortinet ecosystem, ZTNA is not a standalone product, but a capability embedded within the FortiOS operating system, leveraging the broader Security Fabric. This document outlines the components and configuration model for deploying Fortinet ZTNA, including how FortiPAM integrates to secure privileged access.

7.1.1 Core Architectural Components

A Fortinet ZTNA deployment relies on several key components working in concert:

- **FortiGate (Policy Enforcement Point):** The FortiGate acts as the ZTNA gateway. It terminates user connections, verifies identity and device posture with the EMS, and proxies traffic to the internal application. Policies are defined on the FortiGate to control access based on user groups and EMS tags.
- **FortiClient (Endpoint Client):** Installed on user endpoints, FortiClient provides telemetry on the device's security posture. It checks for compliance factors like running antivirus, OS patches, and disk encryption. This information is relayed to the EMS.
- **FortiClient EMS (Coordination & Tagging):** EMS aggregates posture information from all FortiClient endpoints. Based on administrator-defined rules, EMS dynamically assigns "ZTNA tags" to devices (e.g., Compliant_Windows, High_Risk_Device). These tags are shared with the FortiGate and FortiPAM to inform access decisions.
- **FortiPAM (Privileged Access Management):** For managing access to high-value targets like network infrastructure (firewalls, switches) or critical servers, FortiPAM acts as a secure jump host. It integrates with the ZTNA framework to ensure that even administrators must pass device posture checks before accessing privileged credentials or initiating a session.

7.1.2 The Role of FortiPAM in ZTNA Architecture

Standard ZTNA workflows are effective for granting application access to general users. However, administrative access to infrastructure requires additional controls. This is where FortiPAM is integrated into the architecture.

FortiPAM serves as a controlled gateway to sensitive targets. When an administrator needs to access a router or a critical server, they do not connect directly. Instead:

1. **ZTNA-Protected Access to FortiPAM:** The administrator's access to the FortiPAM web interface or client is itself protected by ZTNA policies on the FortiGate. The administrator must authenticate and their device must present the correct ZTNA tags (e.g., Admin_Device) to even reach the FortiPAM login page
2. **Just-in-Time Privileged Access:** Once inside FortiPAM, the administrator requests access to a specific target, such as a core switch. FortiPAM can enforce additional approval workflows and check out a privileged account credential (which may be automatically rotated after use).
3. **Session Isolation and Monitoring:** FortiPAM initiates the connection to the target device. The administrator never receives the direct password or IP address of the target. Instead, they interact with the target through a monitored, recorded session hosted by FortiPAM. This provides a complete audit trail for compliance.

7.1.3 Deployment Models

Fortinet ZTNA can be deployed in two primary modes:

1. **Agentless ZTNA:** This model allows users to access web-based applications from unmanaged devices (e.g., personal laptops) through a standard browser. The FortiGate presents a web portal where the user authenticates. Access is typically more restrictive, based on IP address and time-of-day policies rather than deep endpoint posture checks.
2. **Agent-Based ZTNA:** This model requires FortiClient on the endpoint. It is used for both HTTP/HTTPS applications and TCP-based applications (like RDP or SSH). For TCP applications, FortiClient uses a "ZTNA Destination" tunnel to encapsulate traffic and forward it to the FortiGate proxy. This model provides the highest level of endpoint visibility and control.

By combining these components, organizations can build a layered defence where access to standard applications and critical infrastructure is uniformly verified, logged, and controlled.

In the Agent Based ZTNA scenario all access requires client certificate authentication and ZTNA tags to access FortiPAM. Client certificate authentication is supported by registering the FortiClient with EMS and connecting FortiPAM with EMS. EMS will provision a certificate on the FortiClient endpoint when the endpoint registers with EMS. Connecting FortiPAM to EMS configures FortiPAM to trust the EMS CA. Once this trust relationship has been established, FortiPAM can request client certificate authentication and authorize any FortiClient that has registered with EMS.

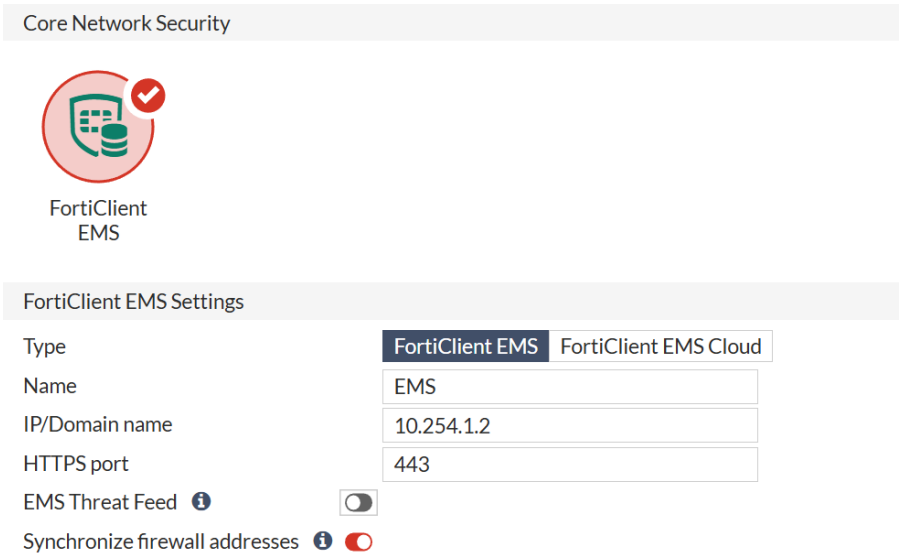
ZTNA Rules & Tags can be created on EMS, and the ZTNA tags associated with FortiClient endpoints connecting to FortiPAM can be validated with EMS via API. FortiPAM can then use these ZTNA Tags in ZTNA Rules and Secrets to allow or block access based on the presence or absence of those tags.

7.2 Connect FortiPAM to EMS

Login to *FPA-Central* GUI as ***SuperAdmin*** . Go to *Network* > *Fabric Connectors* and double click on the connector for *FortiClient EMS*. Configure the connector as follows:

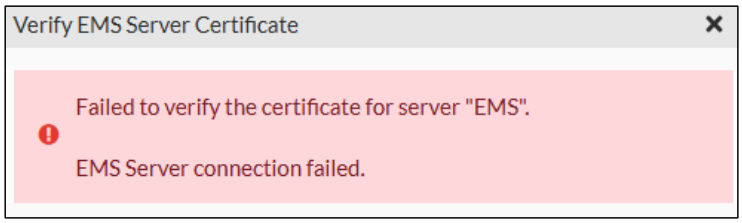
- Name: ***EMS***
- IP/Domain Name: 10.254.1.2

- EMS Threat Feed: ***Disabled***
- Synchronize firewall addresses: ***Enabled***

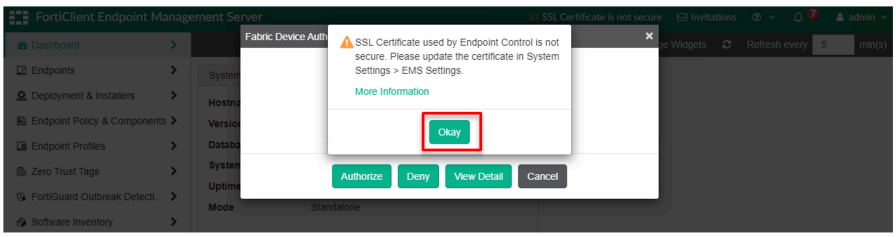


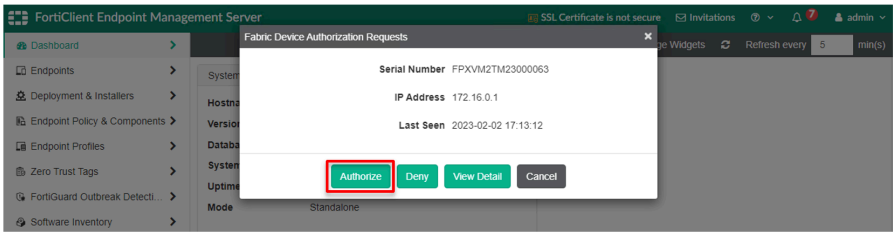
Click OK to save.

You may receive an error that FortiPAM has failed to verify the certificate for EMS.

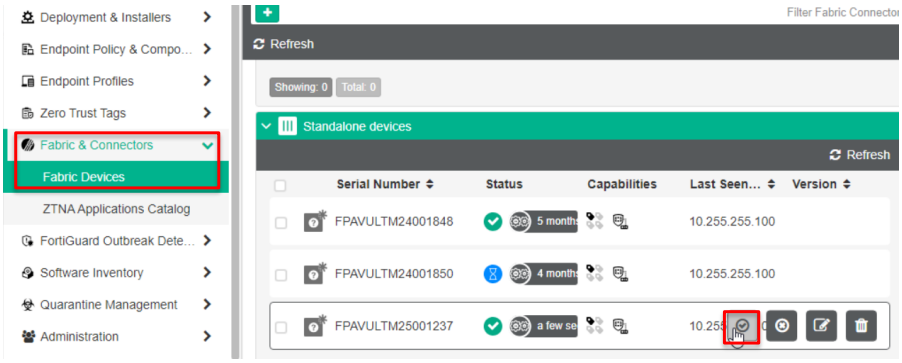


Login to EMS and Click Authorize (login with emsadmin/F0rtiPAM)

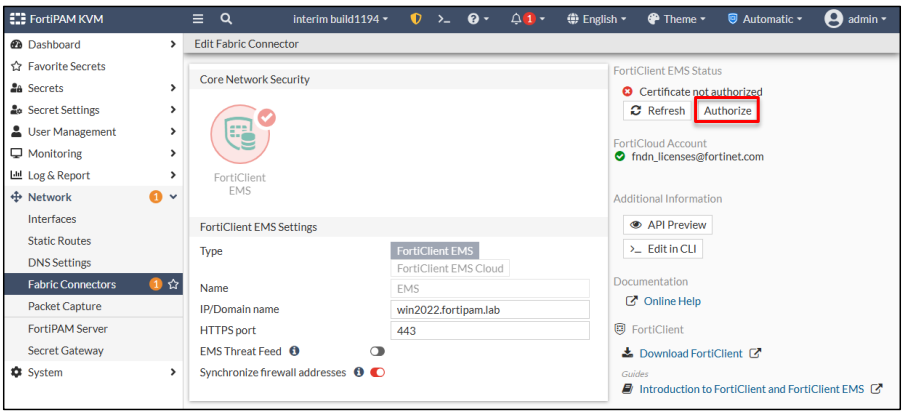




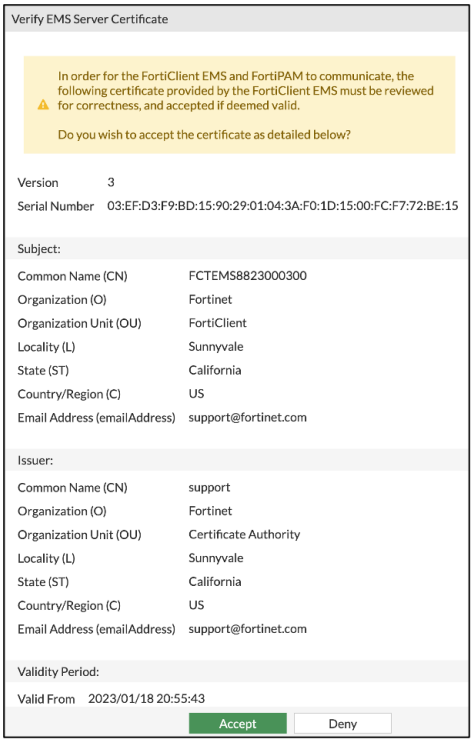
If you don’t see the above prompts go to the EMS Fabric & Connectors > Fabric devices menu. Find your FortiPAM and manually authorize it:



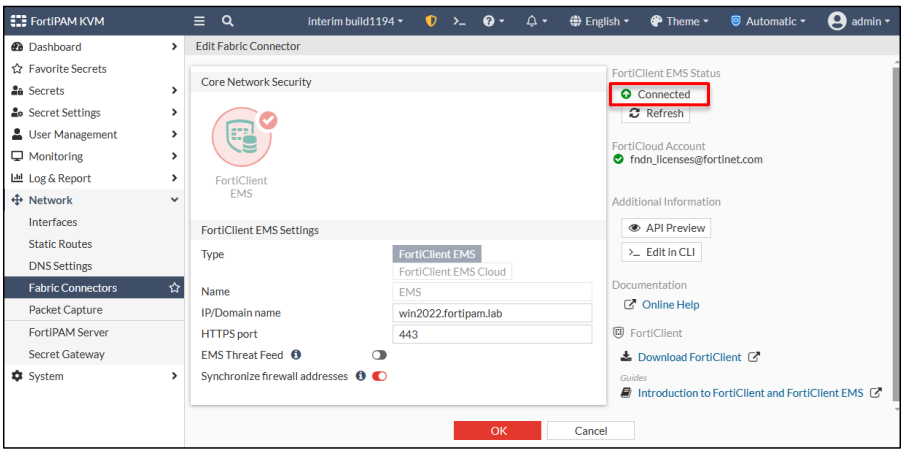
Return to FortiPAM and edit the EMS connector under *Network* > *Fabric Connectors*. If the FortiClient EMS Status shows Certificate not authorized, Click the Authorize button.



You will be prompted to verify the EMS certificate, check the certificate and then Accept it.



FortiClient EMS Status will now show Connected.



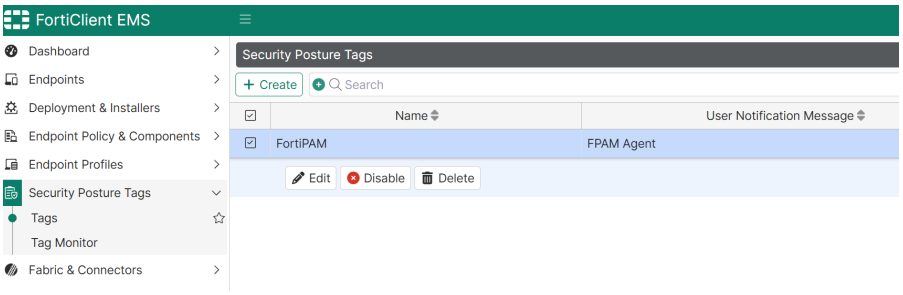
7.3 Configure Client Certificate Authentication and ZTNA Tags

Now you will create a new Access Proxy and Proxy Rule for Employee access and enable Client Certificate Authentication and ZTNA Tags on the Rule for the employee Access Proxy. Client Certificate Authentication will require the endpoint to provide its FortiClient certificate to FortiPAM before the login page is displayed. Then, ZTNA Tags will be checked during the login to verify that the FortiClient is permitted by the ZTNA Rule.

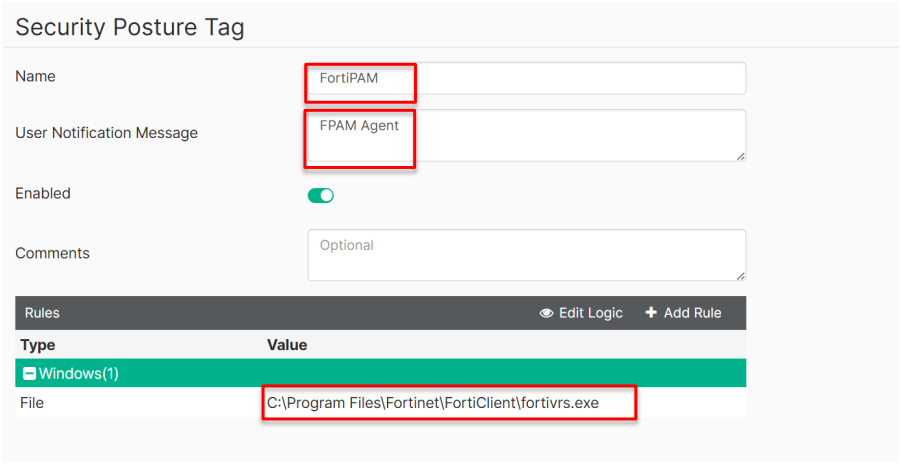
Why would you want to enable both client certificate authentication and ZTNA Tag verification to login to FortiPAM? The answer is that client certificate authentication on its own would allow any FortiClient to connect – in this use case we only want to allow FortiClients that have the FortiPAM components installed to be able to login.

7.3.1 Review EMS ZTNA Tags

Login to EMS and go to *Security Posture Tags* > *Tags* Select the FortiPAM rule and click Edit:



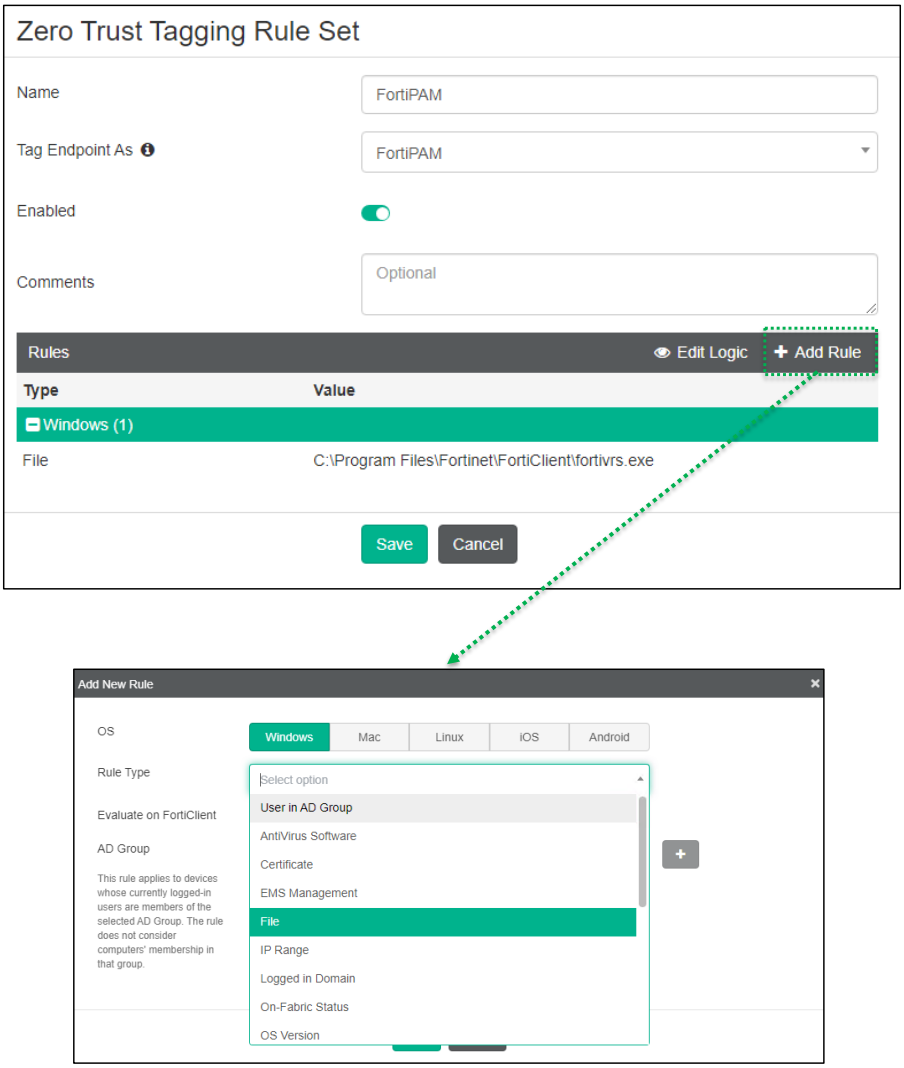
This rule checks for the presence of *fortivrs.exe*, which is the executable used by FortiClient to do session video recording for FortiPAM. This is the ZTNA Tag you will configure on the new Proxy Rule you will create for Employee access.



Note that in this example we are using a tag which checks that a specific file is available on the endpoint but the catalog of tags which can be used renders ZTNA extremely powerful. Examples of available tags:

- Antivirus software
- Running process
- OS Version
- IP Range
- etc…

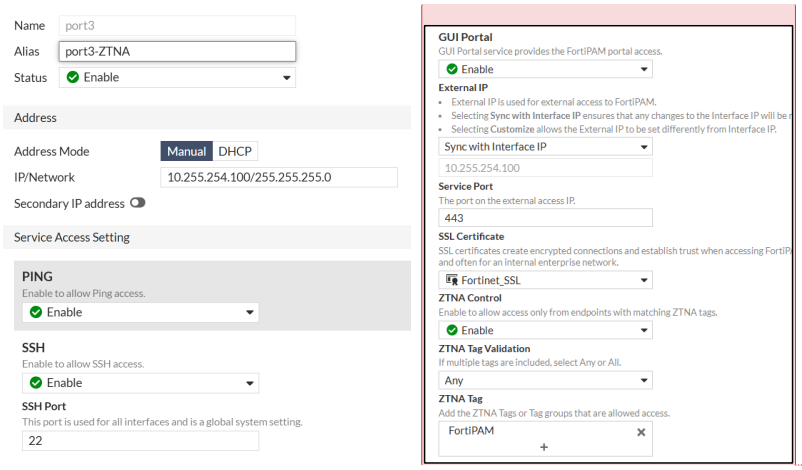
You can check all available options by selecting “Add Rule” option in above menu (**don’t make any changes or you will break the following labs**):



7.3.2 Configure Second Interface for ZTNA Access

Login to FortiPAM GUI as ***admin*** and go to *Network > Interfaces*. Edit *port3*. Enable *GUI Portal* and *ZTNA Control* and select *FortiPAM* in *ZTNA Tag*. Leave the *External IP* option as the default *Sync with Interface IP*.

Commented [VR4]: It is already enabled



Commented [VR5]: Red boxes around ZTNA tag - the rest is lareasdy provisioned but not the specific tag

The correct Firewall Policy for this lab is as follows (FYI):

Commented [VR6]: Is it already provisioned ?

```
config firewall policy
    edit 2001
        set type access-proxy
        set name "fortipam_vip_gwy_pol"
        set uuid 83bba216-e46e-51ef-e2e0-73613dbc81de
        set srcintf "any"
        set srcaddr "fortipam_vip_gwy_addr"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set access-proxy "fortipam_access_proxy"
        set ssl-ssh-profile "deep-inspection"
    next
    edit 1
        set type access-proxy
        set uuid 0f544c3a-e46d-51ef-7d12-1f7b3723e795
        set srcintf "any"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set access-proxy "fortipam_access_proxy"
        set groups "SSO_Guest_Users"
        set ssl-ssh-profile "deep-inspection"
    next
    edit 1002
        set type explicit-web
        set uuid 0f54f0f4-e46d-51ef-7407-b6a9bebf7afc
        set dstintf "any"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set service "web-connect"
        set explicit-web-proxy "web-proxy"
        set ssl-ssh-profile "deep-inspection"
    next
    edit 1001
        set type explicit-web
        set uuid 0f5495e6-e46d-51ef-4a0e-afb68a3095bd
        set dstintf "any"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set service "webproxy"
        set explicit-web-proxy "web-proxy"
        set groups "SSO_Guest_Users"
        set ssl-ssh-profile "deep-inspection"
    next
    edit 5
        set type access-proxy
        set name "port2_auto_create_policy"
        set uuid 359659e0-e48d-51ef-f716-30fe9f4f241b
        set srcintf "port2"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set access-proxy "port2_auto_create_access_proxy"
        set ztna-ems-tag "FCTEMS8825000957_FortiPAM"
        set groups "SSO_Guest_Users"
        set ssl-ssh-profile "deep-inspection"
    next
end
```

Don’t copy & paste ztna-ema-tag.
Please configure your tag information.

The correct Firewall vip for this lab is as follows:

Commented [VR7]: FYI (already provisioned)

```
FPA-Central # show firewall vip
config firewall vip
    edit "fortipam_vip"
        set uuid fe7af330-1aa1-51f0-5478-d604f6fb036a
        set type access-proxy
        set extip 10.254.1.100
        set extintf "port1"
        set server-type https
        set extport 443
        set ssl-certificate "Fortinet_SSL"
    next
    edit "port2_auto_create_vip"
        set uuid e94dab52-1b2c-51f0-cbc2-8b159ad21a79
        set type access-proxy
        set extip 10.255.255.100
        set extintf "port2"
        set server-type https
        set extport 443
        set ssl-certificate "Fortinet_SSL"
    next
    edit "port3_auto_create_vip"
        set uuid 64777a88-1b2d-51f0-6793-19f10aaa9c73
        set type access-proxy
        set extip 10.255.254.100
        set extintf "port3"
        set server-type https
        set extport 443
        set ssl-certificate "Fortinet_SSL"
    next
end
```

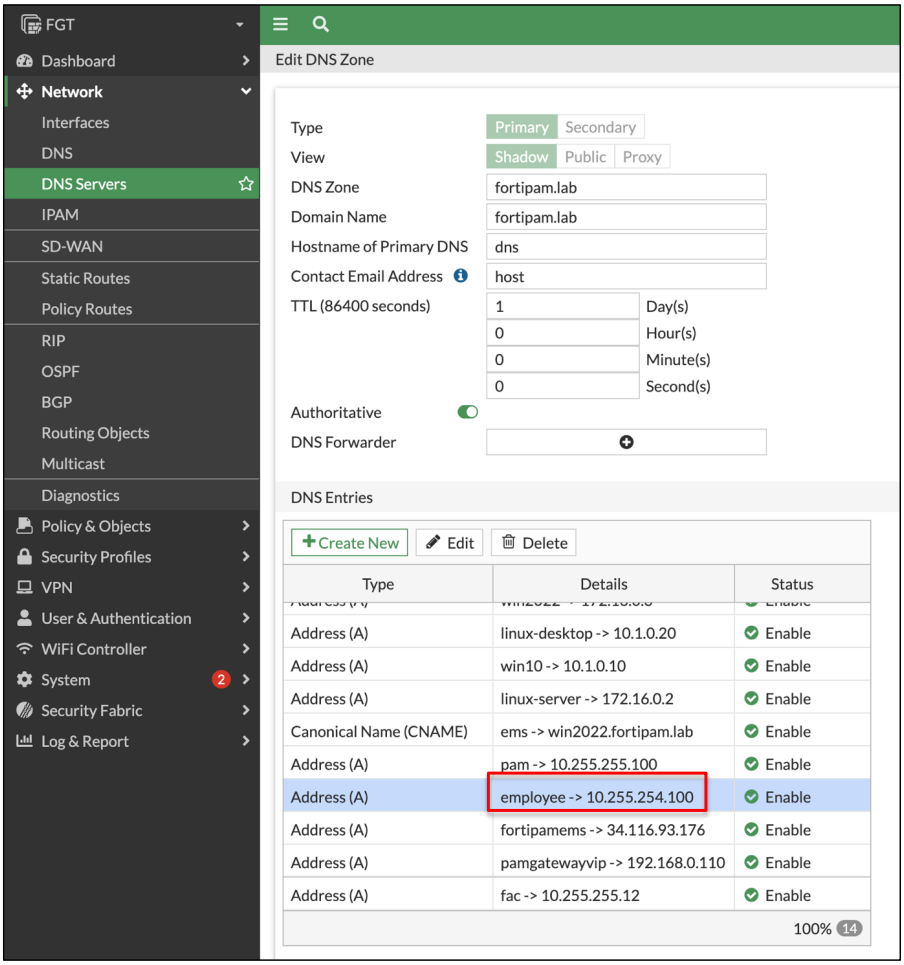
The correct Firewall access-proxy for this lab is as follows

Commented [VR8]: Should we configure it ?

```
            edit 1
                set url-map "/pam"
                set service pam-service
            next
            edit 2
                set url-map "/tcp"
                set service tcp-forwarding
                config realservers
                    edit 1
                        set address "all"
                    next
                end
            next
            edit 3
                set service gui
                config realservers
                    edit 1
                        set ip 127.0.0.1
                        set port 80
                    next
                end
            next
        end
    next
    edit "port3_auto_create_access_proxy"
        set vip "port3_auto_create_vip"
        set client-cert enable
        config api-gateway
            edit 1
                set url-map "/pam"
                set service pam-service
            next
            edit 2
                set url-map "/tcp"
                set service tcp-forwarding
                config realservers
                    edit 1
                        set address "all"
                    next
                end
            next
            edit 3
                set service gui
                config realservers
                    edit 1
                        set ip 127.0.0.1
                        set port 80
                    next
                end
            next
        end
    next
end
```

Login to the FortiGate. Go to *Network* > *DNS Servers* and edit the *fortipam.lab* DNS Zone. Configure the *employee* entry to with the IP address: ***10.255.254.100 (already done)***

Commented [VR9]: Already done - remove ?



7.3.3 Test Employee Access

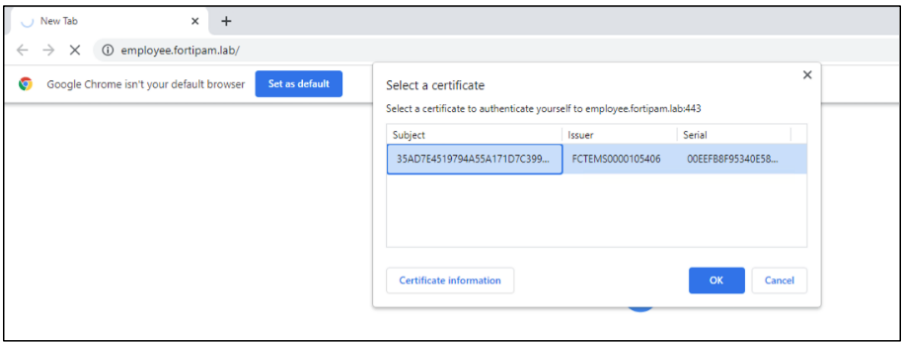
Open an SSH CLI session to FortiPAM from the FortiPOC Access button. Enable the following debugs:

Commented [VR10]: FS

```
diag debug application fcnacd -1
diag wad debug enable category secret
diag debug enable
```

Test login to FortiPAM from the Windows client by going to *https://employee.fortipam.lab*.

You will be prompted to select a client certificate. The default certificate will be the ZTNA certificate that was provisioned to the FortiClient on that workstation. Click Ok to use it. In a production environment it's possible that the customer may have multiple certificates provisioned on the endpoint (for services other than FCT/ZTNA/etc). If so, they would need to make sure they select the correct certificate to authenticate to FortiPAM.



It may take some time before you are prompted to login. If you initially receive a ZTNA error, refresh the page. Login as *pamaduser* and verify you can use the secrets that were defined in previous tasks.

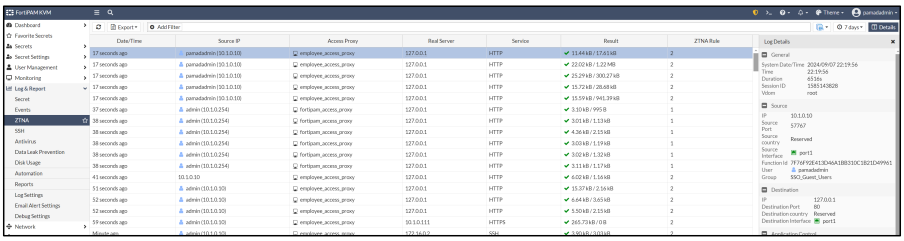
Check the debugs in the FortiPAM SSH session.

```
[ec_ems_context_submit_work:410] Call submitted successfully.
    obj-id: 12, desc: REST API to get updates of tags associated with FCT UID., entry: api/v1/report/fct/uid_tags.

[ec_ez_worker_process:335] Processing call for obj-id: 12, entry: "api/v1/report/fct/uid_tags"
[ec_record_sync_tags_info_store:1401] Received 3 tags for 7F76F92E413D46A1BB310C1B21D49961 with sn FCTEMS8823000300
[ec_ez_worker_process:435] Call completed successfully.
    obj-id: 12, desc: "REST API to get updates of tags associated with FCT UID.", entry: "api/v1/report/fct/uid_tags".

[ec_ems_context_submit_work:410] Call submitted successfully.
    obj-id: 16, desc: REST API to get ZTNA certificate., entry: api/v1/ztna_certificates/download.

[ec_ez_worker_process:335] Processing call for obj-id: 16, entry: "api/v1/ztna_certificates/download"
[_ztna_cert_process_result:147] Received previously received ZTNA certificate.
[ec_ez_worker_process:435] Call completed successfully.
    obj-id: 16, desc: "REST API to get ZTNA certificate.", entry: "api/v1/ztna_certificates/download".
```

Note that the *fcnacd* debug will not show that actual tag names, only the number of tags it has received from EMS for the specific FCT UID.

Login to https://employee.fortipam.lab on your Windows workstation as *superadmin* and go to *Log & Report* > *ZTNA* and check the ZTNA logs for *pamaduser*

Scroll down to the Other section of the log message to see the tags associated with the endpoint



Log Details

General

System Date/Time	2024/09/07 22:19:56
Time	22:19:56
Duration	6516s
Session ID	1585143828
Vdom	root

Source

IP	10.1.0.10
Source Port	57767
Source country	Reserved
Source Interface	port1
Function Id	7F76F92E413D46A1BB310C1B21D49961
User	pamadadmin
Group	SSO_Guest_Users

Destination

IP	127.0.0.1
Destination Port	80
Destination country	Reserved
Destination Interface	port1

Application Control

Category	unscanned
Protocol	6
Service	HTTP

Data

Received Bytes	18 kB
Sent Bytes	11 kB
LAN In	11 kB
LAN Out	20 kB
WAN In	18 kB
WAN Out	8 kB

Action

Action	Accept
ZTNA Rule	2
Policy UUID	1b7e9a9c-6d12-51ef-c003-65ced9979d83
Policy type	Proxy

Security

Level

Cellular

Service HTTP

Other

Event Time	1725711596755260200
Timezone	-0700
Log ID	0005000024

7.3.4 Enabling ZTNA Tags on Secret Permissions

This feature allows a secret to be launched only if certain ZTNA Tags are present for the endpoint. This allows more granular access control to secrets than requiring a ZTNA Tag to login to FortiPAM. You could create a ZTNA Tag that identifies admin computers which may have more stringent security controls on them and only allow certain secrets to be launched from those workstations based on the presence of that ZTNA Tag. In this example we will create a secret to login to an SSH session on the FortiGate and make it available only to workstations that have the *FTNT-Admin* ZTNA Tag.

One of the primary operational advantages of ZTNA is its dynamic policy enforcement: changes in the endpoint's environmental state are detected in real-time and trigger an immediate reassessment of access privileges. This creates a closed-loop control system where trust is continuously verified, not just checked at login.

Within the Fortinet architecture, this capability is extended to privileged access management through the integration of FortiPAM with FortiClient EMS. Access to secrets and privileged credentials is explicitly tied to the presence of specific ZTNA tags on the requesting device. These tags are not static; they reflect the real-time posture of the endpoint.

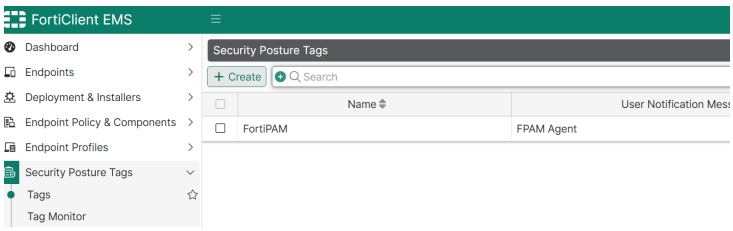
Consider a common use case: an access policy requires that a user's device must be connected to the corporate wired network to retrieve a database credential from FortiPAM. Initially, the device is connected via Ethernet, and EMS has assigned the corresponding Network_Wired tag. The user is granted access to the secret.

The user then unplugs the Ethernet cable and connects to the corporate Wi-Fi. This event is detected by FortiClient, which forwards the telemetry to EMS. EMS immediately recalculates the device's posture. Upon detecting the network change, EMS removes the Network_Wired tag from the device entry and may assign a new tag, such as Network_Wireless.

This tag change is pushed to the FortiPAM in near real-time. Because the FortiPAM policies controlling access to the FortiPAM secrets are tied to the presence of the Network_Wired tag, the user's session is terminated or their access to the secret is revoked. The privilege to view the credential is dynamically removed the moment the environment falls out of compliance, enforcing Zero Trust principles even during an active session.

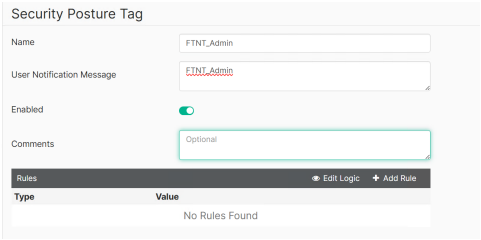
7.3.5 Create a TAG in EMS Server

We're going to create a tag in EMS to identify Fortinet Device Administrators. **This is just an example**—in production, tag assignment should be based on something more robust, like Active Directory group membership. The goal here is to show the versatility of the tag system without turning this into an EMS training session. Login into EMS as ***emsadmin, goto Security Posture Tags> Tags. Click on Create.***



Use the Following settings:

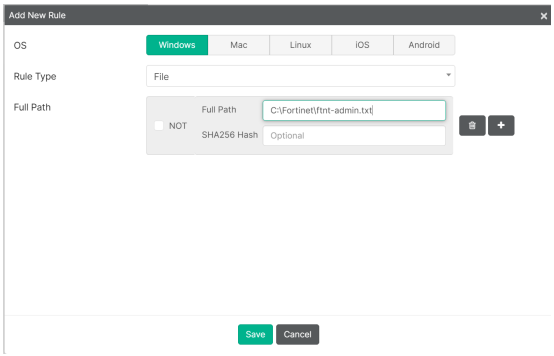
Name: FTNT_Admin
User Notification Message: FTNT_Admin
Enabled: Ticked



Press Add New Rule:

Rule Type: File
Full Path: C:\Fortinet\ftnt-admin.txt

Press Save twice

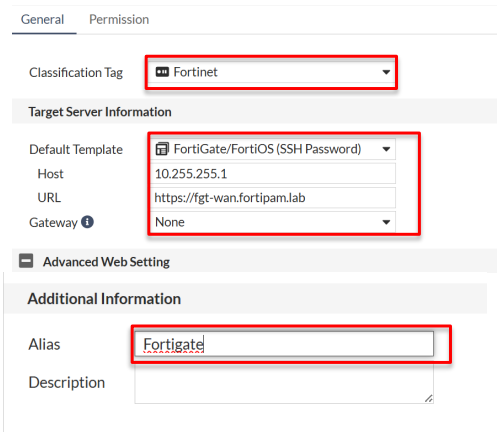


You should have created now a new Security Posture Tag FTNT_Admin

7.3.6 Create Target/Secret for FortiGate

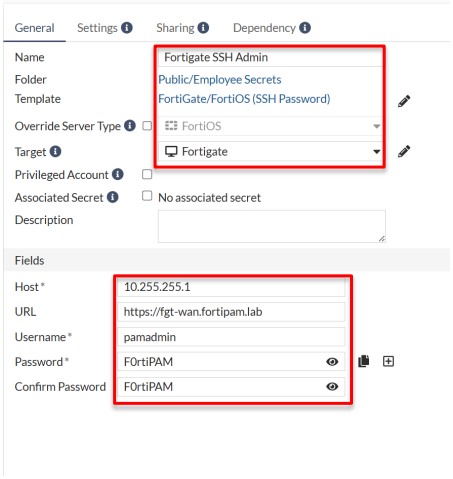
Login to FortiPAM GUI as ***pamadadmin*** . First let's create a Target for the FortiGate. Go to *Secrets* > *Target* and click *Create*

Classification Tag: ***Fortinet (create a new classification)***
Template: ***FortiGate/FortiOS (SSH Password)***
Host: ***10.255.255.1***
URL: ***https://fgt-wan.fortipam.lab***
Alias: Fortigate

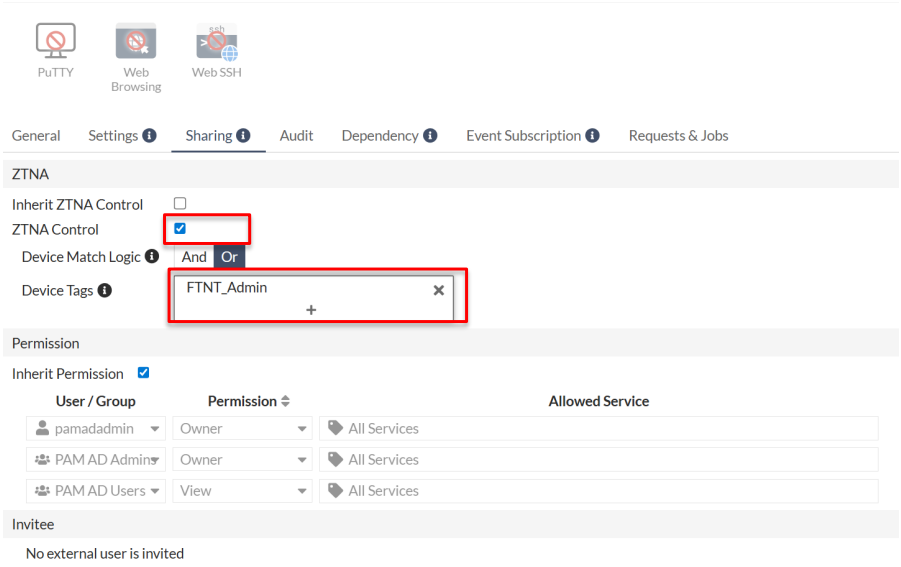


Then go to *Secrets* > *Secrets* and click *Create*. Select the *Employee Secrets* folder and enter the following:

- Name: ***FortiGate SSH Admin***
- Target: ***FortiGate***
- Username: ***pamadmin***
- Password: ***F0rtiPAM***



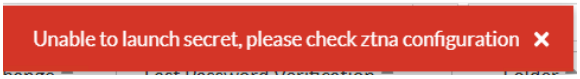
Click the *Sharing* tab. Enable *ZTNA Control* and select the *FTNT-Admin* ZTNA Tag.



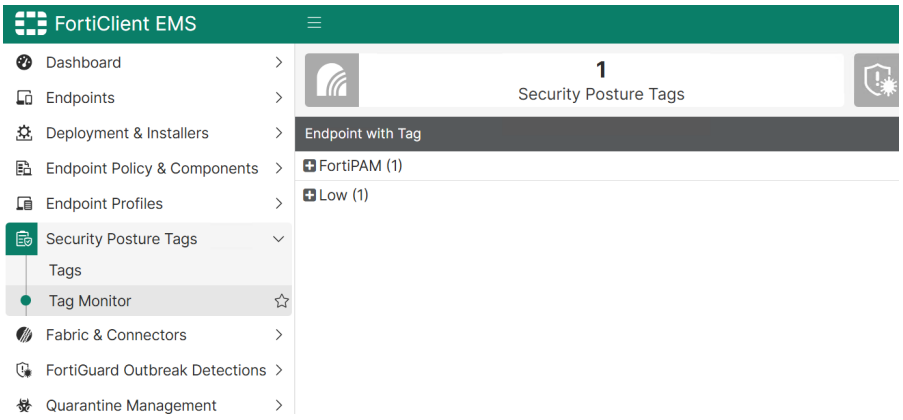
Click *Submit* to save changes.

7.3.7 Test FortiGate Secret

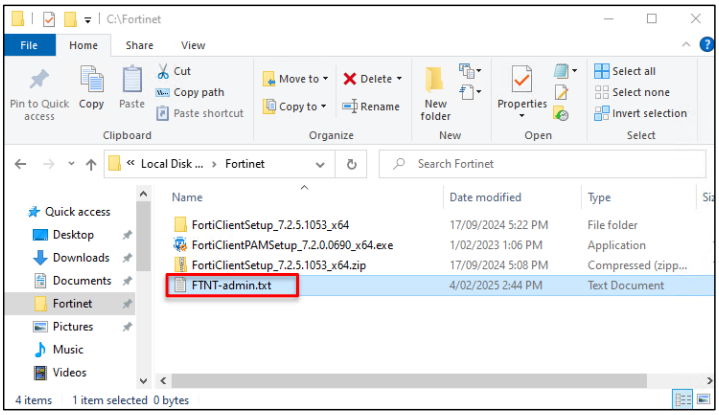
Login to *https://employee.fortipam.lab* on the Windows Workstation as ***pamaduser***. Try and launch the secret you just created using the WebSSH launcher. Did it launch? Why not?



Login to EMS as *admin* and go to **Security Posture Tags > Tag Monitor.**

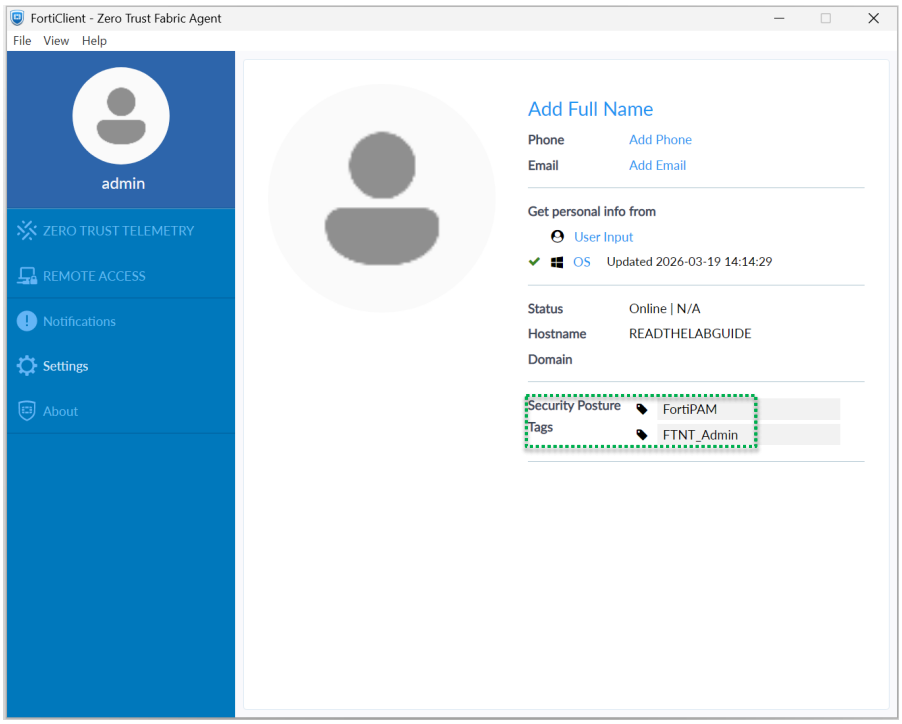


There are no endpoints with the *FTNT-Admin* tag. The *FTNT-Admin* tag is checking for the presence of a file named ***C:\Fortinet\FTNT-Admin.txt***. Create this file on the Windows workstation.

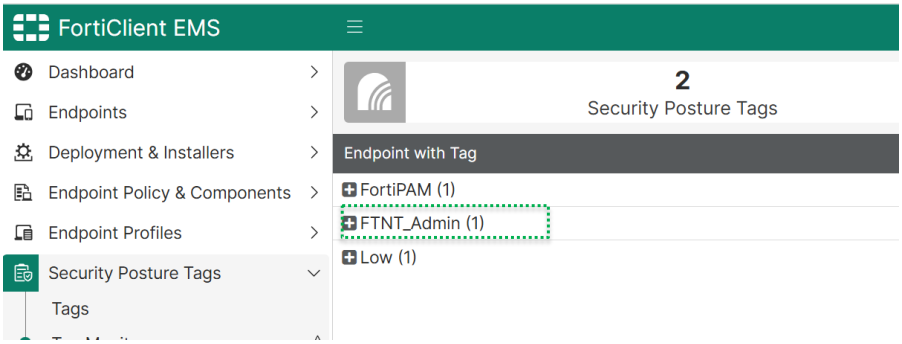


Note that checking for the presence of a file has just been done for convenience in this workshop. The tag could be configured using any of the methods supported by FCT/EMS such as membership of an AD group or requiring FortiEDR to be installed.

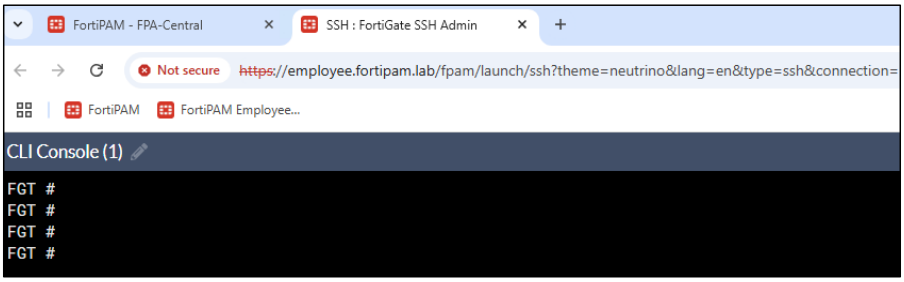
After creating the file, you will need wait until the *FTNT-Admin* tag is updated on the client, EMS and FortiPAM. This should take no more than 5 minutes.



Once the tag has updated on FortiClient, check the EMS Zero Trust Tag Monitor.



Launch the *FortiGate SSH Admin* secret again, this time it should work.


FortiPAM - FPA-Central
SSH : FortiGate SSH Admin
Not secure
https://employee.fortipam.lab/fpam/launch/ssh?theme=neutrino&lang=en&type=ssh&connection=
FortiPAM
FortiPAM Employee...
CLI Console (1)
FGT #
FGT #
FGT #
FGT #

8 Password Handling in FortiPAM

If starting here please upload FPAM_1-8_02 configuration into FPAM, this will not add tags to EMS or install FCT on the windows WS but those are not needed for the following exercises.

Commented [VR11]: Did change it to red

8.1 Overview of FortiPAM Password Handling

FortiPAM employs a comprehensive approach to password handling, ensuring that privileged credentials are not only stored securely but also managed throughout their entire lifecycle. Here's a detailed breakdown of how it works.

Secure Password Storage (Encryption at Rest)
All credentials, such as passwords and private keys, are stored in an encrypted format. This ensures that the actual credentials are protected and cannot be viewed by unauthorized users, including those with viewer-level access. The security of this storage is built on two key concepts:

- **Encryption Key:** FortiPAM encrypts all stored passwords and private keys using a private key. By default, a predefined generated key is used, but you can enhance security by configuring a custom private encryption key of your own (32 hexadecimal numbers) through the CLI. This ensures that the key is only known to your organization.
- **Trusted Platform Module (TPM):** For enhanced security, FortiPAM models equipped with a TPM can store the primary encryption password on the TPM hardware itself, providing an additional layer of protection against software-based attacks.

Password Lifecycle Management (Changing & Rotating)
Once a password is stored, FortiPAM manages its lifecycle by allowing you to change it either manually or automatically. This process is powered by **password changers**, which are configurable components for different target systems like Active Directory, various Linux/Unix systems, Cisco devices, and ESXi hosts.

- **Manual Change:** You can manually change a password for a secret at any time. FortiPAM allows you to either have the system generate a strong, random password or enter a custom password of your own. As a security measure, manual changes are rate-limited to once every 30 seconds.
- **Automatic Change:** You can schedule passwords to rotate automatically by enabling **Automatic Password Changing** when creating or editing a secret. This is a core feature for enforcing a strong password rotation policy without manual intervention.

Password Generation Rules (Password Policies)
To ensure all new passwords are strong and compliant with your organization's security standards, FortiPAM uses **Password Policies**. These policies are applied to secret templates when a password changer is enabled.

You can create a policy to enforce the following criteria:

- **Minimum Length:** From 8 to 64 characters.
- **Maximum Length:** Up to 64 characters.
- **Character Requirements:** Mandate that the password must include a minimum number of:
    - Uppercase letters (A, B, C...)
    - Lowercase letters (a, b, c...)
    - Numbers (1, 2, 3...)
    - Special characters (!, @, #, $, %, ^, &, *, (,)...)

The default password policy comes with a minimum length of 10 and a maximum length of 20 characters.

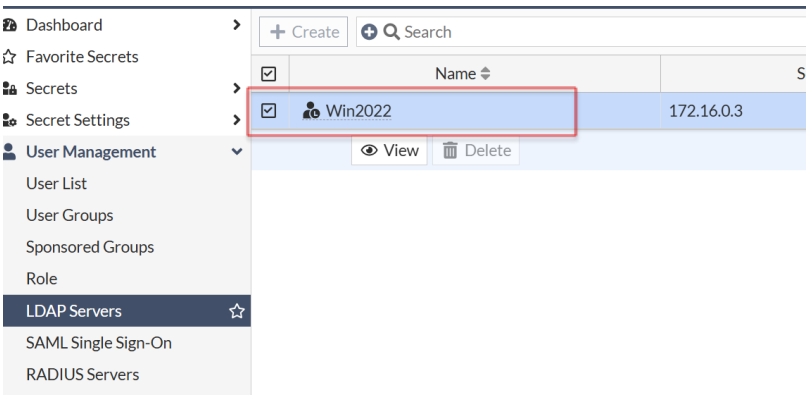
Handling Failures and Out-of-Sync Credentials
One of the challenges of automated password management is when the password stored in FortiPAM becomes out of sync with the one on the target server (e.g., due to a network failure during a change). FortiPAM provides robust tools to handle these situations through its **Credential History** feature.

- **Credential History:** FortiPAM retains a history of previous passwords for each secret. If a password change fails, the last attempted credential is kept in this history .
- **Restoration:** You can go to the **Credential History** tab for a secret, verify a previous password against the remote server, and if successful, easily restore it to FortiPAM. This ensures administrators can quickly resolve out-of-sync issues without manual password resets on the target system.

8.2 Setting up Password changing

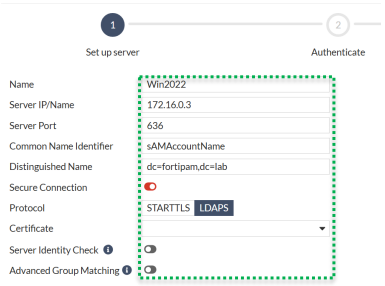
We support a variety of password handlers for a variety of systems, however for this training we are going to focus on Active Directory and LDAPS.

The first step in all password actions with Active Directory is to make sure that the Authentication server that is configured is set to LDAPS. Login as pamadadmin Go to User Management > Ldap Servers and double click on the configured windows server.



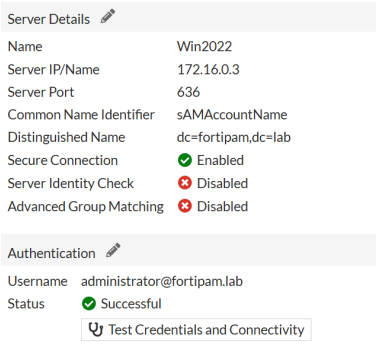
After double clicking make sure that the LDAP server is set to the following settings and if not change it.

Name	**Win2022**
Server IP	**172.16.0.3**
Server Port	**636**
Common Name Identifier	**sAMAccountName**
Distinguished Name	**dc=fortipam,dc=lab**
Secure Connection	**Enabled**
Protocol	**LDAPS**
Certificate	**Leave Blank**
Server Identity	**disabled**
Advanced Group Matching	**disabled**



Press Next

And test the connection with the filled in credentials. It should give you a successful message, once done you should see the following if so press submit



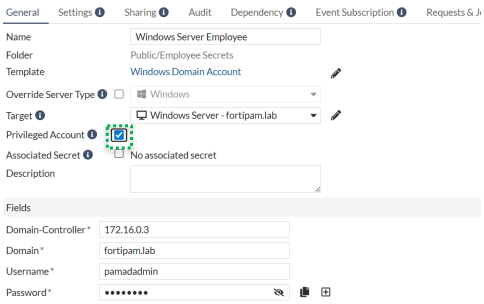
Now that we have enabled the LDAPS on the windows server we can do password changing to those secrets that use Active Directory accounts.

8.3 Password changing and reconciliation

Standard password changing is based on performing a password change on the user account that is used in the secret. This requires that an AD account has remote password changing permissions. There are many cases where it is preferable not to grant such permissions to the account used in the Secret. Additionally, there are cases where a password change may not be successful and the passwords in AD and FortiPAM get out of sync. FortiPAM has the Password Reconciliation feature, which can synchronize the password between AD and FortiPAM using a Secret that has privileged access to AD. Alternatively, this privileged Secret can be configured to always do the password changing for other Secrets, removing the need to give the account remote password changing permissions in AD.

You need to create another secret that uses a normal user in the credential. You will then use the password reconciliation feature to manage the password changing for this credential.

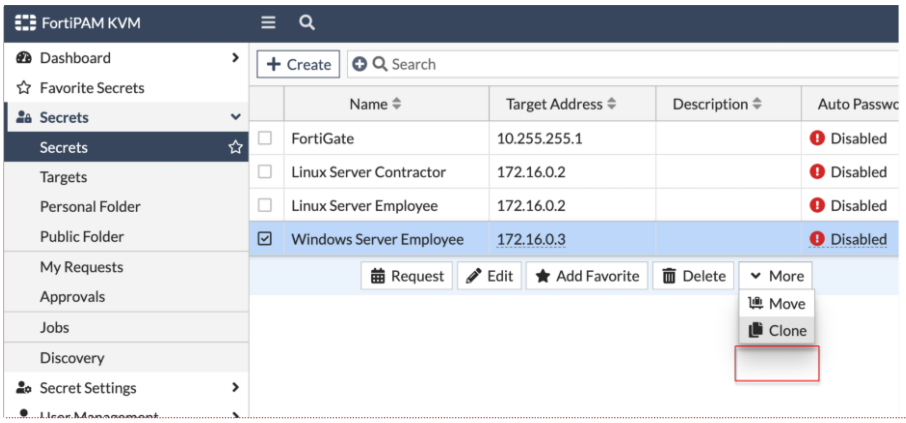
Make sure to log in as pamadadmin , currently, the *Windows Server Employee* secret uses *pamadadmin* as the credential and this Secret is configured as the *Privileged Account*:



This is the Secret (and credential) that you will use to perform the Password Reconciliation. check if ZTNA is turned on for the secret if so turn it off. We do not need it for this exercise and check that it is set as privileged account.

1. Create Windows Server Secret

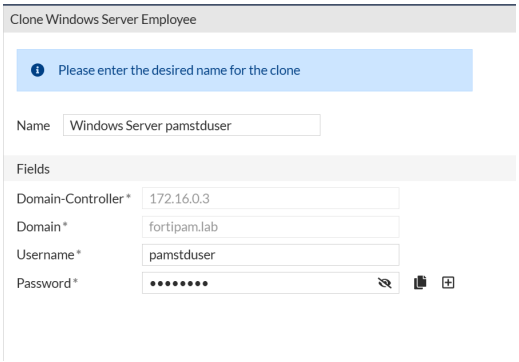
Clone the *Windows Server Employee* secret



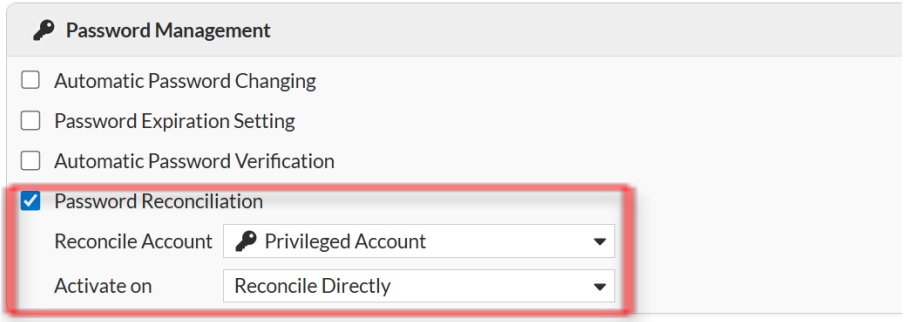
Commented [VR12]: Removed reference to knock

Change the name and *Username* for the credential

Name	**Windows Server pamstduser**
Domain-Controller	*172.16.0.3*
Domain	*fortipam.lab*
Username	**pamstduser**
Password	**F0rtiPAM**

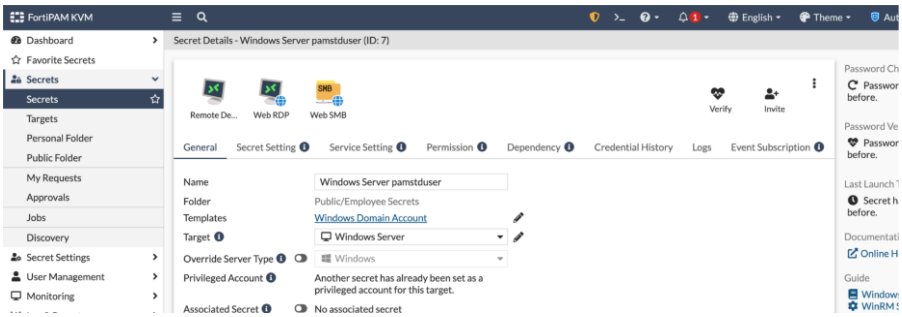


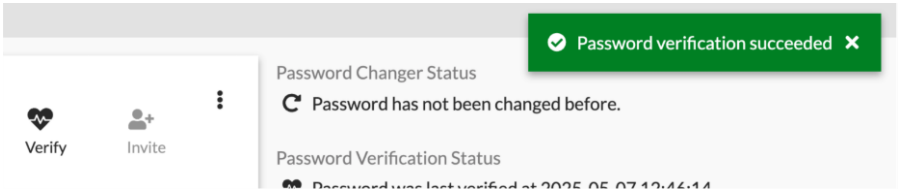
Edit the Secret settings for this new secret, disable Approval and enable Password Reconciliation:



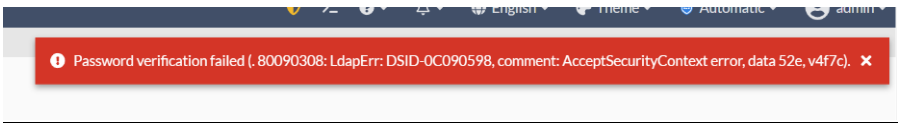
FortiPAM will automatically use the privileged account that has been set for this target. You can overwrite this with another account if so desired, select *Reconcile Directly*.
This option will always use the *Reconcile Account* to change the password. This is the same as resetting a user's password using an admin account. The other option, *Upon Password Change Failure*, will only use the *Reconcile Account* to synchronise the password between AD and FortiPAM if the password change fails.

Automatic Password Changing would normally be enabled also, but we don't need to enable that to test. Save the changes and then Verify the password: If the password has been set correctly then you will get a successful message at verification.

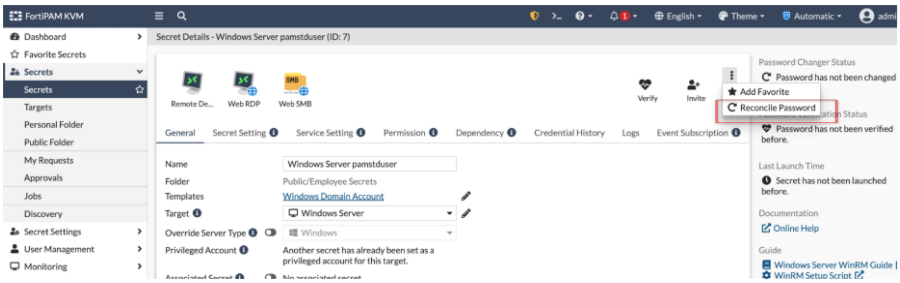




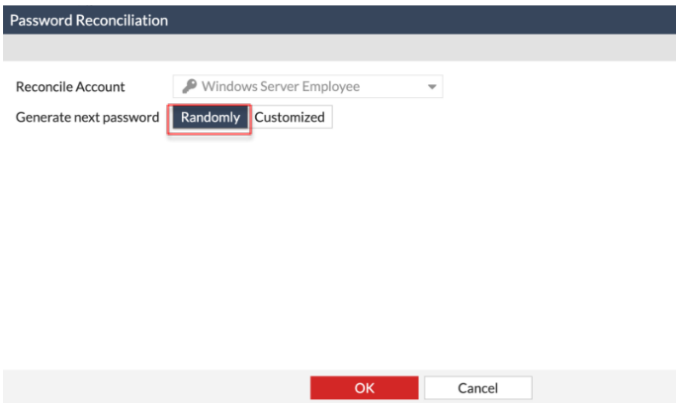
If it has not been set correctly you will get



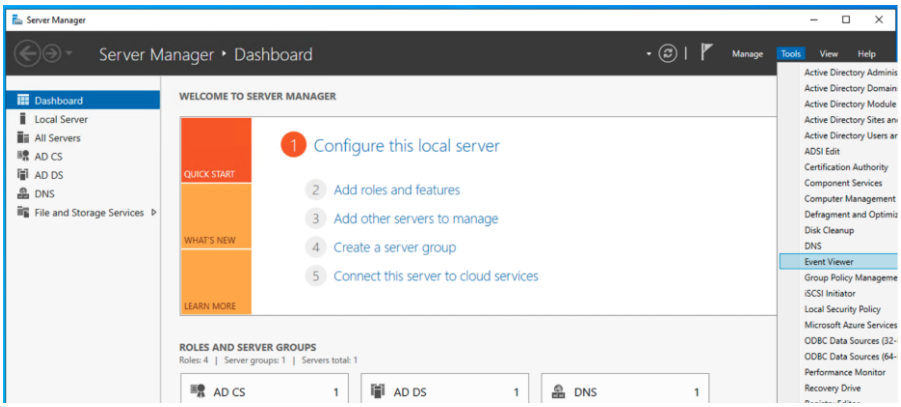
Both options are fine. Now choose the *Reconcile Password* option:

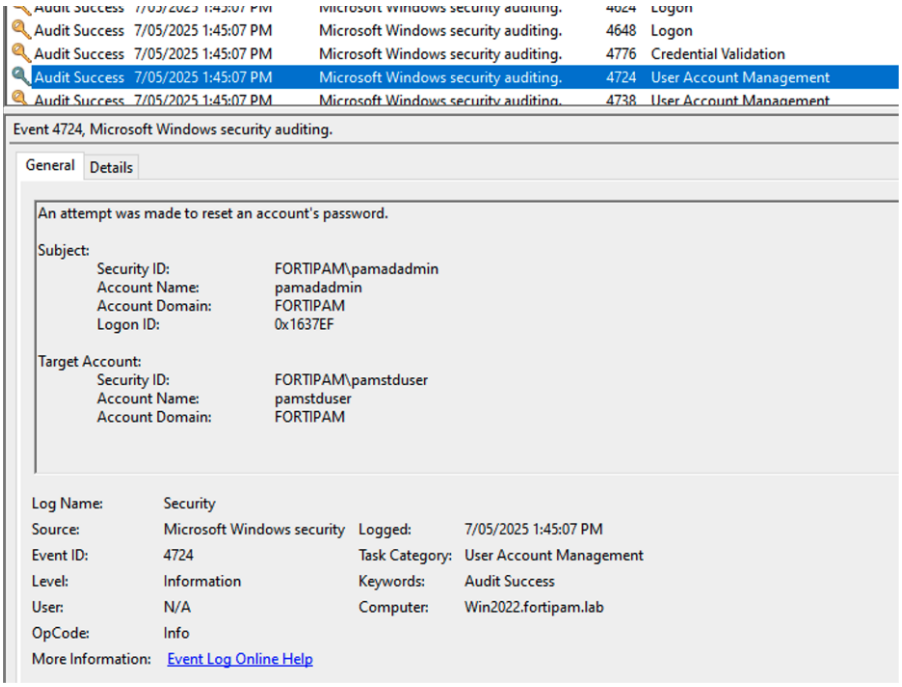


Accept the default to generate the password randomly:

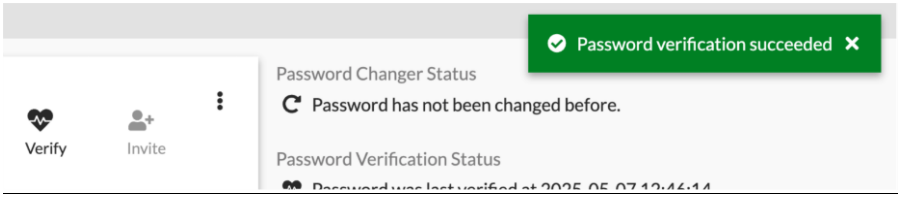


If you now connect to the Windows server you can verify that a password change happened (optional):

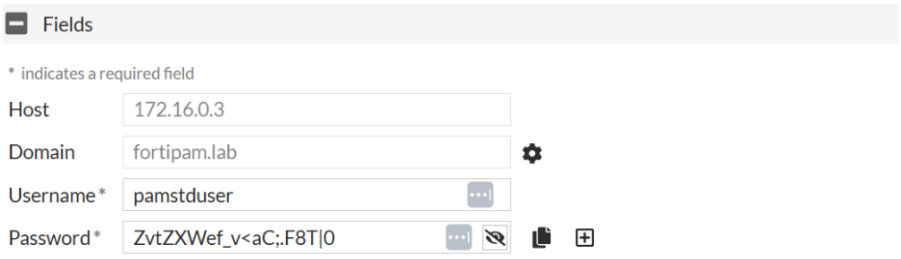




We are now fully in control of the password, and we have just reset the password based on the password policy in FPAM. We can now verify the password, and it will give a password verification message successfully.

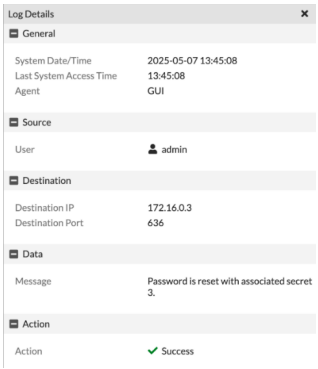


You can also always check what the password is by clicking on the eye icon (if your role has the right to see encrypted information)



Logs/Debugs

Go to the *Logs* tab in the *Windows Server pamstduser* secret and review the log message for "*Password Changed*". Note that states the password has been reset with the associated secret.

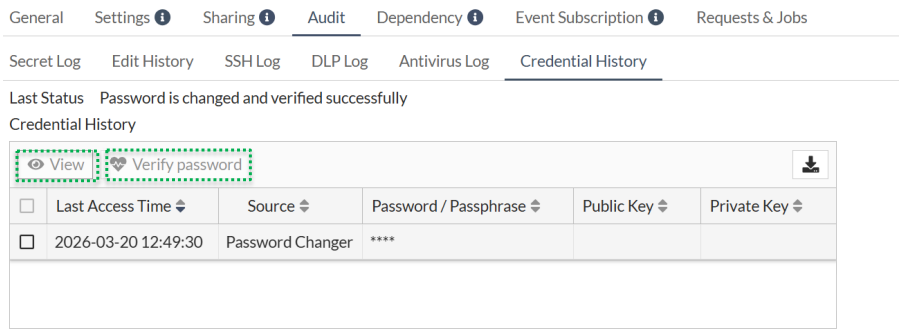


Enable password changing debugs and reconcile the password again so you can see the debugs:

```
FPA-Central # diag wad deb enable category pwdchg
Debug messages will be on for 30 minutes.

FPA-Central # diag deb en

FPA-Central # [I][p:4320][s:180753428][r:16798694] wad_gui_password_handler          :6045  POST to password verify
[I][p:4320]               wad_gui_api_pwd_chg_notify        :5064  recv pwd change resp result=1, code=1, err=
[I][p:4320]               wad_http_pwd_chg_continue         :5890  Password reconciliation succeeded
[I][p:4320]               wad_http_pwd_chg_continue         :5932  attach response body to response
[]
```

One of the nice features of FortiPAM is that we keep a full credential history of all passwords used so that we can revert back to previously used password if something happens. For example, a restore of a target has happened and it has set the password back to a previous version. We could of course use password reconciliation but sometimes we might want to use a previous password.

In the secret if you select audit > credential history you can view the previously used password and verify them to make sure they have been changed.

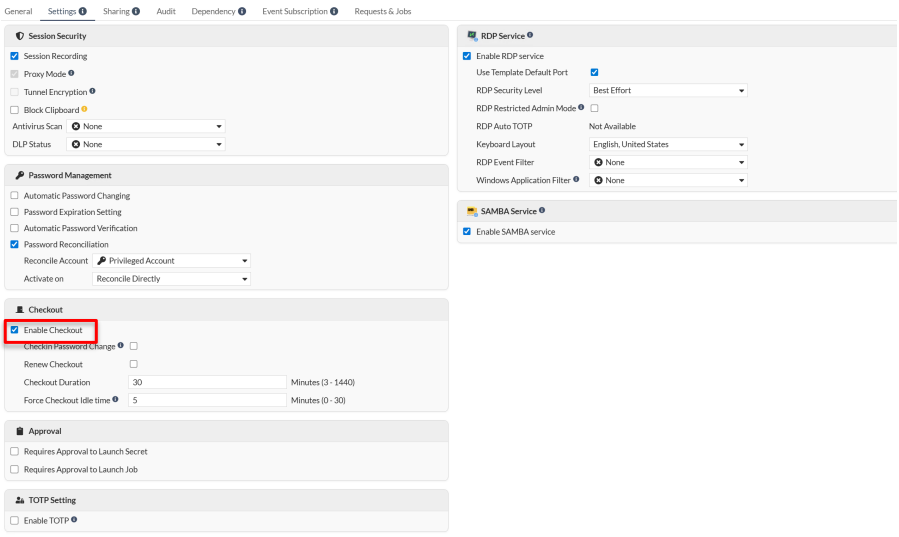


9 Advanced FortiPAM Settings

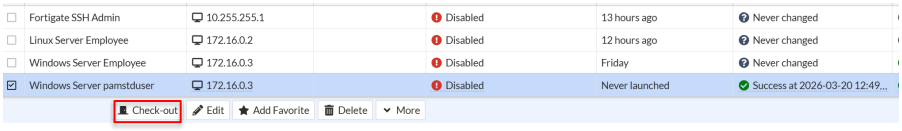
9.1 CheckOut & CheckIn

In some scenarios, it is not desirable to have multiple administrators configuring a system at the same time. Maybe there is a medium to high-risk change happening during a change window, so the organization does not want the additional risk of multiple administrators making changes at the same time. This is where the *Checkout* feature can be used.

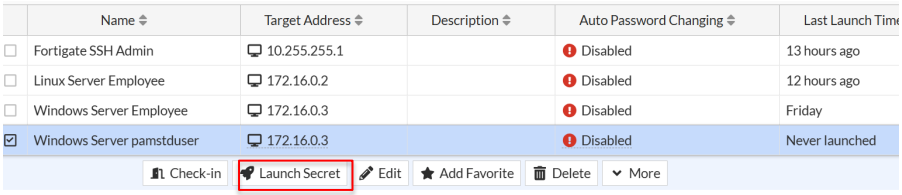
Login to FortiPAM GUI as ***pamadadmin*** and go to *Secrets* > *Secrets*. Edit the *Windows Server pamstduser >settings* and enable *Requires Checkout*. Leave the default Checkout Duration at 30 minutes and save the changes.



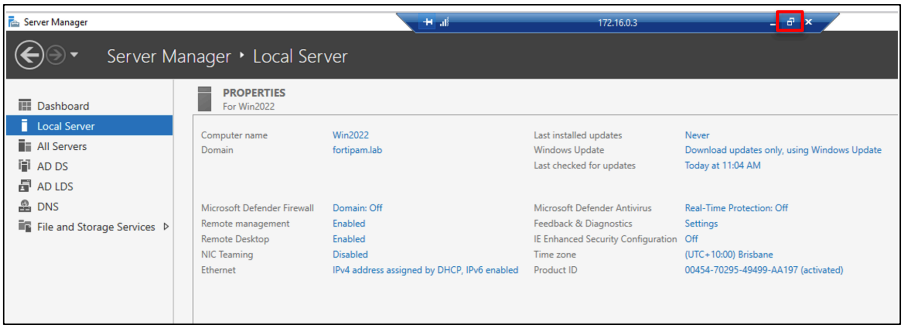
Login to https://employee.fortipam.lab on the Windows Workstation as ***pamaduser***. Notice now that the *Launch Secret* button is not available and there is now a *Check-out* button. Click it.



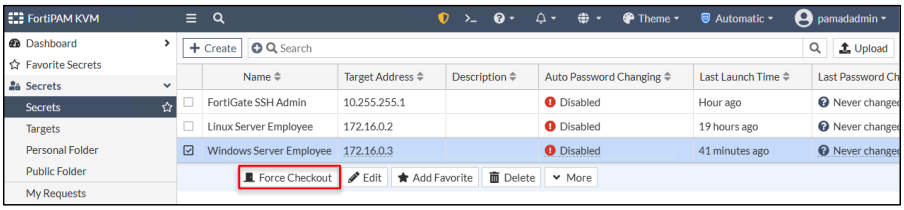
Now the *Launch Secret* button is available. (If you can't see Launch Secret, click same secret) Launch the secret.



If you used the native RDP client take the RDP session out of full screen mode:



Open an Edge browser and login to FortiPAM as a different user, eg. *pamadadmin*. Select the *Windows Server Employee* secret and you will see that you can't check it out or launch it while it has been checked out by a different user:



You can force the check-out of the secret. Sometimes users do not check-in secrets leaving them unavailable for other users. This is a simple way to force check-out a secret to fix that situation, if you want you can now force the check out and you will see the secret is available again. You can perform a Force checkout by waiting 5 minutes of idle time.

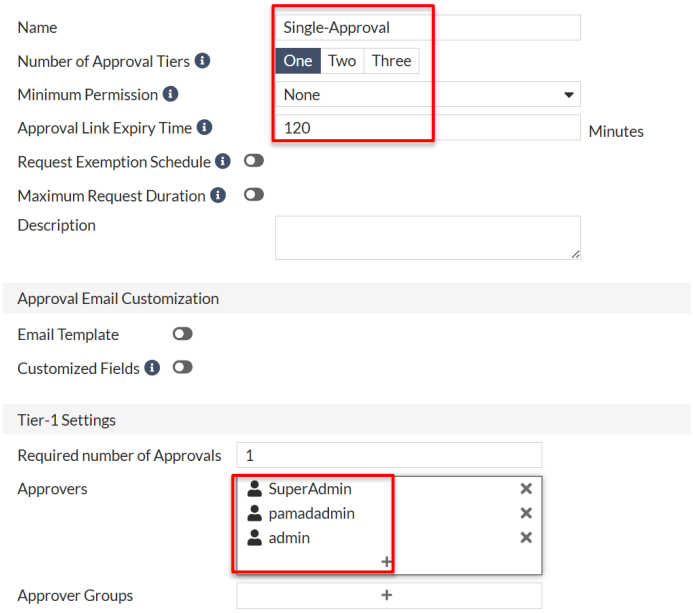
9.2 Approvals

It may be desirable to require approval before access to certain privileged systems is granted. FortiPAM supports *Approval Profiles* with single, dual, and three tier approvals. When a user needs to launch a secret that requires approval, they must first submit a request and wait for the required number of approvers to approve the request before they will be able to launch the secret.

Login to FortiPAM GUI as *pamadadmin* and go to *Secret Settings* > *Approval Profile* and click *Create*. Use the following configuration:

- Name: ***Single-Approval***
- Number of Approval Tiers: ***One***
- Minimum Permission ***None***
- Approval Link Expiry Time: ***120***
- Required Number of Approvals: ***1***
- Approvers: ***SuperAdmin, pamadadmin***
- Save your changes.

With this configuration, 1 approval is required from any user listed in the *Approvers* or *Approver Groups*.



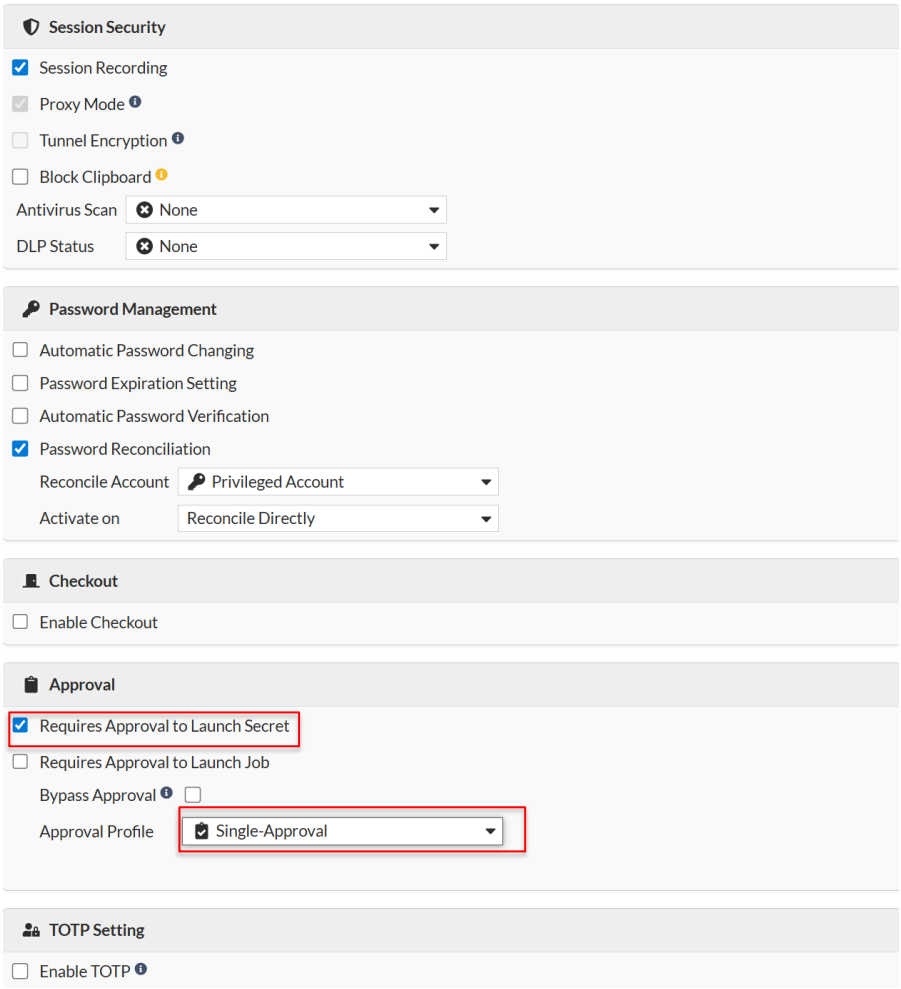
In a Two-Tier approval flow, after the required number of approvers in the first tier has approved the request, the Tier-2 approvers will have to approve it. As an example, Tier-1 could require only one approver, while Tier-2 could require two/three/ten approvers before the user can launch the secret. A three-tier flow then adds another tier. Approvers are notified via email as well as via a visual indication in the FortiPAM GUI.

The minimum Permission entry is to set the level of minimum permission of the secret that is required to be able to approve the access to the secret. An example will clarify this, we have a secret called Linux employee. The pamadmin has edit permission for this secret, if we set the minimum permission level to edit it means that only people with the edit permission so in this

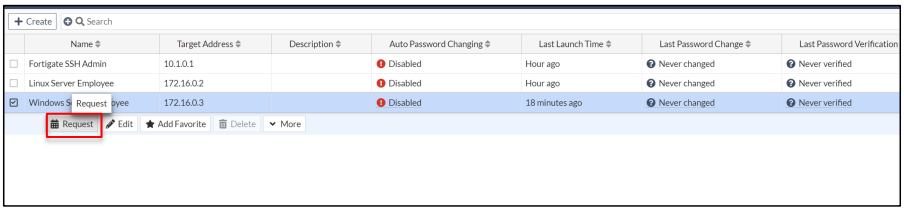
case the pamadmin can approve request to access the secret. Sometimes we want to split administrating the secret and approving access to the secret, for example we might have a businessowner who want to approve the access but is not interested in having access. In this case we set the minim permission to none. This gives us the ability to split business approvals from technical approvals.

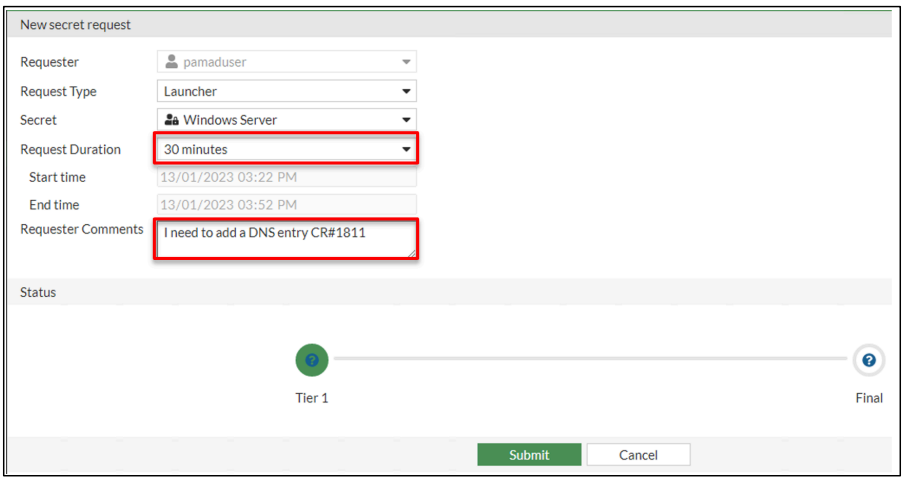
Lastly is the link approval time, we can send a link to automatically approve the access, again especially handy of business owners really do not want to login into FPAM to approve access, however we do want a time limit on it for security reasons.

Edit the ***Windows Server pamstduser*** secret and enable the approval flow (and remove enable check out), selecting the profile you just created.

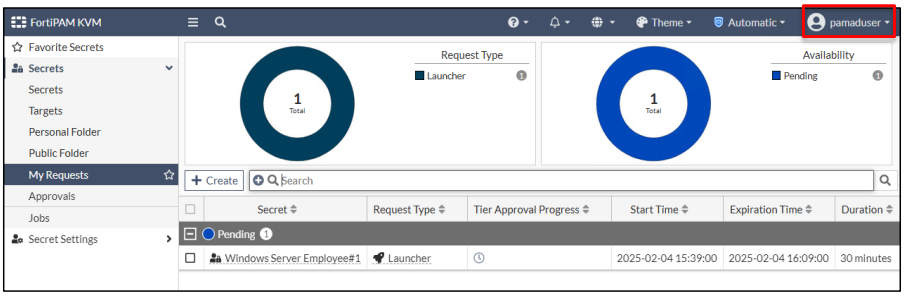


Login to _https://employee.fortipam.lab on the Windows Workstation as ***pamaduser***. Select the *Windows Server Employee* secret and make the approval request. Leave a comment for the approvers – eg. it could be a short message with a change request number. Click *Submit*.

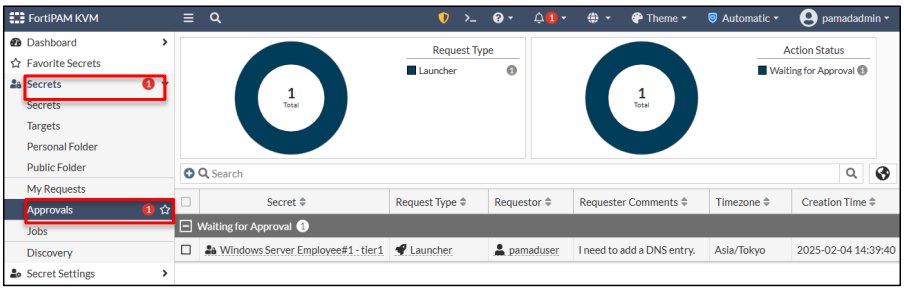




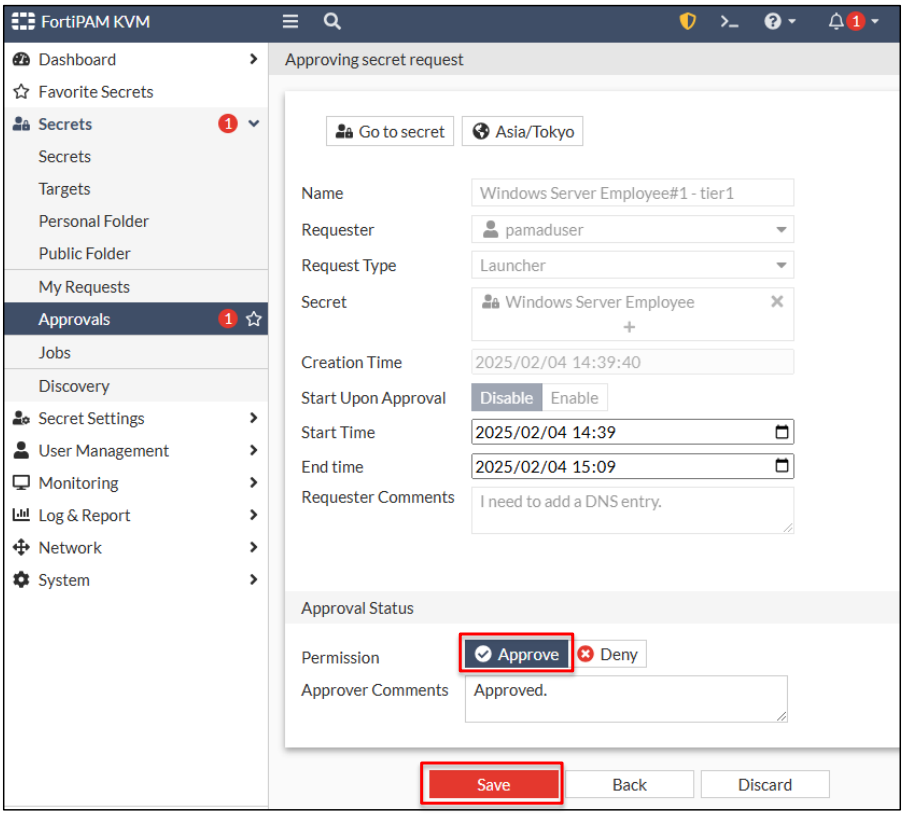
go to *My Request List* page:



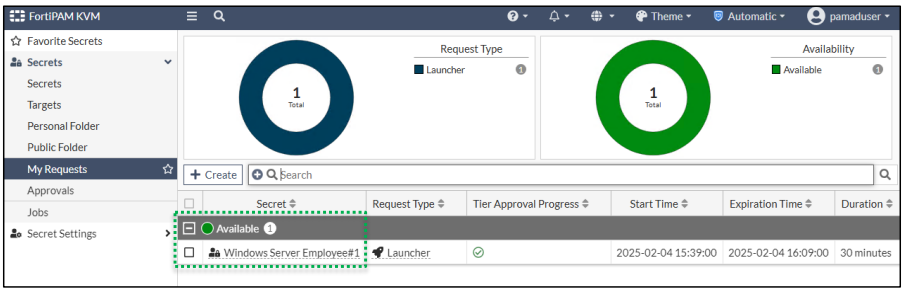
Login to FortiPAM GUI as ***pamadadmin*** . Note the notification indication next to *Secrets* > *Approvals*:



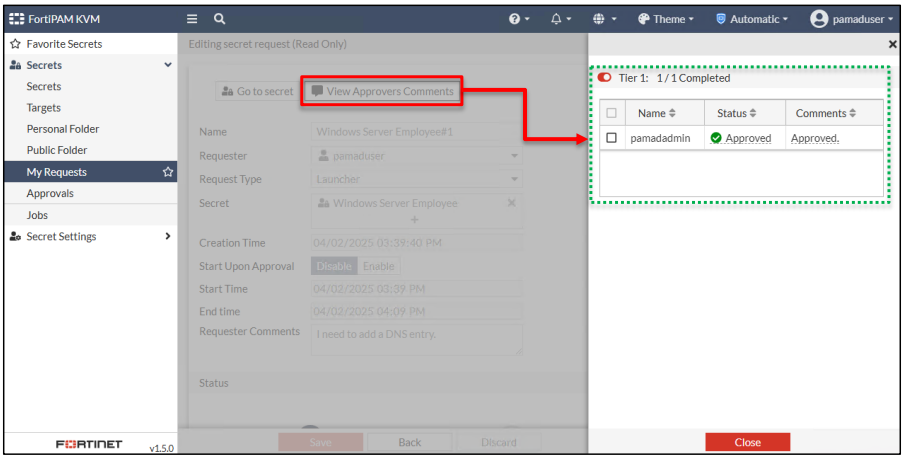
Go to *Secrets* > *Approvals* and edit the request. Approve the request and leave a comment. Don't forget to click Save. Note that the approver can potentially approve multiple secrets and also edit the start time.



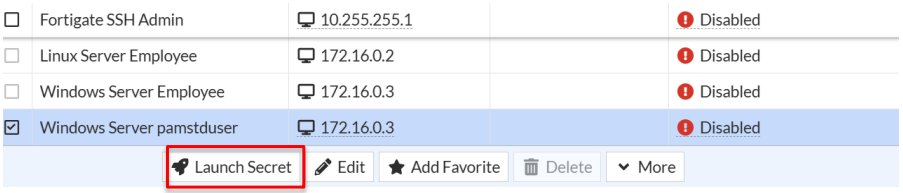
Login to https://employee.fortipam.lab on the Windows Workstation as ***pamaduser***. Go to *Secrets* > *My Request List* and note that it is now green and marked as available.



Open the request to read the comments left by the Approver by clicking the *View Approvers Comments* button.



Click the *Go to secret* button. You can now Launch the secret.



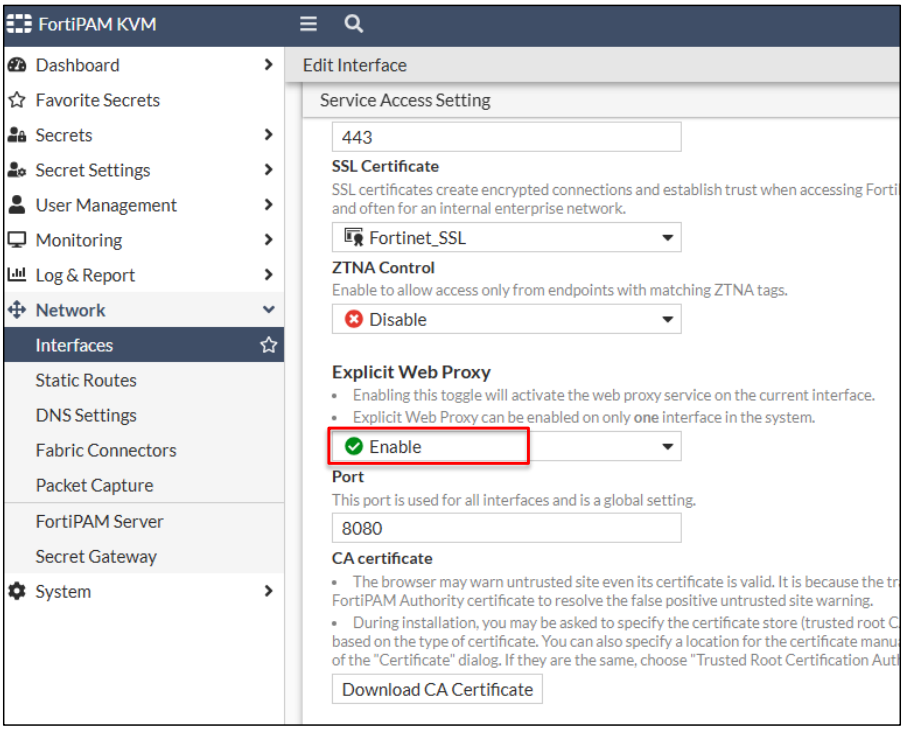
9.3 FortiPAM Web Proxy for Web Launcher

The FortiPAM explicit web proxy can be used for Web Launchers. This allows FortiPAM to provide a fake password to the browser extension and then intercept the session via the explicit proxy to replace the fake password with the real password. Therefore, the real password is only sent between FortiPAM and the target host. The browser/endpoint can never intercept the real password.

The explicit proxy does not need to be explicitly defined on the endpoint. The *Fortinet Privileged Access Agent* dynamically updates the browser/OS to use the proxy only for the IP addresses/FQDNs specified in the Secret Target configuration. Version 7.2.3 or more recent of the browser extension is required for this feature.

9.3.1 Enable Explicit Proxy on the Interface

Close the FortiGate GUI window. On FortiPAM go to *Network* > *Interfaces* and edit *port2.* Enable *Explicit web proxy* and save the changes. This configures FortiPAM to listen on the default Explicit Proxy port for web proxy connections.



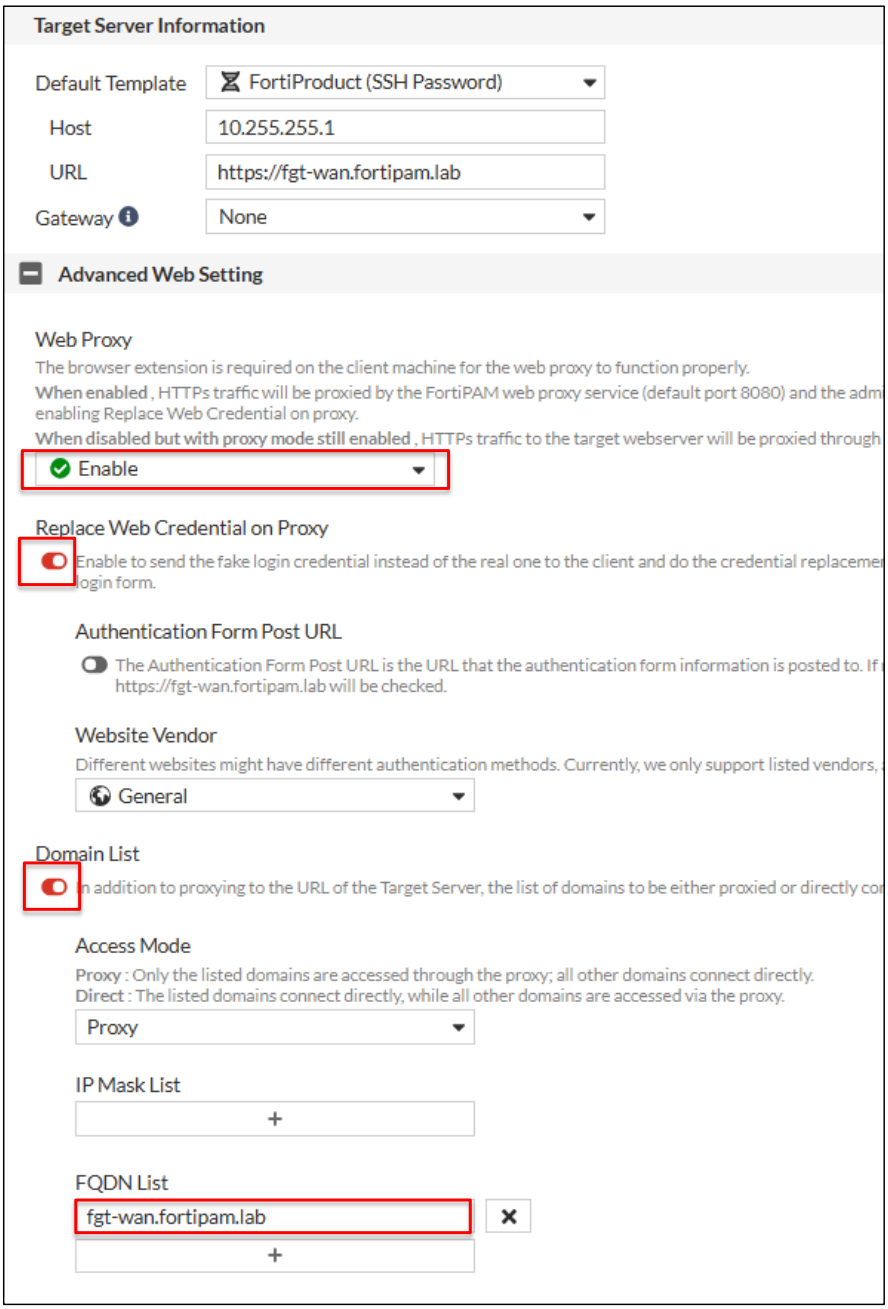
Important note: the web proxy feature is enabled on only one interface. You must configure the FQDN for the web proxy interface:

```
config web-proxy global
  set proxy-fqdn pam.fortipam.lab
```

and make sure DNS resolves that FQDN to the correct IP.

9.3.2 Enable Web Proxy on the Target

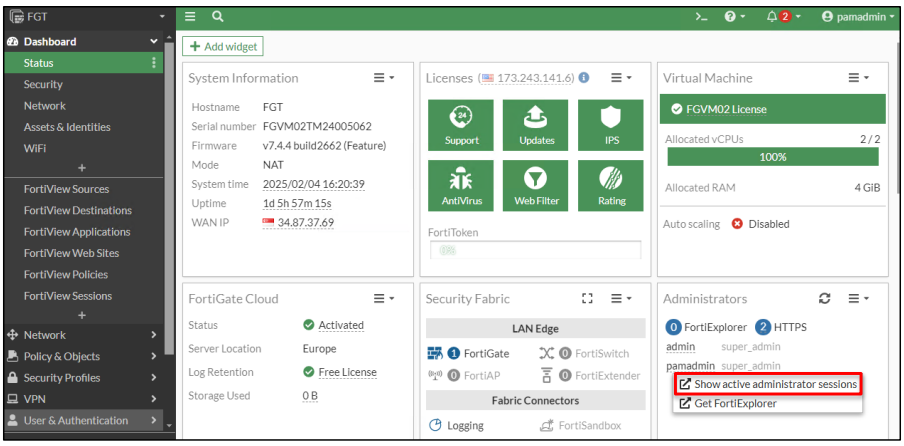
Go to *Secrets > Targets* and edit the *FortiGate* target. Enable *Web Proxy*, enable *Domain List* and add the FortiGate IP address in the IP Mask List with *Proxy* Access Mode. Save the changes. Make sure *Replace Web Credential on Proxy* is enabled. The *Domain List* setting configures the IP addresses/FQDNs (*fgt-wan.fortipam.lab*) that the browser extension will dynamically configure to use the web proxy on FortiPAM.


Target Server Information
Default Template
FortiProduct (SSH Password)
Host
10.255.255.1
URL
https://fgt-wan.fortipam.lab
Gateway
None
Advanced Web Setting
Web Proxy
The browser extension is required on the client machine for the web proxy to function properly.
When enabled , HTTPs traffic will be proxied by the FortiPAM web proxy service (default port 8080) and the adm
enabling Replace Web Credential on proxy.
When disabled but with proxy mode still enabled , HTTPs traffic to the target webserver will be proxied through
Enable
Replace Web Credential on Proxy
Enable to send the fake login credential instead of the real one to the client and do the credential replacemer
login form.
Authentication Form Post URL
The Authentication Form Post URL is the URL that the authentication form information is posted to. If
https://fgt-wan.fortipam.lab will be checked.
Website Vendor
Different websites might have different authentication methods. Currently, we only support listed vendors,
General
Domain List
In addition to proxying to the URL of the Target Server, the list of domains to be either proxied or directly cor
Access Mode
Proxy : Only the listed domains are accessed through the proxy; all other domains connect directly.
Direct : The listed domains connect directly, while all other domains are accessed via the proxy.
Proxy
IP Mask List
+
FQDN List
fgt-wan.fortipam.lab
+

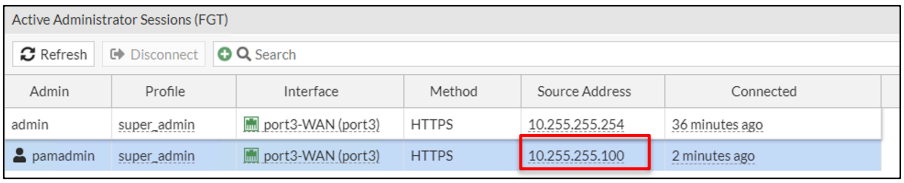
9.3.3 Test Web Launcher with Explicit Web Proxy Enabled

Login to *https://employee.fortipam.lab* on the Windows Workstation as ***pamaduser***. Launch the *FortiGate SSH Admin* secret using the Web Launcher.

On the FortiGate dashboard go to the Administrators widget, click on *pamadmin* and select *Show active administrator sessions*



Check the source address is the IP address of the FortiPAM interface:



9.3.4 Custom HTTPS Ports on Targets

This section is purely for information purposes, we do not need to configure this in the lab, however it is something that will happen quite frequently in production or POC's.

If a custom port is used for the target, for example configuring FortiGate GUI management to use port 11443 instead of 443, the *ssl-ssh-profile* must be configured with this custom port. If multiple targets use different custom ports, add each custom port. The default *deep-inspection* profile cannot be modified, so you will need to edit the *custom-deep-inspection* profile and then config that on the explicit-web firewall policies:

CLI Console (1)

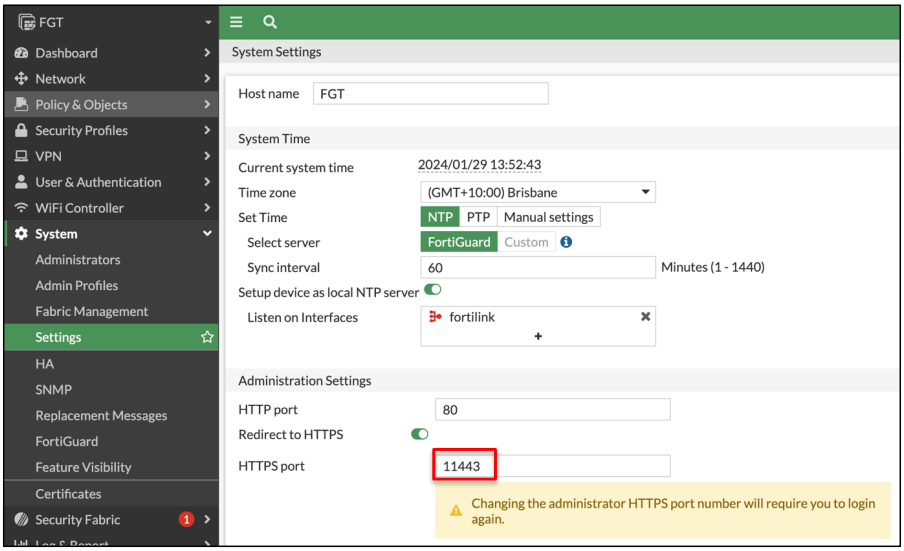
```
FPA-Central # config firewall ssl-ssh-profile

FPA-Central (ssl-ssh-profile) # edit custom-deep-inspection

FPA-Central (custom-deep-insp~ion) # config https

FPA-Central (https) # set ports 443 11443 13443

FPA-Central (https) # end

FPA-Central (custom-deep-insp~ion) # show
config firewall ssl-ssh-profile
    edit "custom-deep-inspection"
        set comment "Customizable deep inspection profile."
        config https
            set ports 443 11443 13443
            set status deep-inspection
        end
```

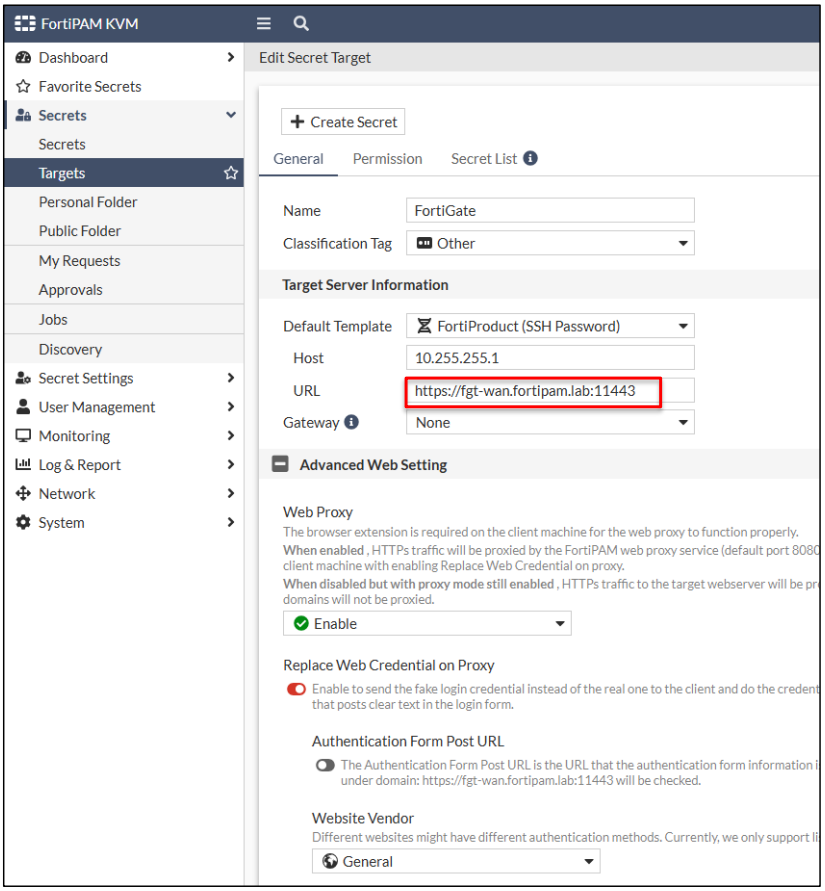
```
FPA-Central # config firewall policy

FPA-Central (policy) # edit 1001

FPA-Central (1001) # show
config firewall policy
    edit 1001
        set type explicit-web
        set uuid 2379ebf2-e1c5-51ef-b2f9-4b6f62f52463
        set dstintf "any"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set service "webproxy"
        set explicit-web-proxy "web-proxy"
        set groups "SSO_Guest_Users"
        set ssl-ssh-profile "deep-inspection"
    next
end

FPA-Central (1001) #
```

```
FPA-Central # config firewall policy

FPA-Central (policy) # edit 1002

FPA-Central (1002) # show
config firewall policy
    edit 1002
        set type explicit-web
        set uuid 237a18c0-e1c5-51ef-bf49-e891e87ebb4e
        set dstintf "any"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set service "web-connect"
        set explicit-web-proxy "web-proxy"
        set ssl-ssh-profile "deep-inspection"
    next
end

FPA-Central (1002) #
```

Your explicit-web firewall policies may have a different policy ID so make sure you are editing the correct policy.

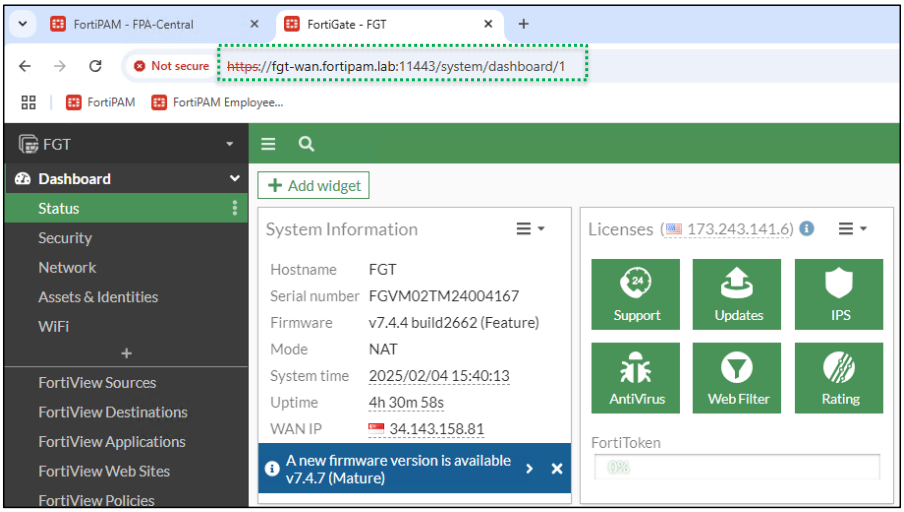
Now if you change the FortiGate HTTPS port to 11443, and update the URL on the Target on FortiPAM, the FortiPAM Web Launcher will work with the Web Proxy mode:


FGT
Dashboard
Network
Policy & Objects
Security Profiles
VPN
User & Authentication
WiFi Controller
System
Administrators
Admin Profiles
Fabric Management
Settings
HA
SNMP
Replacement Messages
FortiGuard
Feature Visibility
Certificates
Security Fabric
System Settings
Host name
FGT
System Time
Current system time
2024/01/29 13:52:43
Time zone
(GMT+10:00) Brisbane
Set Time
NTP
PTP
Manual settings
Select server
FortiGuard
Custom
Sync interval
60
Minutes (1 - 1440)
Setup device as local NTP server
Listen on Interfaces
fortilink
Administration Settings
HTTP port
80
Redirect to HTTPS
HTTPS port
11443
Changing the administrator HTTPS port number will require you to login again.



9.3.5 Test Custom HTTPS Ports on Targets with Explicit Web Proxy Enabled

Login to *https://employee.fortipam.lab* on the Windows Workstation as ***pamaduser***. Launch the *FortiGate SSH Admin* secret using the Web Launcher.



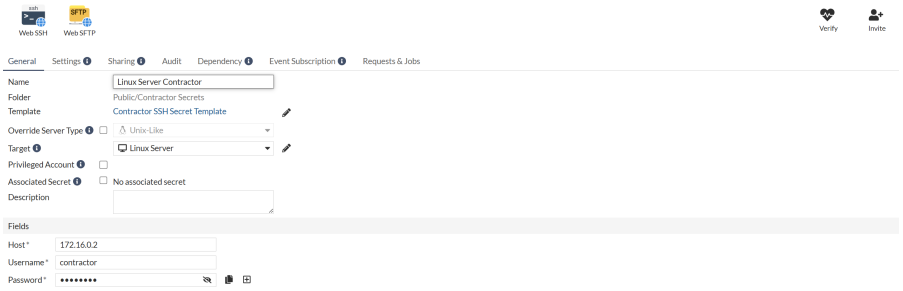
9.4 Invite External User – One-time Invitation

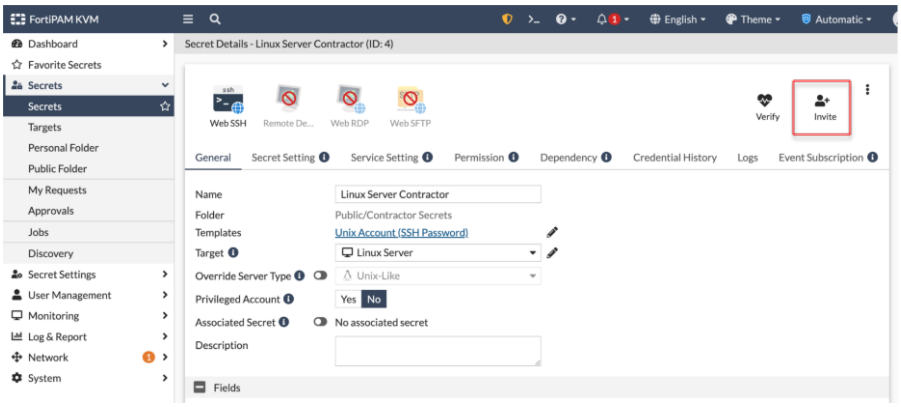
To enhance secure collaboration and controlled access, FortiPAM has a One-Time Invitation Feature that allows a secret owner to share a specific secret with an external user through a time-bound, single-use invite code.

Note: This feature requires a license for the duration of the invite and strict access policies to maintain security and compliance.

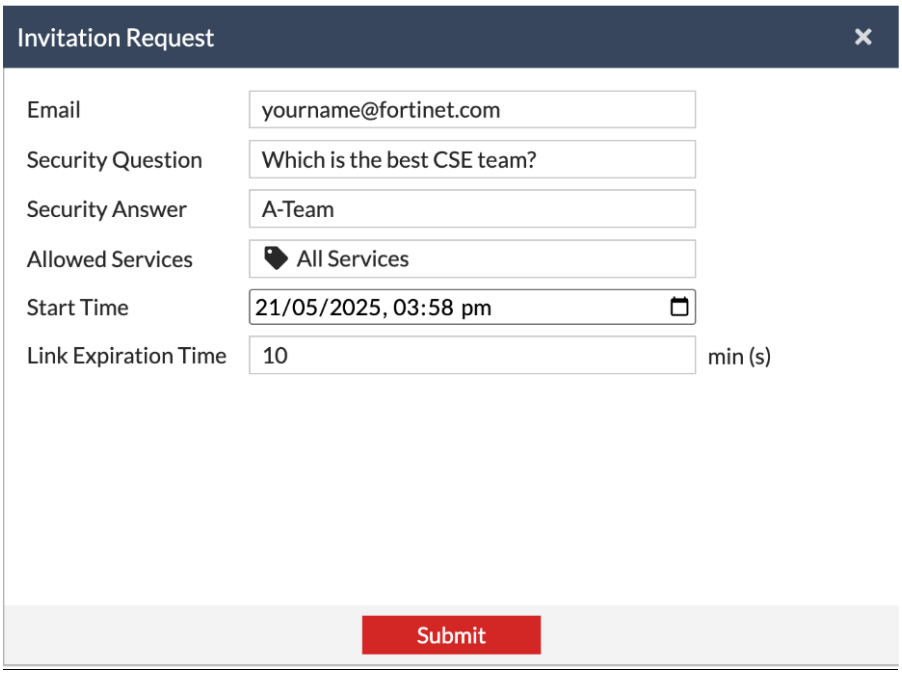
An *Invite* button available when a secret owner opens the secret.

Login to FPA-Central as SuperAdmin and open the *Linux Server Contractor* Secret. You will notice there is an *Invite* button at the top right:

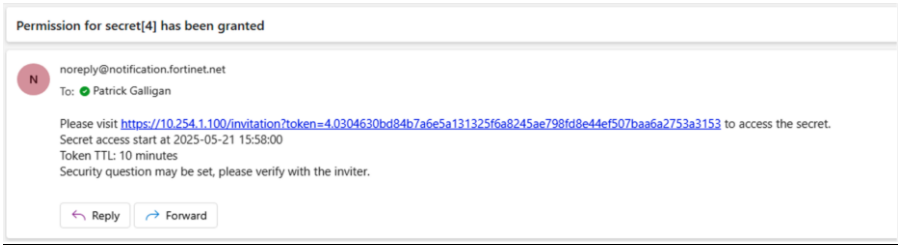




Click the *Invite* button and fill out the details and click *Submit*. Use an email account that you will be able to access via web browser from the Windows 11 workstation within Fabric Studio.



Open the received email (from the Windows 11 workstation within Fabric Studio):



Click the link and enter the security answer in the *Token* field:

You will be logged in and granted access to the Secret.